GUÍA TÉCNICA COLOMBIANA

GTC-ISO/IEC 27002

2022-10-19

Primera actualización

Seguridad de la información, ciberseguridad y protección de la privacidad. Controles de seguridad de la información

E: Information security, cybersecurity and privacy protection. Information security controls

CORRESPONDENCIA: esta Guía Técnica Colombiana es idéntica (IDT) por traducción de la ISO-IEC/ 27002: 2022 y está cubierta por los derechos de autor y otros derechos de propiedad intelectual de IEC, según el acuerdo de licencia con esta entidad.

DESCRIPTORES: seguridad de la información; ciberseguridad; protección de la privacidad.

I.C.S.: 35.030

® ICONTEC 2022

Reservados todos los derechos. Ninguna parte de esta publicación puede ser reproducida o utilizada en cualquier forma o por cualquier medio, electrónico o mecánico incluyendo fotocopiado y microfilmación, sin permiso por escrito del editor.

Editada por ICONTEC. Bogotá, D.C. - Tel. (571) 6078888

Prohibida su reproducción | Editada 2022-10-19

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

PRÓLOGO

El Instituto Colombiano de Normas Técnicas y Certificación, **ICONTEC**, es el organismo nacional de normalización, según el Decreto 1595 de 2015.

ICONTEC es una entidad de carácter privado, sin ánimo de lucro, cuya Misión es fundamental para brindar soporte y desarrollo al productor y protección al consumidor. Colabora con el sector gubernamental y apoya al sector privado del país, para lograr ventajas competitivas en los mercados interno y externo.

La representación de todos los sectores involucrados en el proceso de Normalización Técnica está garantizada por los Comités Técnicos y el período de Consulta Pública, este último caracterizado por la participación del público en general.

Se llama la atención sobre la posibilidad de que algunos elementos de este documento pueden ser objeto de derechos de patente. ICONTEC no asume la responsabilidad por la identificación de dichas patentes, o por la documentación que se haya aportado que goza de esta protección legal.

La guía GTC-ISO/IEC 27002 (Primera actualización) fue elaborada por el CTN 181 Gestión de la tecnología de la información y ratificada por el Consejo Directivo de 2022-10-19.

Este documento está sujeto a ser revisado en cualquier momento con el objeto de que responda a las necesidades y exigencias actuales. Se invita a los usuarios de este documento a presentar sus solicitudes de revisión a ICONTEC; sus comentarios serán puestos a consideración del comité técnico responsable del estudio de este tema.

ICONTEC cuenta con un Centro de Información que pone a disposición de los interesados normas internacionales, regionales y nacionales y otros documentos relacionados.

DIRECCIÓN DE NORMALIZACIÓN

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

CONTENIDO

Página

INTRODUCCIÓN I

0.1 Antecedentes y contexto i

0.2 Requisitos de seguridad de la información ii

0.3 Controles ii

0.4 Determinación de los controles ii

0.5 Elaboración de directrices específicas de la organización iii

0.6 Consideraciones sobre el ciclo de vida iii

0.7 Normas internacionales relacionadas iv

1. OBJETO Y CAMPO DE APLICACIÓN 1

2. REFERENCIAS NORMATIVAS 1

3. TÉRMINOS, DEFINICIONES Y TÉRMINOS ABREVIADOS 1

3.1 Términos y definiciones 1

3.2 Términos abreviados 6

4. ESTRUCTURA DEL DOCUMENTO 8

4.1 Cláusulas 8

4.2 Temas y atributos 9

4.3 Diseño de control 10

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Página

5. CONTROLES ORGANIZACIONALES 11

5.1 Políticas de seguridad de la información 11

5.2 Roles y responsabilidades en materia de seguridad de la información 13

5.3 Segregación de funciones 15

5.4 Responsabilidades de gestión 16

5.5 Contacto con las autoridades 17

5.6 Contacto con grupos de interés especiales 18

5.7 Inteligencia sobre amenazas 19

5.8 Seguridad de la información en la gestión de proyectos 21

5.9 Inventario de información y otros activos asociados 23

5.10 Uso aceptable de la información y otros activos asociados 25

5.11 Devolución de activos 26

5.12 Clasificación de la información 27

5.13 Etiquetado de la información 29

5.14 Transferencia de información 31

5.15 Control de acceso 34

5.16 Gestión de identidad 37

5.17 Información de autenticación 38

5.18 Derechos de acceso 41

5.19 Seguridad de la información en las relaciones con los proveedores 43

5.20 Abordar la seguridad de la información en los acuerdos con los proveedores 46

5.21 Gestión de la seguridad de la información en la cadena de suministro de las TIC 49

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Página

5.22 Monitoreo, revisión y gestión de cambios de los servicios de los proveedores 51
5.23 Seguridad de la información para el uso de servicios en la nube 53
5.24 Planificación y preparación de la gestión de incidentes de seguridad de la información 56
5.25 Evaluación y decisión sobre eventos de seguridad de la información 58
5.27 Aprendizaje de los incidentes de seguridad de la información 60
5.28 Recopilación de evidencias 61
5.29 Seguridad de la información durante la interrupción 62
5.30 Preparación de las TIC para la continuidad de la actividad 63
5.31 Requisitos legales, estatutarios, reglamentarios y contractuales 65
5.32 Derechos de propiedad intelectual 67
5.33 Protección de los registros 69
5.34 Privacidad y protección de la IIP 71
5.35 Revisión independiente de la seguridad de la información 72
5.36 Cumplimiento de las políticas, reglas y normas de seguridad de la información 73
5.37 Procedimientos operativos documentados 74

6. CONTROLES DE PERSONAS 76
6.1 Selección 76
6.2 Condiciones del empleo 78
6.3 Sensibilización, educación y formación en materia de seguridad de la información 79
6.4 Proceso disciplinario 81
6.5 Responsabilidades tras el cese o el cambio de empleo 82

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Página

6.6 Acuerdos de confidencialidad o no divulgación 83
6.7 Trabajo remoto 85
6.8 Informes de eventos de seguridad de la información 87

7. CONTROLES FÍSICOS 88
7.1 Perímetros de seguridad física 88
7.2 Entrada física 89
7.3 Protección de oficinas, salas e instalaciones 92
7.4 Monitoreo de la seguridad física 92
7.5 Protección contra las amenazas físicas y medioambientales 94
7.6 Trabajo en zonas seguras 95
7.7 Escritorio limpio y pantalla limpia 96
7.8 Ubicación y protección de los equipos 97
7.9 Seguridad de los activos fuera de las instalaciones 98
7.10 Medios de almacenamiento 100
7.11 Servicios públicos de respaldo 102
7.12 Seguridad del cableado 103
7.13 Mantenimiento del equipo 104
7.14 Eliminación segura o reutilización del equipo 105

8. CONTROLES TECNOLÓGICOS 107
8.1 Dispositivos finales del usuario 107
8.2 Derechos de acceso privilegiados 110

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Página

8.3 Restricción del acceso a la información 112
8.4 Acceso al código fuente 114
8.5 Autenticación de seguridad 115
8.6 Gestión de capacidad 117
8.7 Protección contra malware 119
8.8 gestión de las vulnerabilidades técnicas 121
8.9 Gestión de la configuración 126
8.10 Eliminación de información 128
8.11 Enmascaramiento de datos 130
8.12 Prevención de la fuga de datos 132
8.13 Copia de seguridad de la información 134
8.14 Redundancia de las instalaciones de tratamiento de la información 136
8.15 Registros 137
8.16 Actividades de monitoreo 141
8.17 Sincronización del reloj 144
8.18 Uso de programas de utilidad privilegiados 145
8.19 Instalación de software en sistemas operativos 146
8.20 Seguridad de las redes 148
8.21 Seguridad de los servicios de red 149
8.22 Segregación de redes 151
8.23 Filtrado web 152
8.24 Uso de cifrado 153

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Página

8.25 Ciclo de vida de desarrollo seguro 156

8.26 Requisitos de seguridad de la información 157

8.27 Arquitectura de sistemas seguros y principios de ingeniería 159

8.28 Codificación segura 162

8.29 Pruebas de seguridad en el desarrollo y la aceptación 166

8.30 Desarrollo tercerizado 167

8.31 Separación de los entornos de desarrollo, prueba y producción 169

8.32 Gestión del cambio 171

8.33 Información de la prueba 172

8.34 Protección de los sistemas de información durante las pruebas de auditoría 173

ANEXOS

ANEXO A (Informativo)
UTILIZACIÓN DE ATRIBUTOS 175

ANEXO B (Informativo)
CORRESPONDENCIA DE LA ISO/IEC 27002:2022 (ESTE DOCUMENTO) CON LA ISO/IEC 27002:2013 192

BIBLIOGRAFÍA 200

Tabla 1. Diferencias entre la política de seguridad de la información y la política específica del tema. 13

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

INTRODUCCIÓN

0.1 Antecedentes y contexto

Este documento está diseñado para organizaciones de todos los tipos y tamaños. Se debería utilizar como referencia para determinar e implementar controles para el tratamiento de riesgos de seguridad de la información en un sistema de gestión de seguridad de la información (SGSI) basado en la norma NTC-ISO/IEC 27001. También se puede utilizar como documento de guía para las organizaciones que determinan e implementan controles de seguridad de la información comúnmente aceptados. Además, este documento está destinado al desarrollo de directrices de gestión de la seguridad de la información específicas de la industria y la organización, tomando en consideración sus entornos de riesgo de seguridad de la información específicos. Los controles específicos de la organización o del entorno distintos de los incluidos en este documento se pueden determinar mediante la evaluación de riesgos según sea necesario.

Las organizaciones de todo tipo y tamaño (incluidos los sectores público y privado, comercial y sin fines de lucro) crean, recopilan, procesan, almacenan, transmiten y disponen de información en muchas formas, incluidas las electrónicas, físicas y verbales (por ejemplo, conversaciones y presentaciones).

El valor de la información va más allá de las palabras escritas, los números y las imágenes: El conocimiento, los conceptos, las ideas y las marcas son ejemplos de formas intangibles de información. En un mundo interconectado, la información y otros activos asociados merecen o requieren protección contra diversas fuentes de riesgo ya sean naturales, accidentales o deliberadas.

La seguridad de la información se logra mediante la implementación de un conjunto adecuado de controles, que incluye políticas, reglas, procesos, procedimientos, estructuras organizativas y funciones de software y hardware. Para cumplir con sus objetivos específicos de seguridad y negocios, la organización debería definir, implementar, monitorear, revisar y mejorar estos controles cuando sea necesario. Un SGSI como el especificado en ISO/IEC 27001 tiene una visión holística y coordinada de los riesgos de seguridad de la información de la organización a fin de determinar e implementar un conjunto completo de controles de seguridad de la información dentro del marco general de un sistema de gestión coherente.

Muchos sistemas de información, incluyendo su gestión y operaciones, no han sido diseñados para ser seguros en términos de un SGSI como se especifica en ISO/IEC 27001 y en este documento. El nivel de seguridad que solo se puede lograr mediante medidas tecnológicas es limitado y debería apoyarse en actividades de gestión y procesos organizativos apropiados. La identificación de los controles que se deberían aplicar requiere una planificación cuidadosa y atención a los detalles mientras se realiza el tratamiento de riesgos.

Un SGSI exitoso requiere el apoyo de todo el personal de la organización. También puede requerir la participación de otras partes interesadas, como accionistas o proveedores. También puede ser necesario el asesoramiento de expertos en la materia.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Un sistema de gestión de la seguridad de la información conveniente, adecuado y eficaz garantiza a la dirección de la organización y a otras partes interesadas que su información y otros activos asociados se mantienen razonablemente seguros y protegidos contra amenazas y daños, lo que le permite a la organización alcanzar los objetivos del negocioes establecidos.

0.2 Requisitos de seguridad de la información

Es esencial que una organización determine sus requisitos de seguridad de la información. Existen tres fuentes principales de requisitos de seguridad de la información:

a) la evaluación de los riesgos para la organización, al tomar en consideración la estrategia y los objetivos del negocio generales de la organización. Esto se puede facilitar o apoyar mediante una evaluación de riesgos específica para la seguridad de la información. Esto debería dar lugar a la determinación de los controles necesarios para Asegurar que el riesgo residual para la organización cumple con sus criterios de aceptación de riesgos;

b) los requisitos legales, estatutarios, reglamentarios y contractuales que una organización y sus partes interesadas (socios comerciales, proveedores de servicios, etc.) tienen que cumplir y su entorno sociocultural;

c) el conjunto de principios, objetivos y requisitos del negocio para todos los pasos del ciclo de vida de la información que una organización ha desarrollado para apoyar sus operaciones.

0.3 Controles

Un control se define como una medida que modifica o mantiene el riesgo. Algunos de los controles de este documento son controles que modifican el riesgo, mientras que otros lo mantienen. Una política de seguridad de la información, por ejemplo, solo puede mantener el riesgo, mientras que el cumplimiento de la política de seguridad de la información puede modificar el riesgo. Además, algunos controles describen la misma medida genérica en diferentes contextos de riesgo. Este documento proporciona una mezcla genérica de controles de seguridad de la información de la organización, las personas, la física y la tecnología derivados de prácticas recomendadas internacionalmente reconocidas.

0.4 Determinación de los controles

La determinación de los controles depende de las decisiones de la organización tras una evaluación de riesgos, con un ámbito claramente definido. Las decisiones relacionadas con los riesgos identificados se deberían basar en los criterios de aceptación del riesgo, las opciones de tratamiento del riesgo y el enfoque de gestión del riesgo aplicado por la organización. En la determinación de los controles también se deberían tener en cuenta todas las leyes y reglamentos nacionales e internacionales pertinentes. La determinación del control también depende de la manera en que los controles interactúan entre sí para proporcionar defensa en profundidad, y de las dependencias del contexto que se puedan presentar en determinado momento.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

La organización puede diseñar controles según sea necesario o identificarlos desde cualquier origen. Al especificar dichos controles, la organización debería considerar los recursos y la inversión necesarios para implementar y operar un control contra el valor del negocio obtenido. Véase la norma ISO/IEC TR 27016 para obtener guía sobre las decisiones relativas a la inversión en un SGSI y las consecuencias económicas de estas decisiones en el contexto de requisitos de recursos que compiten entre sí.

Debería haber un equilibrio entre los recursos desplegados para implementar controles y el posible impacto del negocio resultante de los incidentes de seguridad en ausencia de dichos controles. Los resultados de una evaluación de riesgos deberían ayudar a orientar y determinar las medidas de gestión adecuadas, las prioridades para la gestión de los riesgos de seguridad de la información y para la implementación de los controles que se determinen necesarios para proteger contra estos riesgos.

Algunos de los controles de este documento se pueden considerar como principios rectores para la gestión de la seguridad de la información y como aplicables a la mayoría de las organizaciones. Puede encontrar más información sobre la determinación de controles y otras opciones de tratamiento de riesgos en NTC-ISO/IEC 27005.

0.5 Elaboración de directrices específicas de la organización

Este documento se puede considerar como un punto de partida para elaborar directrices específicas para cada organización. No todos los controles y directrices de este documento se pueden aplicar a todas las organizaciones. También se pueden requerir controles y directrices adicionales que no están incluidos en este documento para abordar las necesidades específicas de la organización y los riesgos que se han identificado. Cuando se desarrollan documentos que contienen directrices o controles adicionales, puede ser útil incluir referencias cruzadas a cláusulas en este documento para futuras referencias.

0.6 Consideraciones sobre el ciclo de vida

La información tiene un ciclo de vida, desde la creación hasta la disposición. El valor y los riesgos de la información pueden variar a lo largo de este ciclo de vida (por ejemplo, la divulgación no autorizada o el robo de las cuentas financieras de una empresa no son significativos después de su publicación, pero la integridad sigue siendo fundamental). Por lo tanto, la seguridad de la información sigue siendo importante en cierta medida en todas las etapas.

Los sistemas de información y otros activos pertinentes para la seguridad de la información tienen ciclos de vida dentro de los cuales se conciben, especifican, diseñan, desarrollan, prueban, implementan, usan, mantienen y eventualmente retiran del servicio y disponen. La seguridad de la información se debería considerar en cada etapa. Los nuevos proyectos de desarrollo de sistemas y los cambios en los sistemas existentes ofrecen oportunidades para mejorar los controles de seguridad, tomando en consideración los riesgos y las lecciones aprendidas de los incidentes por parte de la organización.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

0.7 Normas internacionales relacionadas

Aunque este documento ofrece guía sobre una amplia gama de controles de seguridad de la información que se aplican comúnmente en muchas organizaciones diferentes otros documentos de la familia NTC-ISO/IEC 27000 proporcionan asesoramiento o requisitos complementarios sobre otros aspectos del proceso general de gestión de la seguridad de la información.

Véase la norma NTC-ISO/IEC 27000 para obtener una introducción general a los SGSI y a la familia de documentos. La NTC-ISO/IEC 27000 proporciona un glosario que define la mayoría de los términos utilizados en la familia de documentos NTC-ISO/IEC 27000 y describe el alcance y los objetivos de cada miembro de la familia.

Existen normas específicas para cada sector que tienen controles adicionales que apuntan a abordar áreas específicas (por ejemplo, la NTC-ISO/IEC 27017 para servicios en la nube, NTC-ISO/IEC 27701 para privacidad, ISO/IEC 27019 para energía, ISO/IEC 27011 para organizaciones de telecomunicaciones e ISO 27799 para salud). Tales normas se incluyen en la Bibliografía y algunas de ellas se mencionan en las secciones de guía y otras secciones de información de las cláusulas 5-8.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

SEGURIDAD DE LA INFORMACIÓN, CIBERSEGURIDAD Y PROTECCIÓN DE LA PRIVACIDAD. CONTROLES DE SEGURIDAD DE LA INFORMACIÓN

1. OBJETO Y CAMPO DE APLICACIÓN

Este documento proporciona un conjunto de referencia de controles genéricos de seguridad de la información, incluida la guía de implementación. Este documento está diseñado para que lo utilicen las organizaciones:

a) En el contexto de un sistema de gestión de la seguridad de la información (SGSI) basado en NTC-ISO/IEC 27001;

b) para implementar controles de seguridad de la información basados en prácticas recomendadas internacionalmente reconocidas;

c) para desarrollar directrices de gestión de la seguridad de la información específicas de la organización.

2. REFERENCIAS NORMATIVAS

No hay referencias normativas en este documento.

3. TÉRMINOS, DEFINICIONES Y TÉRMINOS ABREVIADOS

3.1 Términos y definiciones

A los fines del presente documento, se aplican los siguientes términos y definiciones.

La ISO y la IEC mantienen bases de datos terminológicas para su uso en la normalización en las siguientes direcciones:

- ISO Plataforma de navegación en línea: Disponible en https://www.iso.org/obp

- IEC Electropedia: Disponible en https://www.electropedia.org/.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

3.1.1 control de acceso (*access control*). Medios para asegurar que el acceso físico y lógico a los *activos* (3.1.2) esté autorizado y restringido en función de los requisitos de seguridad del negocio y de la información.

3.1.2 activo (*asset)*.

Algo que tenga valor para la organización.

Nota 1 a la entrada: En el contexto de la seguridad de la información, se pueden distinguir dos tipos de activos:

- los activos principales:
- información;
- *procesos* (3.1.27) *y* actividades del negocio;
- los activos de apoyo (de los que dependen los activos principales) de todos los tipos, por ejemplo:
    - hardware;
    - software;
    - red;
    - *personal* (3.1.20);
    - sitio;
    - estructura de la organización.

3.1.3 ataque (*attack*). Intento no autorizado exitoso o fallido de destruir, alterar, desactivar y obtener acceso a un activo (3.1.2) o cualquier intento de exponer, robar o hacer uso no autorizado de un *activo* (3.1.2).

3.1.4 autenticación (*authentication*). Aseguramiento de que una característica reivindicada de una *entidad* (3.1.11) es correcta.

3.1.5 autenticidad (*authenticity*). Propiedad de que una *entidad* (3.1.11) es lo que dice ser.

3.1.6 cadena de custodia (*chain of custody*). Posesión, movimiento, manipulación y ubicación demostrables del material desde un punto en el tiempo hasta otro.

Nota 1 a la entrada: El material incluye información y otros *activos* (3.1.2) asociados en el contexto de la norma ISO/IEC 27002.

[FUENTE: ISO/IEC 27050-1:2019, 3.1: - Se ha añadido la “Nota 1 a la entrada]

3.1.7 información confidencial (*confidential information*). Información que no se pretende poner a disposición o divulgar a personas o *entidades* (3.1.11) o *procesos* no autorizados (3.1.27).

3.1.8 control (*control*). Medida que mantiene o modifica el riesgo.

Nota 1 a la entrada: Los controles incluyen, entre otros, cualquier *proceso* (3.1.27), *política* (3.1.24), dispositivo, práctica u otras condiciones o acciones que mantienen o modifican el riesgo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Nota 2 de la entrada: Es posible que los controles no siempre ejerzan el efecto de modificación previsto o supuesto.

[FUENTE: ISO 31000:2018, 3.8].

3.1.9 interrupción (*disruption*). Incidente ya sea anticipado o imprevisto, que causa una desviación negativa y no planificada de la entrega prevista de productos y servicios según los objetivos de una organización.

[FUENTE: NTC-ISO 22301:2019, 3.10]

3.1.10 dispositivo de punto final (*endpoint device*). Dispositivo de hardware de tecnología de la información y las comunicaciones (TIC) conectado a la red.

Nota 1 a la entrada: El dispositivo de punto final puede hacer referencia a computadores de mesa, portátiles, smartphones, tabletas, clientes ligeros, impresoras u otro hardware especializado, incluidos medidores inteligentes y dispositivos de Internet de las cosas (IoT).

3.1.11 entidad (*entity*). Elemento pertinente para el funcionamiento de un dominio que tiene una existencia reconociblemente distinta.

Nota 1 a la entrada: Una entidad puede tener una representación física o lógica.

Por ejemplo: una persona, una organización, un dispositivo, un grupo de dichos elementos, un suscriptor humano a un servicio de telecomunicaciones, una tarjeta SIM, un pasaporte, una tarjeta de interfaz de red, una aplicación de software, un servicio o un sitio web.

[FUENTE: ISO/IEC 24760-1:2019, 3.1.1]

3.1.12 servicio de procesamiento de información (*information processing facility*). Cualquier sistema de procesamiento de información, servicio o infraestructura o la ubicación física que lo aloja.

[FUENTE: NTC-ISO/IEC 27000:2018, 3.27, modificado - las “instalaciones” se han sustituido por la instalación.]

3.1.13 violación de la seguridad de la información (*information security breach*). Compromiso de seguridad de la información que conduce a la destrucción, pérdida, alteración, divulgación o acceso no deseados a, información protegida transmitida, almacenada o procesada de otro modo.

3.1.14 evento de seguridad de la información (*information security event*). Incidente que indica una posible *violación de seguridad de la información* (3.1.13) o una falla de los controles (3.1.8).

[FUENTE: GTC-ISO/IEC 27035-1:2016, 3.3, modificado - “Violación de la seguridad de la información” se ha sustituido por “Violación de la seguridad de la información”]

3.1.15 incidente de seguridad de la información (*information security incidente*). Uno o varios *eventos de seguridad de la información* (3.1.14) relacionados e identificados que pueden dañar los *activos* (3.1.2) de una organización o poner en peligro sus operaciones.

[FUENTE: GTC-ISO/IEC 27035-1:2016, 3.4]

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

3.1.16 gestión de incidentes de seguridad de la información (*information security incident management*). Ejercicio de un enfoque coherente y eficaz para el tratamiento de los *incidentes de seguridad de la información* (3.1.15).

[FUENTE: GTC-ISO/IEC 27035-1:2016, 3.5].

3.1.17 sistema de información (*information system*). Conjunto de aplicaciones, servicios, *activos* (3.1.2) de tecnología de la información u otros componentes de tratamiento de la información.

[FUENTE: NTC-ISO/IEC 27000:2018, 3.35]

3.1.18 parte interesada (*interested party*). Persona u organización que puede afectar, verse afectada o percibirse afectada por una decisión o actividad.

[FUENTE: NTC-ISO/IEC 27000:2018, 3.37]

3.1.19 no repudio (*non-repudiation*). Capacidad para probar la ocurrencia de un evento o acción reclamada y sus *entidades* de origen (3.1.11).

3.1.20 personal (*personnel*). Personas que trabajan bajo la dirección de la organización.

Nota 1 a la entrada: El concepto de personal incluye a los miembros de la organización, como el órgano rector, la alta dirección, los empleados, el personal temporal, los contratistas y los voluntarios.

3.1.21 información de identificación personal (IIP) (*personally identifiable information*, PII). Cualquier información que (a) se pueda utilizar para establecer un vínculo entre la información y la persona natural a la que se refiere dicha información o (b) esté o pueda estar directa o indirectamente vinculada a una persona natural.

Nota 1 a la entrada: La “persona natural” en la definición es el *IIP principal* (3.1.22). Para determinar si un IIP principal es identificable, se deberían tener en cuenta todos los medios que puedan ser razonablemente utilizados por la parte interesada en la privacidad que posee los datos o por cualquier otra parte, para establecer el vínculo entre el conjunto de la IIP y la persona natural.

[FUENTE: NTC-ISO/IEC 29100:2011/Mod.1:2018, 2.9]

3.1.22 IIP principal (PII principal). Persona natural a la que se refiere la *información de identificación personal (IIP)* (3.1.21).

Nota 1 a la entrada: Dependiendo de la jurisdicción y de la legislación particular sobre protección de datos y privacidad, el sinónimo “sujeto de datos” también se puede utilizar en lugar del término “IIP principal”.

[FUENTE: NTC-ISO/IEC 29100:2011, 2.11]

3.1.23 procesador de IIP (*PII processor*). Parte interesada en la privacidad que procesa *información de identificación personal (IIP)* (3.1.21) en nombre y de acuerdo con las instrucciones de un controlador de IIP.

[FUENTE: NTC-ISO/IEC 29100:2011, 2.12]

3.1.24 política(*policy*). Intenciones y dirección de una organización, expresadas formalmente por su alta dirección.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

[FUENTE: NTC-ISO/IEC 27000:2018, 3.53]

3.1.25 evaluación del impacto en la privacidad EIP (*privacy impact assessment* PIA). *Proceso* (3.1.27) global de identificar, analizar, evaluar, consultar, comunicar y planificar el tratamiento de posibles impactos a la privacidad con respecto al procesamiento de *información de identificación personal (IIP)* (3.1.21), enmarcado dentro del marco más amplio de gestión de riesgos de una organización.

[FUENTE: ISO/IEC 29134:2017, 3.7, modificado - Se ha eliminado la Nota 1 de la entrada].

3.1.26 procedimiento (*procedure*). Forma específica de llevar a cabo una actividad o un *proceso* (3.1.27).

[FUENTE: ISO 30000:2009, 3.12]

3.1.27 proceso (*process*). Conjunto de actividades mutuamente relacionadas o que interactúan, que utilizan las entradas para proporcionar un resultado previsto.

[FUENTE: NTC-ISO 9000:2015, 3.4.1, modificado- Se ha eliminado la nota de la entrada].

3.1.28 registro (*record*). Información que se crea, recibe y mantiene como prueba y como *activo* (3.1.2) por parte de una organización o persona, en cumplimiento de sus obligaciones legales o en la transacción de un negocio.

Nota 1 a la entrada: Las obligaciones legales en este contexto incluyen todos los requisitos legales, estatutarios, reglamentarios y contractuales.

[FUENTE: IEC 15489-1:2016, 3.14: - Se ha añadido la “Nota 1 a la entrada.]

3.1.29 punto objetivo de recuperación POR (*recovery point objective,* RPO). Punto en el tiempo hasta el que se recuperarán los datos después de que se haya producido una *interrupción* (3.1.9).

[FUENTE: ISO/IEC 27031:2011, 3.12, modificado - debería sustituirse por “se debería”.]

3.1.30 tiempo objetivo de recuperación TOR (*recovery time objective* RTO). Período de tiempo dentro del cual los niveles mínimos de servicios o productos y los sistemas, aplicaciones o funciones de apoyo se deberían recuperar después de una *interrupción* (3.1.9).

[FUENTE: GTC-ISO/IEC 27031:2011, 3.13, modificado - debería sustituirse por “se debería”.]

3.1.31 confiabilidad (*reliability*). Propiedad del comportamiento y resultados previstos coherentes.

3.1.32 regla (*rule*) principio aceptado o instrucción que indiica las expectativas de la organización sobre lo que se requiere hacer, lo que se permite o no se permite.

Nota 1 a la entrada: Las normas se pueden expresar formalmente en *políticas específicas por temas* (3.1.35) y en otros tipos de documentos.

3.1.33 información sensible (*sensitive information*). Información que necesita ser protegida de indisponibilidad, acceso no autorizado, modificación o divulgación pública debido a posibles efectos adversos en una persona, organización, en la seguridad nacional o la seguridad pública.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

3.1.34 amenaza (*threat*). Causa potencial de un incidente no deseado, que puede provocar daños en un sistema u organización.

[FUENTE: NTC-ISO/IEC 27000:2018, 3.74]

3.1.35 política específica por tema (*topic-specific policy*). Intenciones y guía sobre un asunto o tema específico, expresadas formalmente por el nivel apropiado de gestión.

Nota 1 a la entrada: Las políticas específicas por temas pueden expresar formalmente *reglas* (3.1.32) o normas de organización. Nota 2 de la entrada: Algunas organizaciones utilizan otros términos para estas directivas específicas de temas.

Nota 3 de la entrada: Las directivas específicas del tema a las que se hace referencia en este documento están relacionadas con la seguridad de la información. EJEMPLO Directiva específica del tema sobre *control de acceso* (3.1.1), directiva específica del tema sobre escritorio y pantalla limpia.

3.1.36 usuario (*user*). *Parte interesada* (3.1.18) con acceso a los *sistemas de información* (3.1.17) de la organización.

EJEMPLO Personal (3.1.20), clientes, proveedores.

3.1.37 dispositivo de punto final del usuario (user endpoint device). *Dispositivo de punto final* (3.1.10) utilizado por los usuarios para acceder a los servicios de procesamiento de información.

Nota 1 a la entrada: El dispositivo de punto final del usuario se puede referir a computadores de mesa, portátiles, smartphones, tablets, clientes ligeros, etc.

3.1.38 vulnerabilidad (*vulnerability*). Debilidad de un *activo* (3.1.2) o *control* (3.1.8) que puede ser explotado por una o más *amenazas* (3.1.34).

[FUENTE: NTC - ISO/IEC 27000:2018, 3.77]

3.2 Términos abreviados

ABAC control de acceso basado en atributos.

ACL lista de control de acceso.

BIA análisis de impacto de negocio.

BYOD traiga su propio dispositivo.

CAPTCHA Prueba de Turing pública y automática para diferenciar máquinas y humanos.

CPU unidad central de procesamiento.

DAC control de acceso discrecional.

DNS sistema de nombres de dominio.

GPS sistema de posicionamiento global.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

IAM	gestión de identidades y accesos.
ICT	tecnologías de la información y la comunicación.
ID	identificador.
IDE	entorno de desarrollo integrado.
IDS	sistema de detección de intrusiones.
IoT	internet de las cosas.
IP	protocolo de internet.
IPS	sistema de prevención de intrusiones.
IT	tecnología de la información
ISMS	sistema de gestión de la seguridad de la información
MAC	control de acceso obligatorio
NTP	protocolo de tiempo de red
PIA	evaluación del impacto en la privacidad
PII	información de identificación personal
P/N	número de identificación personal
PKI	infraestructura de clave pública
PTP	protocolo de tiempo de precisión
RBAC	control de acceso basado en roles
RPO	punto objetivo de recuperación
RTO	tiempo objetivo de recuperación
SAST	pruebas de seguridad de aplicaciones estáticas
SD	tarjeta de memoria
SDN	redes definidas por software
SD-WAN	red de área extensa definida por software
SIEM	información de seguridad y gestión de eventos

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

SMS	servicio de mensajes cortos
SQL	lenguaje de consulta estructurado
SSO	inicio de sesión único
SWID	identificación del software
UEBA	análisis de comportamiento de usuarios y entidades
UPS	sistema de alimentación ininterrumpida
URL	localizador uniforme de recursos
USB	bus universal en serie
VM	máquina virtual
VPN	red privada virtual
WiFi	fidelidad inalámbrica

4. ESTRUCTURA DEL DOCUMENTO

4.1 Cláusulas

Este documento se estructura de la siguiente manera:

a) Controles organizacionales (Cláusula 5)

b) Controles de las personas (Cláusula 6)

c) Controles físicos (Cláusula 7)

d) Controles tecnológicos (Cláusula 8) Tiene 2 anexos informativos:

- Anexo A - Utilización de atributos
- Anexo B - Correspondencia con la ISO/IEC 27002:2013

El Anexo A explica cómo una organización puede utilizar atributos (véase el numeral 4.2) para crear sus propias vistas basándose en los atributos de control definidos en este documento o en su propia creación.

En el Anexo B se muestra la correspondencia entre los controles de esta edición de la norma ISO/IEC 27002 y la edición anterior de 2013.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

4.2 Temas y atributos

La categorización de los controles que figuran en las cláusulas 5 a la 8 se denomina temas. Los controles se clasifican como:

a) personas, si se refieren a personas individuales;

b) físicas, si se refieren a objetos físicos;

c) tecnológica, si se refiere a la tecnología;

d) de lo contrario, se categorizan como organizacionales.

La organización puede utilizar atributos para crear diferentes vistas que son categorizaciones diferentes de los controles desde una perspectiva diferente a los temas. Los atributos se pueden utilizar para filtrar ordenar o presentar controles en diferentes vistas para diferentes audiencias. En el Anexo A se explica cómo se puede lograr esto y se ofrece un ejemplo del punto de vista.

A modo de ejemplo, cada control de este documento se ha asociado con cinco atributos con los valores de atributo correspondientes (precedidos por "#" para que se puedan buscar), de la siguiente manera:

a) Tipo de control

El tipo de control es un atributo que permite ver los controles desde la perspectiva de cuándo y cómo modifica el control el riesgo con respecto a la ocurrencia de un incidente de seguridad de la información. Los valores de los atributos consisten en Preventivo (el control que pretende evitar que se produzca un incidente de seguridad de la información), de Detección (el control actúa cuando se produce un incidente de seguridad de la información) y de Corrección (el control actúa después de que se produzca un incidente de seguridad de la información).

b) Propiedades de seguridad de la información

Las propiedades de seguridad de la información son un atributo para ver los controles desde la perspectiva de qué característica de la información contribuirá a conservar el control. Los valores de atributo consisten en Confidencialidad, Integridad y Disponibilidad.

c) Conceptos de ciberseguridad

Los conceptos de ciberseguridad son un atributo para ver los controles desde la perspectiva de la asociación de los controles a los conceptos de ciberseguridad definidos en el marco de ciberseguridad descrito en la norma ISO/IEC TS 27110. Los valores de atributo consisten en Identificar, Proteger, Detectar, Responder y Recuperar.

d) Capacidades operativas

Las capacidades operativas son un atributo para ver los controles desde la perspectiva del profesional de las capacidades de seguridad de la información. Los valores de atributo consisten en Gobierno, Gestión de activos, Protección de información, Seguridad de recursos

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

humanos, Seguridad física, Seguridad sistema y red , Seguridad aplicación, Configuración segura, Gestión de acceso e identidad, Gestión de amenazas y vulnerabilidades, Continuidad, Seguridad de las relaciones con los proveedores, Conformidad jurídica, Gestión de eventos de la información y Aseguramiento de la información.

e) Dominios de seguridad

Los dominios de seguridad son un atributo para ver los controles desde la perspectiva de cuatro dominios de seguridad de la información: “Gobierno y ecosistema” incluye “Gobierno y gestión de riesgos de seguridad de sistemas de información” y “Gestión de ciberseguridad de ecosistemas” (incluidas las partes interesadas internas y externas); “Protección” incluye “Arquitectura de seguridad de TI”, “Administración de seguridad de TI”, “Gestión de identidades y acceso”, “Mantenimiento de seguridad de TI” y “Seguridad física y ambiental”; “Defensa” incluye “Detección” y “Gestión de incidentes de seguridad informática”; La “resiliencia” incluye la “continuidad de las operaciones” y la “gestión de crisis”. Los valores de los atributos consisten en Gobierno y Ecosistema, Protección, Defensa y Resiliencia.

Los atributos que se proporcionan en este documento se seleccionan porque se consideran suficientemente genéricos para que los utilicen distintos tipos de organizaciones. Las organizaciones pueden optar por ignorar uno o varios de los atributos que se proporcionan en este documento. También pueden crear atributos propios (con los valores de atributo correspondientes) para crear sus propias vistas organizativas. La cláusula A.2 incluye ejemplos de tales atributos.

4.3 Diseño de control

El diseño de cada control contiene lo siguiente:

- Título de control Nombre abreviado del control;
- Tabla de atributos: Una tabla muestra los valores de cada atributo para el control dado;
- Control: Qué es el control;
- Objetivo: Por qué se debería implementar el control;
- Guía: Cómo se debería implementar el control;
- Información adicional: Texto explicativo o referencias a otros documentos relacionados.

Los subtítulos se utilizan en el texto de guía de algunos controles para facilitar la legibilidad cuando la guía es larga y trata varios temas. Estos títulos no se utilizan necesariamente en todo el texto de guía. Los subtítulos están subrayados.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

5. CONTROLES ORGANIZACIONALES

5.1 Políticas de seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gobierno	#Gobierno_y_sistema_ecológico #Resiliencia

Control

La política de seguridad de la información y las políticas de temas específicos deberían ser definidas, aprobadas por la dirección, publicadas, comunicadas y reconocidas por el personal y las partes interesadas pertinentes y revisadas a intervalos planificados y si se producen cambios significativos.

Objetivo

Asegurar la idoneidad, adecuación y eficacia continuas de la dirección y el apoyo a la seguridad de la información de acuerdo con los requisitos del negocio, legales, reglamentarios y contractuales.

Guía

En el nivel más alto, la organización debería definir una “política de seguridad de la información” que sea aprobada por la alta dirección y que establezca el enfoque de la organización para administrar su seguridad de la información.

La política de seguridad de la información debería tener en cuenta los requisitos derivados de:

a) estrategia y requisitos del negocioes;

b) reglamentos, legislación y contratos;

c) los riesgos y amenazas actuales y proyectados para la seguridad de la información.

La política de seguridad de la información debería contener declaraciones relativas a:

a) definición de la seguridad de la información;

b) los objetivos de seguridad de la información o el marco para establecer los objetivos de seguridad de la información;

c) principios que orienten todas las actividades relacionadas con la seguridad de la información;

d) compromiso de satisfacer los requisitos aplicables relacionados con la seguridad de la información;

e) compromiso con la mejora continua del sistema de gestión de la seguridad de la información;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

f) asignación de responsabilidades para la gestión de la seguridad de la información a funciones definidas;

g) procedimientos para manejar exenciones y excepciones.

La administración superior debería aprobar cualquier cambio en la política de seguridad de la información.

En un nivel inferior, la política de seguridad de la información debería apoyarse en políticas específicas según sea necesario, a fin de seguir encomendando la aplicación de los controles de seguridad de la información. Las directivas específicas de un tema se estructuran normalmente para satisfacer las necesidades de determinados grupos de destino dentro de una organización o para cubrir determinadas áreas de seguridad. Las políticas específicas por tema deberían estar alineadas y complementarse con la política de seguridad de la información de la organización.

Algunos ejemplos de temas incluyen:

a) control de acceso;

b) seguridad física y ambiental;

c) gestión de activos;

d) transferencia de información;

e) configuración y gestión seguras de dispositivos finales de usuario;

f) seguridad de red;

g) gestión de incidentes de seguridad de la información;

h) copia de seguridad;

i) criptografía y gestión de claves;

j) clasificación y tratamiento de la información;

k) gestión de las vulnerabilidades técnicas;

l) desarrollo seguro.

La responsabilidad de la elaboración, revisión y aprobación de las políticas específicas del tema se debería asignar al personal pertinente en función de su nivel apropiado de autoridad y competencia técnica. La revisión debería incluir la evaluación de las oportunidades de mejora de la política de seguridad de la información de la organización y de las políticas de temas específicos y la gestión de la seguridad de la información en respuesta a los cambios:

a) la estrategia del negocio de la organización;

b) el entorno técnico de la organización;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) reglamentos, estatutos, legislación y contratos;

d) riesgos de seguridad de la información;

e) el entorno actual y proyectado de amenazas a la seguridad de la información;

f) lecciones aprendidas de incidentes y eventos de seguridad de la información.

La revisión de la política de seguridad de la información y de las políticas específicas por tema debería tener en cuenta los resultados de las revisiones y auditorías de la dirección. Se debería considerar la revisión y actualización de otras políticas relacionadas cuando se cambia una política con la finalidad de mantener la coherencia.

La política de seguridad de la información y las políticas específicas por tema se deberían comunicar al personal pertinente y a las partes interesadas de una forma que sea pertinente, accesible y comprensible para el lector al que se dirige. Los destinatarios de las políticas deberían estar obligados a reconocer que comprenden y aceptan cumplir con las políticas cuando sea aplicable. La organización puede determinar los formatos y nombres de estos documentos de políticas que satisfagan las necesidades de la organización. En algunas organizaciones, la política de seguridad de la información y las políticas específicas por temas pueden estar en un solo documento. La organización puede nombrar estas directivas específicas de temas como normas, directivas, políticas u otras.

Si la política de seguridad de la información o cualquier política específica por tema se distribuye fuera de la organización, se debería tener cuidado de no revelar información confidencial de forma incorrecta.

En la Tabla 1 se muestran las diferencias entre la política de seguridad de la información y la política específica por tema.

Tabla 1. Diferencias entre la política de seguridad de la información y la política específica del tema.

	Política de seguridad de la información	**Política específica por tema**
Nivel de detalle	General o de alto nivel	Específico y detallado
Documentado y aprobado formalmente por	Alta dirección	Nivel apropiado de gestión

Otra información

Las políticas específicas por tema pueden variar según las organizaciones.

5.2 Roles y responsabilidades en materia de seguridad de la información

Tipo de control	**Propiedades de seguridad de la información**	**Conceptos de ciberseguridad**	**Capacidades operativas**	**Dominios de seguridad**
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gobierno	#Gobierno_y_ecosistema #Protección #Resiliencia

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Control

Los roles y responsabilidades de seguridad de la información se deberían definir y asignar de acuerdo con las necesidades de la organización.

Objetivo

Establecer una estructura definida, aprobada y entendida para la implementación operación y gestión de la seguridad de la información dentro de la organización.

Guía

La asignación de los roles y responsabilidades de seguridad de la información se debería realizar de acuerdo con la política de seguridad de la información y las políticas específicas por tema (véase el numeral 5.1). La organización debería definir y gestionar las responsabilidades de:

a) protección de la información y otros activos asociados;

b) llevar a cabo procesos específicos de seguridad de la información;

c) actividades de gestión de riesgos de seguridad de la información y, en particular, aceptación de riesgos residuales (por ejemplo, para los propietarios de riesgos);

d) todo el personal que utilice la información de una organización y otros activos asociados.

Estas responsabilidades se deberían complementar, cuando sea necesario, con una guía más detallada para sitios específicos e instalaciones de procesamiento de información. Las personas con responsabilidades asignadas en materia de seguridad de la información pueden asignar tareas de seguridad a otras personas. Sin embargo, siguen siendo responsables y deberían determinar que cualquier tarea delegada se ha realizado correctamente.

Se debería definir, documentar y comunicar cada área de seguridad de la que son responsables los individuos. Se deberían definir y documentar los niveles de autorización. Las personas que asumen una función específica de seguridad de la información deberían ser competentes en cuanto a los conocimientos y habilidades requeridos por el rol y deberían recibir apoyo para mantenerse al día con los desarrollos relacionados con el rol y requeridos para cumplir con las responsabilidades de la misma.

Otra información

Muchas organizaciones nombran a un administrador de seguridad de la información para que asuma la responsabilidad general del desarrollo e implementación de la seguridad de la información y para que apoye la identificación de riesgos y los controles mitigantes.

Sin embargo, la responsabilidad de la obtención de recursos y la aplicación de los controles a menudo recae en los directores individuales. Una práctica común es nombrar un propietario para cada activo que se haga responsable de su protección diaria.

En función del tamaño y la obtención de recursos de una organización, la seguridad de la información puede estar cubierta por roles o tareas dedicadas que se llevan a cabo además de los roles existentes.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

5.3 Segregación de funciones

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gobierno #Gestión_de_la_identidad_y_del_acceso #Gobierno y ecosistema	#Gobierno_y_ecosistema

Control

Las obligaciones y las áreas de responsabilidad conflictivas deberían estar separadas.

Objetivo

Reducir el riesgo de fraude, error y omisión de los controles de seguridad de la información.

Guía

La separación de obligaciones y áreas de responsabilidad tiene como objetivo separar las obligaciones conflictivas entre diferentes individuos a fin de evitar que un individuo ejecute posibles obligaciones conflictivas por su cuenta.

La organización debería determinar qué obligaciones y áreas de responsabilidad deberían ser segregadas. A continuación se muestran ejemplos de actividades que pueden requerir separación:

a) inicio, aprobación y ejecución de un cambio;

b) solicitud, aprobación e implementación de los derechos de acceso;

c) diseño, implementación y revisión del código;

d) desarrollo de software y administración de sistemas de producción;

e) utilización y administración de aplicaciones;

f) utilización de aplicaciones y administración de bases de datos;

g) diseño, auditoría y aseguramiento de los controles de seguridad de la información.

Al diseñar los controles de segregación se debería tener en cuenta la posibilidad de colusión. Las organizaciones pequeñas pueden encontrar difícil lograr la separación de obligaciones, pero el principio se debería aplicar siempre que sea posible y factible. Cuando sea difícil separar, se deberían considerar otros controles, como el seguimiento de las actividades, las pistas de auditoría y la supervisión de la dirección.

Cuando se utilicen sistemas de control de acceso basados en roles, hay que tener cuidado de que no se concedan a las personas roles contradictorios. Cuando hay un gran número de roles, la organización debería considerar el uso de herramientas automatizadas para identificar conflictos y

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

facilitar su remoción. Los roles se deberían definir y aprovisionar cuidadosamente para minimizar los problemas de acceso si se elimina o se reasigna un rol.

Otra información

No hay más información.

5.4 Responsabilidades de gestión

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gobierno	#Gobierno_y_ecosistema

Control

La dirección debería exigirle a todo el personal que aplique la seguridad de la información de acuerdo con la política de seguridad de la información establecida, las políticas y los procedimientos específicos por tema de la organización.

Objetivo

Asegurar que la dirección comprenda su papel en la seguridad de la información y emprender acciones encaminadas a asegurar que todo el personal sea consciente y cumpla con sus responsabilidades en materia de seguridad de la información.

Guía

La dirección debería demostrar el apoyo a la política de seguridad de la información, a las políticas específicas por tema, a los procedimientos y a los controles de seguridad de la información.

Las responsabilidades de la dirección deberían incluir la garantía de que el personal:

a) estar debidamente informados sobre sus roles y responsabilidades de seguridad de la información antes de que se le conceda acceso a la información de la organización y a otros activos asociados;

b) se proporcionan orientaciones que indican las expectativas de seguridad de la información de su role dentro de la organización;

c) tienen el mandato de cumplir la política de seguridad de la información y las políticas específicas por tema de la organización;

d) lograr un nivel de sensibilización sobre la seguridad de la información pertinente para sus roles y responsabilidades dentro de la organización (véase el numeral 6.3);

e) el cumplimiento de los términos y condiciones de empleo, contrato o acuerdo, que comprende la política de seguridad de la información de la organización y los métodos de trabajo apropiados;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

f) seguir teniendo las habilidades y calificaciones apropiadas de seguridad de la información a través de la educación profesional continua;

g) cuando sea factible, se les proporcionará un canal confidencial para informar sobre violaciones de la política de seguridad de la información, políticas específicas de temas o procedimientos para la seguridad de la información (“denuncia”). Esto puede permitir la presentación de informes anónimos o tener disposiciones para asegurar que el conocimiento de la identidad del informante sea conocido solo por aquellos que necesiten ocuparse de dichos informes;

h) se les proporcionan recursos adecuados y tiempo de planificación de proyectos para implementar los procesos y controles relacionados con la seguridad de la organización.

Otra información

No hay más información.

5.5 Contacto con las autoridades

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger #responder #recuperar	#Gobierno	#Defensa #Resiliencia

Control

La organización debería establecer y mantener contacto con las autoridades pertinentes.

Objetivo

Asegurar un flujo de información adecuado con respecto a la seguridad de la información entre la organización y las autoridades legales, reglamentarias y de supervisión pertinentes.

Guía

La organización debería especificar cuándo y por quién se debería contactar a las autoridades (por ejemplo, las autoridades encargadas de hacer cumplir la ley, los organismos reguladores, las autoridades supervisoras) y cómo deberían informarse oportunamente los incidentes de seguridad de la información identificados.

Los contactos con las autoridades también se deberían utilizar para facilitar la comprensión de las expectativas actuales y futuras de estas autoridades (por ejemplo, las normas aplicables de seguridad de la información).

Otra información

Las organizaciones bajo un ataque pueden solicitar a las autoridades que tomen medidas contra la fuente del ataque. El mantenimiento de estos contactos puede ser un requisito para respaldar la gestión de incidentes de seguridad de la información (Véanse los numerales 5.24 a 5.28) o los

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

procesos de planificación de contingencias y continuidad del negocio (Véanse los numerales 5.29 y 5.30). Los contactos con los organismos reguladores también son útiles para anticipar y prepararse para los próximos cambios en las leyes o reglamentos pertinentes que afectan a la organización. Los contactos con otras autoridades incluyen los servicios públicos, los servicios de emergencia, los proveedores de electricidad y la salud y la seguridad [por ejemplo, los departamentos de bomberos (en conexión con la continuidad del negocio), proveedores de telecomunicaciones (en relación con el enrutamiento y la disponibilidad de las líneas) y proveedores de agua (en relación con las instalaciones de refrigeración de equipos)].

5.6 Contacto con grupos de interés especiales

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder #Recuperar	#Gobierno	#Defensa

Control

La organización debería establecer y mantener contacto con grupos de interés especial u otros foros de seguridad especializados y asociaciones profesionales.

Objetivo

Asegurar que se produce un flujo adecuado de información con respecto a la seguridad de la información.

Guía

La pertenencia a grupos o foros de interés especial debería considerarse como un medio para:

a) mejorar el conocimiento sobre las mejores prácticas y mantenerse al día con la información de seguridad pertinente;

b) asegurarse de que la comprensión del entorno de seguridad de la información es actual;

c) recibir alertas tempranas, avisos y parches relacionados con ataques y vulnerabilidades;

d) obtener acceso a asesoramiento especializado en seguridad de la información;

e) compartir e intercambiar información sobre nuevas tecnologías, productos, servicios, amenazas o vulnerabilidades;

f) proporcionar puntos de enlace adecuados cuando se trate de incidentes de seguridad de la información (véanse los numerales 5.24 al 5.28).

Otra información

No hay más información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

5.7 Inteligencia sobre amenazas

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención #Detección #Corrección	#Confidencialidad #Integridad #Disponibilidad	#Identificación #Detección #Respuesta	#Gestión_de_amenazas_y_vulnerabilidades	#Defensa #Resiliencia

Control

La información relativa a las amenazas a la seguridad de la información se debería recopilar y analizar para producir inteligencia sobre amenazas.

Objetivo

Dar a conocer el entorno de amenazas de la organización para que se puedan tomar las medidas de mitigación adecuadas.

Guía

Se recopila y analiza información sobre amenazas existentes o emergentes para:

a) facilitar acciones informadas para evitar que las amenazas causen daños a la organización;

b) reducir el impacto de tales amenazas.

La inteligencia frente a amenazas se puede dividir en tres capas, que se deberían considerar:

a) inteligencia de amenazas estratégicas: intercambio de información de alto nivel sobre el cambiante panorama de amenazas (por ejemplo, tipos de atacantes o tipos de ataques);

b) inteligencia de amenazas tácticas: información sobre metodologías, herramientas y tecnologías de atacantes implicadas;

c) inteligencia operativa sobre amenazas: detalles sobre ataques específicos, incluidos indicadores técnicos.

La inteligencia frente a amenazas debería ser:

a) pertinente (es decir, relacionado con la protección de la organización);

b) perspicaz (es decir, proporcionar a la organización una comprensión precisa y detallada del panorama de amenazas);

c) contextual, para proporcionar conciencia situacional (es decir, agregar contexto a la información basada en el momento de los eventos, donde ocurren, experiencias previas y prevalencia en organizaciones similares);

d) procesable (es decir, la organización puede actuar sobre la información de forma rápida y eficaz).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Las actividades de inteligencia frente a amenazas deberían incluir:

a) establecer objetivos para la producción de inteligencia frente a amenazas;

b) identificar, revisar y seleccionar fuentes de información internas y externas que sean necesarias y apropiadas para proporcionar la información necesaria para la producción de inteligencia frente a amenazas;

c) recopilar información de fuentes seleccionadas, que pueden ser internas y externas;

d) procesar la información recopilada para prepararla para el análisis (por ejemplo, traduciendo, formateando o corroborando la información);

e) analizar la información para entender cómo se relaciona y es significativa para la organización;

f) comunicarla y compartirla con los individuos pertinentes en un formato que pueda ser entendido.

Se debería analizar y utilizar la inteligencia de amenazas posteriormente:

a) mediante la implementación de procesos para incluir información recopilada de fuentes de inteligencia frente a amenazas en los procesos de gestión de riesgos de seguridad de la información de la organización;

b) como aportación adicional a los controles técnicos preventivos y de detección, como firewalls, sistemas de detección de intrusiones o soluciones antimalware;

c) como aportación a los procesos y técnicas de prueba de seguridad de la información.

La organización debería compartir la inteligencia sobre amenazas con otras organizaciones de forma mutua a fin de mejorar la inteligencia general sobre amenazas.

Otra información

Las organizaciones pueden utilizar la inteligencia frente a amenazas para prevenir, detectar o responder a las amenazas. Las organizaciones pueden producir inteligencia frente a amenazas, pero normalmente reciben y utilizan la inteligencia frente a amenazas producida por otras fuentes.

La inteligencia sobre amenazas es a menudo proporcionada por proveedores o asesores independientes, agencias gubernamentales o grupos de inteligencia sobre amenazas colaborativos.

La eficacia de los controles como los descritos en los numerales 5.25, 8.7, 8.16 o 8.23, depende de la calidad de la información disponible sobre las amenazas.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

5.8 Seguridad de la información en la gestión de proyectos

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Gobierno	#Gobierno_y_ecosistema #Protección

Control

La seguridad de la información se debería integrar en la gestión de proyectos.

Objetivo

Asegurar que los riesgos de seguridad de la información relacionados con los proyectos y los entregables se aborden de forma eficaz en la gestión de proyectos durante todo el ciclo de vida del proyecto.

Guía

La seguridad de la información se debería integrar en la gestión de proyectos para asegurar que los riesgos de seguridad de la información se aborden como parte de la gestión del proyecto. Esto se puede aplicar a cualquier tipo de proyecto independientemente de su complejidad, tamaño, duración, disciplina o área de aplicación (por ejemplo, un proyecto para un proceso del negocio principal, TIC, gestión de instalaciones u otros procesos de soporte).

La gestión de proyectos en uso debería exigir que:

a) los riesgos de seguridad de la información se evalúen y traten en una fase temprana y periódicamente como parte de los riesgos del proyecto a lo largo del ciclo de vida del proyecto;

b) requisitos de seguridad de la información [por ejemplo, requisitos de seguridad de las aplicaciones (véase el numeral 8.26), requisitos para el cumplimiento de los derechos de propiedad intelectual (véase el numeral 5.32), etc.] se aborden en las primeras etapas de los proyectos;

c) los riesgos de seguridad de la información asociados con la ejecución de proyectos, como la seguridad de los aspectos de comunicación interna y externa, se consideren y traten a lo largo del ciclo de vida del proyecto;

d) se revise el progreso en el tratamiento de riesgos de seguridad de la información y se evalúe y prueba la eficacia del tratamiento.

La idoneidad de las consideraciones y actividades de seguridad de la información debería ser seguida en etapas predefinidas por personas u órganos de gobierno adecuados, como el comité directivo del proyecto.

Las responsabilidades y autoridades de seguridad de la información pertinentes para el proyecto se deberían definir y asignar a roles específicos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Los requisitos de seguridad de la información para los productos o servicios que el proyecto debería proporcionar se deberían determinar mediante varios métodos, incluidos los requisitos de cumplimiento derivados de la política de seguridad de la información, las políticas y las normativas específicas por tema. Se pueden obtener requisitos adicionales de seguridad de la información a partir de actividades como la modelización de amenazas, las revisiones de incidentes, el uso de umbrales de vulnerabilidad o la planificación de contingencias, asegurando así que la arquitectura y el diseño de los sistemas de información estén protegidos contra amenazas conocidas basadas en el entorno operativo.

Los requisitos de seguridad de la información se deberían determinar para todos los tipos de proyectos, no solo para los proyectos de desarrollo de las TIC. Al determinar estos requisitos también se debería tener en cuenta lo siguiente:

a) qué información está involucrada (determinación de la información), cuáles son las necesidades de seguridad de la información correspondientes (clasificación; véase el numeral 5.12) y el impacto negativo potencial en el negocio que puede resultar de la falta de seguridad adecuada;

b) las necesidades de protección requeridas de la información y otros activos asociados involucrados, particularmente en términos de confidencialidad, integridad y disponibilidad;

c) el nivel de confianza o garantía necesario para la identidad declarada de las entidades con el fin de obtener los requisitos de autenticación;

d) acceder a los procesos de provisión y autorización, tanto para clientes como para otros posibles usuarios del negocio, así como para usuarios con privilegios o técnicos, como los miembros relevantes del proyecto, el personal de operaciones potencial o los proveedores externos;

e) informar a los usuarios de sus deberes y responsabilidades;

f) los requisitos derivados de los procesos del negocio, como el registro y la supervisión de transacciones, los requisitos de no repudiación;

g) requisitos exigidos por otros controles de seguridad de la información (por ejemplo, interfaces para el registro y la supervisión o sistemas de detección de fugas de datos);

h) el cumplimiento del entorno estatutario, reglamentario y contractual en el que opera la organización;

i) nivel de confianza o garantía requerido para que terceros cumplan la política de seguridad de la información de la organización y las políticas específicas por temas, incluidas las cláusulas de seguridad pertinentes en cualquier acuerdo o contrato.

Otra información

El enfoque de desarrollo del proyecto, como el ciclo de vida en cascada o el ciclo de vida ágil, debería apoyar la seguridad de la información de una manera estructurada que se pueda adaptar a la gravedad evaluada de los riesgos de seguridad de la información, en función del carácter del proyecto. La consideración temprana de los requisitos de seguridad de la información para el

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

producto o servicio (por ejemplo, en las etapas de planificación y diseño) puede conducir a soluciones más eficaces y rentables para la calidad y la seguridad de la información. Las normas ISO 21500 e ISO 21502 proporcionan guía sobre conceptos y procesos de gestión de proyectos que son importantes para el desempeño de los proyectos.

La norma ISO/IEC 27005 proporciona orientación sobre el uso de procesos de gestión de riesgos para identificar controles que cumplan con los requisitos de seguridad de la información.

5.9 Inventario de información y otros activos asociados

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gestión_de_activos	#Gobierno_y_Ecosistema #Protección

Control

Se debería elaborar y mantener un inventario de información y otros activos asociados, incluidos los propietarios.

Objetivo

Identificar la información de la organización y otros activos asociados para preservar su seguridad de la información y asignar la propiedad apropiada.

Guía

Inventario

La organización debería identificar su información y otros activos asociados y determinar su importancia en términos de seguridad de la información. La documentación se debería mantener en inventarios dedicados o existentes, según corresponda.

El inventario de información y otros activos asociados debería ser preciso, actualizado, coherente y alineado con otros inventarios. Las opciones para Asegurar la exactitud de un inventario de información y otros activos asociados incluyen:

a) realizar revisiones periódicas de la información identificada y otros activos asociados con respecto al inventario de activos;

b) aplicar automáticamente una actualización de inventario en el proceso de instalación, cambio o eliminación de un activo.

La ubicación de un activo se debería incluir en el inventario según corresponda.

No es necesario que el inventario sea una lista única de información y otros activos asociados. tomando en consideración que el inventario se debería mantener por las funciones pertinentes, se puede considerar como un conjunto de inventarios dinámicos, como inventarios de activos de información, hardware, software, máquinas virtuales (VM), instalaciones, personal, competencia, capacidades y registros.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Cada activo se debería clasificar de conformidad con la clasificación de la información (véase el numeral 5.12) asociada a dicho activo.

La granularidad del inventario de información y otros activos asociados debería ser a un nivel apropiado para las necesidades de la organización. A veces no es posible documentar casos específicos de activos en el ciclo de vida de la información debido a la naturaleza del activo. Un ejemplo de activo de corta duración es una instancia de VM cuyo ciclo de vida puede ser de corta duración.

Propiedad

Para la información identificada y otros activos asociados, la propiedad del activo debería asignarse a un individuo o a un grupo y debería identificarse la clasificación (véanse los numerales 5.12, 5.13). Se debería implementar un proceso para asegurar la asignación oportuna de la propiedad de los activos. La propiedad se debería asignar cuando se crean activos o cuando se transfieren a la organización. La propiedad de activos se debería reasignar según sea necesario cuando los propietarios de activos actuales abandonen o cambien las funciones del trabajo.

Obligaciones del propietario

El propietario del activo debería ser responsable de la correcta gestión de un activo durante todo el ciclo de vida del activo y Asegurar que:

a) se realizar el inventario de la información y otros activos asociados;

b) la información y otros activos asociados se clasifican y protegen adecuadamente;

c) la clasificación se revisa periódicamente;

d) se listan y vinculan componentes que respaldan activos tecnológicos, como bases de datos, almacenamiento, componentes de software y subcomponentes;

e) se establecen requisitos para el uso aceptable de la información y otros activos asociados (véase el numeral 5.10);

f) las restricciones de acceso corresponden a la clasificación y son efectivas y se revisan periódicamente;

g) la información y otros activos asociados, cuando se eliminan o disponen, se gestionan de forma segura y se remueven del inventario;

h) participan en la identificación y gestión de los riesgos asociados a sus activos;

i) apoyan al personal que tiene los roles y responsabilidades de gestionar su información.

Otra información

Los inventarios de información y otros activos asociados son a menudo necesarios para Asegurar la protección eficaz de la información y pueden ser necesarios para otros fines, como salud y seguridad, seguros o razones financieras. Los inventarios de información y otros activos asociados

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

también apoyan la gestión de riesgos, las actividades de auditoría, la gestión de la vulnerabilidad, la respuesta a incidentes y la planificación de la recuperación.

Las tareas y responsabilidades se pueden delegar (por ejemplo, a un custodio que se encarga de los activos diariamente), pero la persona o grupo que los delegó sigue siendo responsable.

Puede ser útil designar grupos de información y otros activos asociados que actúen conjuntamente para proporcionar un servicio en particular. En este caso, el propietario de este servicio es responsable de la prestación del servicio, incluido el funcionamiento de sus activos.

Véase el numeral la norma ISO/IEC 19770-1 para obtener información adicional sobre la gestión de activos de tecnología de la información (TI). Véase el numeral la norma NTC-ISO 55001 para obtener información adicional sobre la gestión de activos.

5.10 Uso aceptable de la información y otros activos asociados

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de activos Protección de la información	#Gobierno_y_ecosistema #Protección

Control

Se deberían identificar, documentar e implementar reglas para el uso aceptable y procedimientos para el manejo de la información y otros activos asociados.

Objetivo

Asegurar que la información y otros activos asociados estén protegidos, utilizados y gestionados de forma adecuada.

Guía

El personal y los usuarios externos que utilicen o tengan acceso a la información de la organización y a otros activos asociados deberían ser conscientes de los requisitos de seguridad de la información para proteger y manejar la información de la organización y otros activos asociados. Deberían ser responsables del uso de cualquier servicio de procesamiento de información.

La organización debería establecer una política específica sobre el uso aceptable de la información y otros activos asociados y comunicarla a cualquier persona que utilice o maneje la información y otros activos asociados. La política específica sobre el uso aceptable debería proporcionar una guía clara sobre cómo se espera que los individuos utilicen la información y otros activos asociados. La política específica del tema debería indicar:

a) comportamientos esperados e inaceptables de los individuos desde una perspectiva de seguridad de la información;

b) uso permitido y prohibido de la información y otros activos asociados;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) seguimiento de las actividades realizadas por la organización.

Se deberían elaborar procedimientos de uso aceptables para el ciclo de vida completo de la información de acuerdo con su clasificación (véase el numeral 5.12) y los riesgos determinados.

Se deberían tomar en consideración los siguientes factores:

a) restricciones de acceso que apoyen los requisitos de protección para cada nivel de clasificación;

b) mantenimiento de un registro de los usuarios autorizados de la información y otros activos asociados;

c) protección de copias temporales o permanentes de la información a un nivel compatible con la protección de la información original;

d) almacenamiento de los activos asociados a la información de conformidad con las especificaciones de los fabricantes (Véase el numeral 7.8);

e) marcado claro de todas las copias de los medios de almacenamiento (electrónicos o físicos) a la atención del destinatario autorizado (véase el numeral 7.10);

f) autorización de la disposición de la información y otros activos asociados y método(s) de eliminación admitido(s) (Véase el numeral 8.10).

Otra información

Puede ocurrir que los activos afectados no pertenezcan directamente a la organización, como los servicios de nube pública. El uso de dichos activos de terceros y de cualquier activo de la organización asociado con dichos activos externos (por ejemplo, información, software) se debería identificar como aplicable y controlarse, por ejemplo, mediante acuerdos con proveedores de servicios en la nube. También se debería tener cuidado cuando se utiliza un entorno de trabajo colaborativo.

5.11 Devolución de activos

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_activos	#Protección

Control

El personal y otras partes interesadas, según corresponda, deberían devolver todos los activos de la organización que estén en su poder al cambiar o terminar su empleo, contrato o acuerdo.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Proteger los activos de la organización como parte del proceso de cambio o terminación de empleo, contrato o acuerdo.

Guía

El proceso de cambio o terminación debería formalizarse para incluir la devolución de todos los activos físicos y electrónicos emitidos anteriormente que sean propiedad de la organización o que se hayan confiado a ella.

En los casos en que el personal y otras partes interesadas adquieran el equipo de la organización o utilicen su propio equipo personal, se deberían seguir los procedimientos necesarios para Asegurar que toda la información relevante se rastree y transfiera a la organización y se elimine de forma segura del equipo (véase el numeral 7.14).

En los casos en que el personal y otras partes interesadas tengan conocimientos importantes para las operaciones en curso, esa información se debería documentar y transferir a la organización.

Durante el período de notificación y posteriormente, la organización debería evitar la copia no autorizada de la información relevante (por ejemplo, propiedad intelectual) por parte del personal previo aviso de terminación.

La organización debería identificar y documentar claramente toda la información y otros activos asociados que se devolverán, que pueden incluir:

a) dispositivos finales del usuario;

b) dispositivos de almacenamiento portátiles;

c) equipo especializado;

d) hardware de autenticación (por ejemplo, claves mecánicas, tokens físicos y tarjetas inteligentes) para sistemas de información, sitios y archivos físicos;

e) copias físicas de la información.

Otra información

Puede ser difícil devolver información contenida en activos que no son propiedad de la organización. En tales casos, es necesario restringir el uso de la información al utilizar otros controles de seguridad de la información como la gestión de derechos de acceso (véase el numeral 5.18) o el uso de criptografía (véase el numeral 8.24).

5.12 Clasificación de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Protección de la información	#Protección #Defensa

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Control

La información se debería clasificar según las necesidades de seguridad de la información de la organización en función de la confidencialidad, la integridad, la disponibilidad y los requisitos pertinentes de las partes interesadas.

Objetivo

Asegurar la identificación y comprensión de las necesidades de protección de la información de acuerdo con su importancia para la organización.

Guía

La organización debería establecer una política específica sobre clasificación de la información y comunicarla a todas las partes interesadas pertinentes.

La organización debería tener en cuenta los requisitos de confidencialidad, integridad y disponibilidad en el esquema de clasificación.

Las clasificaciones y los controles de protección asociados para la información deberían tener en cuenta las necesidades de negocio para compartir o restringir la información, para proteger la integridad de la información y para asegurar la disponibilidad, así como los requisitos legales relativos a la confidencialidad, integridad o disponibilidad de la información. Los activos distintos de la información también se pueden clasificar de acuerdo con la clasificación de la información, que se almacena, procesa o gestiona o protege el activo.

Los propietarios de la información deberían ser responsables de su clasificación.

El esquema de clasificación debería incluir convenciones para la clasificación y criterios para la revisión de la clasificación a lo largo del tiempo. Los resultados de la clasificación deberían actualizarse de acuerdo con los cambios en el valor, la sensibilidad y la criticidad de la información a lo largo de su ciclo de vida.

El esquema debería estar alineado con la política específica por tema sobre control de acceso (véase el numeral 5.1) y debería ser capaz de abordar las necesidades del negocioes específicas de la organización.

La clasificación puede determinarse por el nivel de impacto que el compromiso de la información tendría para la organización. A cada nivel definido en el esquema se le debería dar un nombre que tenga sentido en el contexto de la aplicación del esquema de clasificación.

El sistema debería ser coherente en toda la organización e incluirse en sus procedimientos para que todos clasifiquen la información y otros activos asociados aplicables de la misma manera. De esta manera, todos tienen una comprensión común de los requisitos de protección y aplican una protección adecuada.

El esquema de clasificación utilizado dentro de la organización puede ser diferente de los esquemas utilizados por otras organizaciones, incluso si los nombres de los niveles son similares. Además, la información se mueve entre las organizaciones pueden variar en clasificación dependiendo de su contexto en cada organización, incluso si sus esquemas de clasificación son idénticos. Por lo tanto,

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

los acuerdos con otras organizaciones que incluyan el intercambio de información debería incluir procedimientos para identificar la clasificación de esa información e interpretar los niveles de clasificación de otras organizaciones. La correspondencia entre los distintos regímenes puede determinarse buscando la equivalencia en los métodos de manipulación y protección asociados.

Otra información

La clasificación proporciona a las personas que se ocupan de la información una indicación concisa de cómo manejarla y protegerla. Esto se facilita mediante la creación de grupos de información con necesidades de protección similares y la especificación de procedimientos de seguridad de la información que se aplican a toda la información de cada grupo. Este enfoque reduce la necesidad de una evaluación de riesgos caso por caso y un diseño personalizado de controles.

La información puede dejar de ser sensible o crítica después de un cierto período de tiempo. Por ejemplo, cuando la información se ha hecho pública ya no tiene requisitos de confidencialidad, pero puede requerir protección para sus propiedades de integridad y disponibilidad. Estos aspectos deberían tenerse en cuenta ya que la excesiva clasificación puede conducir a la aplicación de controles innecesarios que producen gastos adicionales o, por el contrario, la subclasificación puede conducir a controles insuficientes para proteger la información de compromisos.

Como ejemplo, un esquema de clasificación de confidencialidad de la información puede basarse en cuatro niveles como sigue:

a) la divulgación no causa ningún daño;

b) la divulgación causa daños menores a la reputación o un menor impacto operativo;

c) la divulgación tiene un impacto significativo a corto plazo en las operaciones o los objetivos del negocioes;

d) la divulgación tiene un impacto grave en los objetivos del negocioes a largo plazo o pone en riesgo la supervivencia de la organización.

5.13 Etiquetado de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Información_ protección_	#Defensa #Protección

Control

Debería elaborarse e implementarse un conjunto adecuado de procedimientos para el etiquetado de la información de conformidad con el esquema de clasificación de la información adoptado por la organización.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Facilitar la comunicación de la clasificación de la información y apoyar la automatización del procesamiento y la gestión de la información.

Guía

Los procedimientos para el etiquetado de la información deberían abarcar la información y otros activos asociados en todos los formatos. El etiquetado debería reflejar el esquema de clasificación establecido en el numeral 5.12. Las etiquetas deberían ser fácilmente reconocibles. Los procedimientos deberían proporcionar guía sobre dónde y cómo se adjuntan las etiquetas en consideración de cómo se accede a la información o cómo se manejan los activos dependiendo de los tipos de medios de almacenamiento. Los procedimientos pueden definir:

a) casos en los que se omite el etiquetado (por ejemplo, etiquetado de información no confidencial para reducir las cargas de trabajo);

b) cómo etiquetar la información enviada o almacenada por medios electrónicos o físicos o en cualquier otro formato;

c) cómo manejar los casos en los que no es posible el etiquetado (por ejemplo, debido a restricciones técnicas).

Entre los ejemplos de técnicas de etiquetado se incluyen:

a) etiquetas físicas;

b) encabezados y pies de página;

c) metadatos;

d) marcas de agua;

e) sellos de goma.

La información digital debería utilizar metadatos para identificar, gestionar y controlar la información, especialmente en lo que respecta a la confidencialidad. Los metadatos también deberían permitir una búsqueda eficaz y correcta de la información. Los metadatos deberían facilitar la interacción de los sistemas y la toma de decisiones basadas en las etiquetas de clasificación asociadas.

Los procedimientos deberían describir cómo adjuntar metadatos a la información, qué etiquetas utilizar y cómo deberían manejarse los datos, de acuerdo con el modelo de información y la arquitectura de las TIC de la organización.

Los sistemas deberían agregar metadatos adicionales pertinentes cuando procesan la información en función de sus propiedades de seguridad de la información.

El personal y otras partes interesadas deberían tener conocimiento de los procedimientos de etiquetado. Se debería proporcionar a todo el personal la formación necesaria para Asegurar que la información está correctamente etiquetada y manejada en consecuencia.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

La salida de los sistemas que contienen información clasificada como sensible o crítica debería llevar una etiqueta de clasificación adecuada.

Otra información

El etiquetado de la información clasificada es un requisito clave para el intercambio de información.

Otros metadatos útiles que se pueden adjuntar a la información son del proceso organizativo creó la información y en qué momento.

El etiquetado de la información y otros activos asociados a veces puede tener efectos negativos. Los activos clasificados pueden ser más fáciles de identificar por parte de actores malintencionados para un posible uso indebido.

Algunos sistemas no etiquetan archivos individuales o registros de bases de datos con su clasificación, sino que protegen toda la información al nivel más alto de clasificación de cualquier información que contiene o que se permite que contenga. En estos sistemas es habitual determinar y etiquetar la información cuando se exporta.

5.14 Transferencia de información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de activos Protección de la información	#Protección

Control

Se debería establecer reglas, procedimientos o acuerdos de transferencia de información para todos los tipos de facilidades de transferencia dentro de la organización y entre la organización y otras partes.

Objetivo

Mantener la seguridad de la información transferida dentro de una organización y con cualquier parte externa interesada.

Guía

General

La organización debería establecer y comunicar a todas las partes interesadas una política específico por tema de transferencia de información sobre un tema específico. Las reglas, procedimientos y acuerdos para proteger la información en tránsito deberían reflejar la clasificación de la información involucrada. Cuando la información se transfiere entre la organización y terceros, se debería establecer y mantener acuerdos de transferencia (incluida la autenticación del destinatario) para proteger la información en todas las formas en tránsito (véase el numeral 5.10).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

La transferencia de información puede realizarse mediante transferencia electrónica, transferencia de medios de almacenamiento físico y transferencia verbal.

Para todos los tipos de transferencia de información, las normas, procedimientos y acuerdos deberían incluir:

a) controles diseñados para proteger la información transferida de intercepciones, accesos no autorizados, copias, modificaciones, rutas incorrectas, destrucción y denegación de servicio, incluidos los niveles de control de acceso acordes con la clasificación de la información involucrada y cualquier control especial que se requiera para proteger la información sensible, como el uso de técnicas cifradas (véase el numeral 8.24);

b) controles para asegurar la trazabilidad y la no repudiación, incluido el mantenimiento de una cadena de custodia de la información durante el tránsito;

c) identificación de los contactos apropiados relacionados con la transferencia, incluidos los propietarios de la información, los propietarios de riesgos, los oficiales de seguridad y los custodios de la información, según corresponda;

d) responsabilidades y obligaciones en caso de incidentes de seguridad de la información, como la pérdida de medios de almacenamiento físicos o datos;

e) el uso de un sistema de etiquetado acordado para información sensible o crítica, garantizando que el significado de las etiquetas se entienda inmediatamente y que la información esté debidamente protegida (véase el numeral 5.13);

f) fiabilidad y disponibilidad del servicio de transferencia;

g) la política o directrices específicas por tema sobre el uso aceptable de los servicios de transferencia de la información (véase el numeral 5.10);

h) directrices de retención y disposición para todos los registros de negocio, incluidos los mensajes;

NOTA Puede existir legislación y regulaciones locales en relación con la retención y disposición de registros de negocio.

i) la consideración de cualquier otro requisito legal, estatutario, reglamentario y contractual pertinente (véanse los numerales 5.31, 5.32, 5.33, 5.34) relacionado con la transferencia de información (por ejemplo, requisitos para firmas electrónicas).

Transferencia electrónica

Las reglas, procedimientos y acuerdos también deberían considerar los siguientes puntos cuando se utilicen medios de comunicación electrónica para la transferencia de información:

a) detección y protección contra malware que se puede transmitir mediante el uso de comunicaciones electrónicas (véase el numeral 8.7);

b) protección de la información electrónica sensible comunicada en forma de anexo;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) prevención contra el envío de documentos y mensajes en comunicaciones a direcciones o números incorrectos;

d) obtener la aprobación antes de utilizar servicios públicos externos como mensajería instantánea, redes sociales, uso compartido de archivos o almacenamiento en la nube;

e) niveles más sólidos de autenticación al transferir información a través de redes de acceso público;

f) restricciones asociadas a las instalaciones de comunicación electrónica (por ejemplo, evitar la automatización reenvío de correo electrónico a direcciones de correo externas);

g) aconsejar al personal y a otras partes interesadas que no envíen mensajes SMS (servicio de mensajes cortos) o mensajes instantáneos con información crítica ya que pueden leerse en lugares públicos (y por lo tanto por personas no autorizadas) o almacenarse en dispositivos que no estén protegidos adecuadamente;

h) asesorar al personal y a otras partes interesadas sobre los problemas del uso de máquinas o servicios de fax, a saber:

   1) acceso no autorizado a almacenes de mensajes integrados para recuperar mensajes;

   2) programación deliberada o accidental de máquinas para enviar mensajes a números específicos.

Transferencia de medios de almacenamiento físico

Al transferir medios de almacenamiento físicos (incluido el papel), las reglas, procedimientos y acuerdos también deberían incluir:

a) responsabilidades de control y notificación de la transmisión, envío y recepción;

b) asegurar el correcto direccionamiento y transporte del mensaje;

c) embalaje que proteja el contenido de cualquier daño físico que se pueda producir durante el transporte y de acuerdo con las especificaciones de cualquier fabricante, por ejemplo, protección contra cualquier factor ambiental que pueda reducir la eficacia de la restauración de los medios de almacenamiento, como la exposición al calor, la humedad o los campos electromagnéticos; utilizar normas técnicas mínimas para el embalaje y la transmisión (por ejemplo, el uso de sobres opacos);

d) una lista de correos fiables autorizados acordada por la dirección;

e) normas de identificación de mensajería;

f) en función del nivel de clasificación de la información del medio de almacenamiento que se va a transportar, utilice controles a prueba de manipulaciones o a prueba de manipulaciones (por ejemplo, bolsas, contenedores);

g) procedimientos para verificar la identificación de los correos;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

h) lista aprobada de terceros que proporcionan servicios de transporte o mensajería en función de la clasificación de la información;

i) mantener registros para identificar el contenido de los medios de almacenamiento, la protección aplicada, así como registrar la lista de destinatarios autorizados, los tiempos de transferencia a los custodios de tránsito y la recepción en el destino.

Transferencia verbal

Para proteger la transferencia verbal de información, se debería recordar al personal y a otras partes interesadas que deberían:

a) no tener conversaciones verbales confidenciales en lugares públicos o a través de canales de comunicación inseguros ya que pueden ser escuchadas por personas no autorizadas;

b) no dejar mensajes que contengan información confidencial en los contestadores automáticos o mensajes de voz ya que pueden ser reproducidos por personas no autorizadas, almacenados en sistemas comunitarios o almacenados incorrectamente como resultado de un marcado erróneo;

c) ser seleccionado al nivel apropiado para escuchar la conversación;

d) asegúrese de que se implementan los controles de la sala adecuados (por ejemplo, , aislamiento acústico, puerta cerrada);

e) comenzar cualquier conversación sensible con un descargo de responsabilidad para que los presentes conozcan el nivel de clasificación y cualquier requisito de manejo de lo que están a punto de oír.

Otra información

No hay más información.

5.15 Control de acceso

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de la identidad y del acceso	#Protección

Control

Las reglas para controlar el acceso físico y lógico a la información y otros activos asociados deberían establecerse e implementarse en función de los requisitos de seguridad de la información y del negocio.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Asegurar el acceso autorizado y evitar el acceso no autorizado a la información y otros activos asociados.

Guía

Los propietarios de la información y otros activos asociados deberían determinar la seguridad de la información y los requisitos de negocio relacionados con el control de acceso. Debería definirse una política específica por tema sobre el control del acceso que tenga en cuenta estos requisitos y debería comunicarse a todas las partes interesadas pertinentes.

Estos requisitos y la política específica del tema deberían considerar lo siguiente:

a) determinar qué entidades requieren qué tipo de acceso a la información y otros activos asociados;

b) seguridad de las aplicaciones (véase el numeral 8.26);

c) el acceso físico, que debería estar soportado por los controles de entrada físicos apropiados (véanse los numerales 7.2, 7.3, 7.4);

d) difusión y autorización de la información (por ejemplo, el principio de necesidad de conocer) y niveles de seguridad de la información y clasificación de la información (véanse los numerales 5.10, 5.12, 5.13);

e) restricciones al acceso privilegiado (véase el numeral 8.2);

f) segregación de tareas (el numeral 5.3);

g) la legislación, los reglamentos y las obligaciones contractuales pertinentes relativas a la limitación del acceso a datos o servicios (véanse los numerales 5.31, 5.32, 5.33, 5.34, 8.3);

h) segregación de las funciones de control de acceso (por ejemplo, solicitud de acceso, autorización de acceso, administración de acceso);

i) autorización formal de solicitudes de acceso (véanse los numerales 5.16 y 5.18);

j) la gestión de los derechos de acceso (véase el numeral 5.18);

k) registro (véase el numeral 8.15).

Las reglas de control de acceso deberían implementarse definiendo y mapeando los derechos y restricciones de acceso apropiados a las entidades pertinentes (véase el numeral 5.16). Una entidad puede representar a un usuario humano, así como a un elemento técnico o lógico (por ejemplo, una máquina, un dispositivo o un servicio). Para simplificar la gestión del control de acceso, se pueden asignar roles específicos a los grupos de entidades.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Al definir e implementar las reglas de control de acceso, se debería tener en cuenta lo siguiente:

a) coherencia entre los derechos de acceso y la clasificación de la información;

b) coherencia entre los derechos de acceso y las necesidades y requisitos de seguridad del perímetro físico;

c) considerar todos los tipos de conexiones disponibles en los entornos distribuidos para que las entidades solo tengan acceso a la información y otros activos asociados, incluidas las redes y los servicios de red, que estén autorizados a utilizar;

d) considerar cómo se pueden reflejar los elementos o factores pertinentes para el control dinámico de acceso.

Otra información

A menudo se utilizan principios generales en el contexto del control de acceso. Dos de los principios más utilizados son:

a) necesidad de saber: a una entidad solo se le concede acceso a la información que requiere para realizar sus tareas (diferentes tareas o funciones significan una información diferente de necesidad de saber y, por lo tanto, diferentes perfiles de acceso);

b) necesidad de uso: a una entidad solo se le asigna acceso a la infraestructura de tecnología de la información cuando existe una necesidad clara.

Se debería tener cuidado al especificar las reglas de control de acceso que se deberían tener en cuenta:

a) establecer reglas basadas en la premisa del menor privilegio, "Todo está generalmente prohibido a menos que esté expresamente permitido", en lugar de la regla más débil, "Todo está generalmente permitido a menos que esté expresamente prohibido";

b) los cambios en las etiquetas de información (véase el numeral 5,13) que se inician automáticamente mediante las instalaciones de procesamiento de información y los iniciados a discreción del usuario;

c) los cambios en los permisos de usuario iniciados automáticamente por el sistema de información y los iniciados por un administrador;

d) cuándo definir y revisar regularmente la aprobación.

Las reglas de control de acceso deberían estar respaldadas por procedimientos documentados (véanse los numerales 5.16, 5.17, 5.18, 8.2, 8.3, 8.4, 8.5, 8.18) y definición de responsabilidades (véanse los numerales 5.2, 5.17).

Existen varias formas de implementar el control de acceso, como MAC (control de acceso obligatorio), DAC (control de acceso discrecional), RBAC (control de acceso basado en roles) y ABAC (control de acceso basado en atributos).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Las reglas de control de acceso también pueden contener elementos dinámicos (por ejemplo, una función que evalúa accesos pasados o valores de entorno específicos). Las reglas de control de acceso se pueden implementar en diferentes granularidad, desde la cobertura de redes o sistemas completos hasta campos de datos específicos y también pueden considerar propiedades como la ubicación del usuario o el tipo de conexión de red que se utiliza para el acceso. Estos principios y cómo se define el control de acceso granular pueden tener un impacto significativo en los costes. Las reglas más sólidas y una mayor granularidad normalmente conducen a un mayor costo. Los requisitos del negocioes y las consideraciones de riesgo se deberían utilizar para definir qué reglas de control de acceso se aplican y qué granularidad se requiere.

5.16 Gestión de identidad

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de la identidad y del acceso	#Protección

Control

Se debería gestionar todo el ciclo de vida de las identidades.

Objetivo

Permitir la identificación única de individuos y sistemas que acceden a la información de la organización y otros activos asociados y permitir la asignación adecuada de derechos de acceso.

Guía

Los procesos utilizados en el contexto de la gestión de identidades deberían asegurar que:

a) para las identidades asignadas a personas, una identidad específica solo está vinculada a una sola persona para que pueda responsabilizar a la persona de las acciones realizadas con esta identidad específica;

b) las identidades asignadas a varias personas (por ejemplo, identidades compartidas) solo se permiten cuando son necesarias por motivos del negocioes u operativos y están sujetas a aprobación y documentación específicas;

c) las identidades asignadas a entidades no humanas están sujetas a una aprobación debidamente segregada y a una supervisión independiente continua;

d) las identidades se desactivan o eliminan de forma oportuna si ya no son necesarias (por ejemplo, si sus entidades asociadas se eliminan o ya no se utilizan o si la persona vinculada a una identidad ha abandonado la organización o ha cambiado el rol);

e) en un dominio específico, se asigna una única identidad a una sola entidad, [es decir, se evita la asignación de varias identidades a la misma entidad dentro del mismo contexto (identidades duplicadas)];

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

f) se mantienen registros de todos los eventos significativos relacionados con el uso y la gestión de las identidades de usuario y de la información de autenticación.

La organización debería contar con un proceso de apoyo para gestionar los cambios en la información relacionada con las identidades de los usuarios. Estos procesos pueden incluir la verificación doble de documentos de confianza relacionados con una persona.

Al utilizar identidades proporcionadas o emitidas por terceros (por ejemplo, credenciales de redes sociales), la organización debería asegurarse de que las identidades de terceros proporcionan el nivel de confianza necesario y de que se conocen y tratan suficientemente los riesgos asociados. Esto puede incluir controles relacionados con terceros (véase el numeral 5.19), así como controles relacionados con la información de autenticación asociada (véase el numeral 5.17).

Otra información

Proporcionar o revocar el acceso a la información y otros activos asociados suele ser un procedimiento de varios pasos:

a) confirmar los requisitos del negocioes para establecer una identidad;

b) verificar la identidad de una entidad antes de asignarles una identidad lógica;

c) establecer una identidad;

d) configurar y activar la identidad. Esto también incluye la configuración y configuración inicial de los servicios de autenticación relacionados;

e) proporcionar o revocar derechos de acceso específicos a la identidad, sobre la base de las decisiones de autorización o derecho apropiadas (Véase el numeral 5.18).

5.17 Información de autenticación

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de la identidad y del acceso	#Protección

Control

La asignación y gestión de la información de autenticación debería controlarse mediante un proceso de gestión, que incluya el asesoramiento del personal sobre el tratamiento adecuado de la información de autenticación.

Objetivo

Para Asegurar la autenticación de entidades correcta y evitar errores en los procesos de autenticación.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Guía

Asignación de información de autenticación

El proceso de asignación y gestión debería asegurar que:

a) Las contraseñas personales o los números de identificación personal (PIN) generados automáticamente durante los procesos de inscripción cómo información de autenticación secreta temporal no se puede adivinar y es única para cada persona y los usuarios deberían cambiarlos después del primer uso;

b) se establecen procedimientos para verificar la identidad de un usuario antes de proporcionar información de autenticación nueva, de sustitución o temporal;

c) la información de autenticación, incluida la información de autenticación temporal, se transmite a los usuarios de forma segura (por ejemplo, a través de un canal autenticado y protegido) y se evita el uso de mensajes de correo electrónico no protegidos (texto no cifrado) con este fin;

d) los usuarios acusan recibo de la información de autenticación;

e) la información de autenticación predeterminada predefinida o proporcionada por los proveedores se cambia inmediatamente después de la instalación de sistemas o software;

f) se mantienen registros de eventos significativos relativos a la asignación y gestión de la información de autenticación y se otorga su confidencialidad y se aprueba el método de mantenimiento de registros (por ejemplo, mediante el uso de una herramienta de almacén de contraseñas aprobada).

Responsabilidades del usuario

Cualquier persona que tenga acceso o utilice la información de autenticación debería ser aconsejada para asegurarse de que:

a) la información de autenticación secreta, como las contraseñas, se mantiene confidencial. La información de autenticación secreta personal no debería compartirse con nadie. La información de autenticación secreta utilizada en el contexto de identidades vinculadas a varios usuarios o vinculadas a entidades no personales se comparte únicamente con personas autorizadas;

b) la información de autenticación afectada o comprometida se cambia inmediatamente tras la notificación o cualquier otra indicación de un compromiso;

c) cuando se utilizan contraseñas como información de autenticación, se seleccionan contraseñas seguras según las recomendaciones de prácticas recomendadas, por ejemplo:

   1) las contraseñas no se basan en nada que otra persona pueda adivinar u obtener fácilmente al utilizar información relacionada con la persona (por ejemplo, nombres, números de teléfono y fechas de nacimiento);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

2) las contraseñas no se basan en palabras de diccionario o sus combinaciones;

3) utilice frases de contraseña fáciles de recordar e intente incluir caracteres alfanuméricos y especiales;

4) las contraseñas tienen una longitud mínima;

d) las mismas contraseñas no se utilizan en distintos servicios y sistemas;

e) la obligación de seguir estas normas también se incluye en términos y condiciones de empleo (véase el numeral 6.2).

Sistema de gestión de contraseñas

Cuando se utilizan contraseñas como información de autenticación, el sistema de gestión de contraseñas debería:

a) permitirles a los usuarios seleccionar y cambiar sus propias contraseñas e incluir un procedimiento de confirmación para solucionar los errores de entrada;

b) Aplicar contraseñas seguras de acuerdo con las recomendaciones de buenas prácticas [véase el literal c) de “Responsabilidades del usuario”];

c) forzar a los usuarios a cambiar sus contraseñas en el primer inicio de sesión;

d) aplicar los cambios de contraseña según sea necesario, por ejemplo, después de un incidente de seguridad o al terminar o cambiar de empleo cuando un usuario tiene contraseñas conocidas para identidades que permanecen activas (por ejemplo, identidades compartidas);

e) evitar la reutilización de contraseñas anteriores;

f) evitar el uso de contraseñas de uso común y nombres de usuario comprometidos, combinaciones de contraseñas de sistemas pirateados;

g) no mostrar contraseñas en la pantalla al introducirlas;

h) almacene y transmita contraseñas en forma protegida.

El cifrado de contraseñas y el *hashing* deberían realizarse de acuerdo con las técnicas cifradas aprobadas para contraseñas (véase el numeral 8.24).

Otra información

Las contraseñas o frases de acceso son un tipo de información de autenticación que se utiliza habitualmente y son un medio común de verificar la identidad de un usuario. Otros tipos de información de autenticación son las claves cifradas, los datos almacenados en tokens de hardware (por ejemplo, tarjetas inteligentes) que producen códigos de autenticación y datos biométricos, como escaneos de iris o huellas dactilares. Puede encontrar información adicional en la serie ISO/IEC 24760.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Requerir cambios frecuentes de contraseñas puede ser problemático porque los usuarios se pueden molestar por los cambios frecuentes olvidar contraseñas nuevas, anotarlas en lugares inseguros o elegir contraseñas no seguras. La provisión de inicio de sesión único (SSO) u otras herramientas de administración de autenticación (por ejemplo, almacenes de contraseñas) reduce la cantidad de información de autenticación que los usuarios deberían proteger y, por lo tanto, puede aumentar la eficacia de este control. Sin embargo, estas herramientas también pueden aumentar el impacto de la revelación de información de autenticación.

Algunas aplicaciones requieren que una autoridad independiente asigne contraseñas de usuario. En tales casos, a), c) y d) del sistema de gestión de contraseñas no se aplican.

5.18 Derechos de acceso

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de la identidad y del acceso	#Protección

Control

Los derechos de acceso a la información y a otros activos asociados se deberían aprovisionar, revisar, modificar y eliminar de acuerdo con la política y las reglas de control de acceso específicas del tema de la organización.

Objetivo

Asegurar que el acceso a la información y otros activos asociados se define y autoriza de acuerdo con los requisitos de negocio.

Guía

Provisión y revocación de derechos de acceso

El proceso de aprovisionamiento para asignar o revocar derechos de acceso físicos y lógicos otorgados a la identidad autenticada de una entidad debería incluir:

a) obtención de la autorización del propietario de la información y otros activos asociados para el uso de la información y otros activos asociados (véase el numeral 5.9). También puede ser apropiada la aprobación por separado de los derechos de acceso por parte de la administración;

b) consideración de los requisitos de negocio y la política y las reglas específicas por tema de la organización sobre el control de acceso;

c) consideración de la separación de deberes, que incluye la separación de los roles de aprobación e implementación de los derechos de acceso y la separación de roles conflictivos;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

d) asegurar que se eliminan los derechos de acceso cuando alguien no necesita acceder a la información y a otros activos asociados, en particular garantizando que los derechos de acceso de los usuarios que han abandonado la organización se eliminan de forma oportuna;

e) consideración de la concesión de derechos de acceso temporal durante un período de tiempo limitado y su revocación en la fecha de vencimiento, en particular para el personal temporal o el acceso temporal requerido por el personal;

f) verificación de que el nivel de acceso concedido se ajuste a las políticas específicas del tema sobre control de acceso (véase el numeral 5.15) y sea coherente con otros requisitos de seguridad de la información, como la separación de funciones (véase el numeral 5.3);

g) asegurar que los derechos de acceso se activen (por ejemplo, por parte de los proveedores de servicios) solo después de que los procedimientos de autorización se hayan completado correctamente;

h) Mantener un registro central de los derechos de acceso otorgados a un identificador de usuario (ID, lógico o físico) para acceder a la información y otros activos asociados;

i) modificar los derechos de acceso de los usuarios que han cambiado de roles o trabajos;

j) eliminar o ajustar los derechos de acceso físicos y lógicos, que se pueden realizar mediante la eliminación, revocación o sustitución de claves, información de autenticación, tarjetas de identificación o suscripciones;

k) mantener un registro de los cambios en los derechos de acceso lógicos y físicos de los usuarios.

Revisión de los derechos de acceso

Las revisiones periódicas de los derechos de acceso físicos y lógicos deberían tener en cuenta lo siguiente:

a) los derechos de acceso de los usuarios después de cualquier cambio en la misma organización (por ejemplo, cambio de empleo, ascenso, descenso) o terminación del empleo (véanse los numerales 6.1 a 6.5);

b) autorizaciones para derechos de acceso con privilegios.

Consideración antes del cambio o la terminación del empleo

Los derechos de acceso de un usuario a la información y otros activos asociados deberían revisarse y ajustarse o eliminarse antes de cualquier cambio o cese del empleo basándose en la evaluación de factores de riesgo como:

a) si la terminación o el cambio es iniciado por el usuario o por la dirección y el motivo de la terminación;

b) las responsabilidades actuales del usuario;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) el valor de los activos actualmente accesibles.

Otra información

Se debería tener en cuenta el establecimiento de roles de acceso de usuarios en función de los requisitos de negocio que resumen una serie de derechos de acceso en perfiles de acceso de usuarios típicos. Las solicitudes de acceso y las revisiones de los derechos de acceso se gestionan más fácilmente en el nivel de dichos roles que en el nivel de derechos particulares.

Se debería considerar la inclusión de cláusulas en los contratos de personal y de servicios que especifiquen sanciones si el personal intenta acceder sin autorización (véanse los numerales 5.20, 6.2, 6.4, 6.6).

En los casos de terminación iniciada por la gerenció, el personal descalificado o los usuarios externos pueden dañar deliberadamente la información o sabotear las instalaciones de procesamiento de la información. En los casos de personas que se refirman o son despedidas, pueden verse tentadas a recoger información para uso futuro.

La clonación es una forma eficaz de que las organizaciones asignen acceso a los usuarios. Sin embargo, debería hacerse con cuidado basado en roles distintos identificados por la organización en lugar de clonar una identidad con todos los derechos de acceso asociados. La clonación tiene un riesgo inherente de resultar en derechos de acceso excesivos a la información y otros activos asociados.

5.19 Seguridad de la información en las relaciones con los proveedores

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad de las relaciones con los proveedores	#Gobierno_y_ ecosistema #Protección

Control

Deberían definirse e implementarse procesos y procedimientos para gestionar los riesgos de seguridad de la información asociados con el uso de los productos o servicios del proveedor.

Objetivo

Mantener un nivel acordado de seguridad de la información en las relaciones con los proveedores.

Guía

La organización debería establecer y comunicar a todas las partes interesadas una política específica por tema sobre las relaciones con los proveedores.

La organización debería identificar e implementar procesos y procedimientos para abordar los riesgos de seguridad asociados con el uso de productos y servicios proporcionados por los proveedores. Esto también debería aplicarse al uso por parte de la organización de los recursos de los proveedores de servicios en la nube. Estos procesos y procedimientos deberían incluir aquellos

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

que debería implementar la organización, así como aquellos que la organización requiere que el proveedor implemente para el inicio del uso de los productos o servicios de un proveedor o para la terminación del uso de los productos y servicios de un proveedor, tales como:

a) identificar y documentar los tipos de proveedores (por ejemplo, Servicios de TIC, logística, servicios públicos, servicios financieros, componentes de infraestructura de TIC) que pueden afectar a la confidencialidad, integridad y disponibilidad de la información de la organización;

b) establecer cómo evaluar y seleccionar proveedores según la sensibilidad de la información, los productos y los servicios (por ejemplo, con análisis de mercado, referencias de clientes, revisión de documentos, evaluaciones in situ, certificaciones);

c) evaluar y seleccionar los productos o servicios del proveedor que tengan controles adecuados de seguridad de la información y revisarlos; en particular, la exactitud e integridad de los controles implementados por el proveedor que garanticen la integridad de la información del proveedor y el procesamiento de la información y, por lo tanto, la seguridad de la información de la organización;

d) definir la información de la organización, los servicios de TIC y la infraestructura física a la que los proveedores pueden acceder, supervisar, controlar o utilizar;

e) definir los tipos de componentes y servicios de la infraestructura de TIC proporcionados por los proveedores que puedan afectar a la confidencialidad, integridad y disponibilidad de la información de la organización;

f) evaluación y gestión de los riesgos de seguridad de la información asociados con:

   1) el uso por parte de los proveedores de la información de la organización y otros activos asociados, incluidos los riesgos originados por el personal potencialmente malintencionado de los proveedores;

   2) el mal funcionamiento o las vulnerabilidades de los productos (incluidos los componentes y subcomponentes de software utilizados en estos productos) o los servicios prestados por los proveedores;

g) supervisión del cumplimiento de los requisitos de seguridad de la información establecidos para cada tipo de proveedor y tipo de acceso, incluida la revisión por parte de terceros y la validación del producto;

h) mitigación de la no conformidad de un proveedor, tanto si se ha detectado a través de la supervisión como por otros medios;

i) manejo de incidentes y contingencias asociados con productos y servicios del proveedor, incluyendo responsabilidades tanto de la organización como de los proveedores;

j) resiliencia y, si es necesario, medidas de recuperación y contingencia para asegurar la disponibilidad de la información y el procesamiento de la información del proveedor y, por ende, la disponibilidad de la información de la organización;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

k) sensibilización y formación para el personal de la organización que interactúa con el personal de los proveedores en lo que respecta a las reglas de compromiso adecuadas, las políticas, los procesos y los procedimientos específicos por tema y el comportamiento en función del tipo de proveedor y del nivel de acceso del proveedor a los sistemas y la información de la organización;

l) gestionar la necesaria transferencia de información, de otros activos asociados y de cualquier otro elemento que deba modificarse y Asegurar el mantenimiento de la seguridad de la información durante todo el periodo de transferencia;

m) requisitos para asegurar una terminación segura de la relación con el proveedor, que incluye:

1) desaprovisionamiento de los derechos de acceso;

2) tratamiento de la información;

3) determinar la titularidad de la propiedad intelectual desarrollada durante el compromiso;

4) la portabilidad de la información en caso de cambio de proveedor o de recurso interno (*insourcing*);

5) gestión de documentos;

6) devolución de activos;

7) disposicion segura de la información y otros activos asociados;

8) requisitos de confidencialidad continuos;

n) nivel de seguridad del personal y seguridad física que se espera del personal y las instalaciones del proveedor.

Los procedimientos para continuar con el tratamiento de la información en caso de que el proveedor no pueda suministrar sus productos o servicios (por ejemplo, debido a un incidente, porque el proveedor ya no está en el negocio o ya no proporciona algunos componentes debido a los avances tecnológicos) debería considerarse para evitar cualquier retraso en la organización de productos o servicios de sustitución (por ejemplo, identificando un proveedor alternativo por adelantado o al utilizar siempre proveedores alternativos).

Otra información

En los casos en que no es posible que una organización coloque requisitos en un proveedor, la organización debería:

a) considerar la guía dada en este control al tomar decisiones sobre la elección de un proveedor y su producto o servicio;

b) implementar controles de compensación según sea necesario basándose en una evaluación de riesgos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Los proveedores con una gestión inadecuada de la seguridad de la información pueden poner en peligro la información. Se deberían determinar y aplicar controles para gestionar el acceso del proveedor a la información y otros activos asociados. Por ejemplo, si existe una necesidad especial de confidencialidad de la información, se pueden utilizar acuerdos de no divulgación o técnicas de cifrado. Otro ejemplo son los riesgos de protección de datos personales cuando el acuerdo con el proveedor implica la transferencia de información o el acceso a ella a través de las fronteras. La organización debería ser consciente de que la responsabilidad legal o contractual de proteger la información sigue siendo responsabilidad de la organización.

Los riesgos también pueden ser causados por controles inadecuados de los componentes de la infraestructura de TIC o de los servicios prestados por los proveedores. Los componentes o servicios vulnerables o que funcionan mal pueden provocar infracciones de la seguridad de la información en la organización o en otra entidad (por ejemplo, pueden causar infecciones de malware, ataques u otros daños a entidades distintas de la organización).

Véase el numeral la norma ISO/IEC 27036-2 para obtener más información.

5.20 Abordar la seguridad de la información en los acuerdos con los proveedores

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad de las relaciones con los proveedores	#Gobierno_y_ ecosistema #Protección

Control

Los requisitos de seguridad de la información pertinentes deberían establecerse y acordarse con cada proveedor en función del tipo de relación con el proveedor.

Objetivo

Mantener un nivel acordado de seguridad de la información en las relaciones con los proveedores.

Guía

Se deberían establecer y documentar acuerdos con proveedores para Asegurar que existe un entendimiento claro entre la organización y el proveedor en relación con las obligaciones de ambas partes de cumplir los requisitos de seguridad de la información pertinentes.

Se pueden considerar los siguientes términos para su inclusión en los acuerdos con el fin de satisfacer los requisitos de seguridad de la información identificados:

a) descripción de la información que se debería proporcionar o acceder a ella y métodos de suministro o acceso a la información;

b) clasificación de la información según el esquema de clasificación de la organización (véanse los numerales 5.10, 5.12, 5.13);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) la correspondencia entre el esquema de clasificación propio de la organización y el esquema de clasificación del proveedor;

d) Requisitos legales, legales, reglamentarios y contractuales, incluidos la protección de datos, el tratamiento de la información de identificación personal (IIP), los derechos de propiedad intelectual y los derechos de autor y una descripción de cómo se Asegurará su cumplimiento;

e) obligación de cada parte contractual de implementar un conjunto acordado de controles, incluyendo control de acceso, revisión de desempeño, monitoreo, informe y auditoría y las obligaciones del proveedor de cumplir con los requisitos de seguridad de la información de la organización;

f) normas de uso aceptable de la información y otros activos asociados, incluido el uso inaceptable si es necesario;

g) procedimientos o condiciones para la autorización y eliminación de la autorización para el uso de la información de la organización y otros activos asociados por parte del personal del proveedor (por ejemplo, mediante una lista explícita del personal del proveedor autorizado para utilizar la información de la organización y otros activos asociados);

h) requisitos de seguridad de la información en relación con la infraestructura de TIC del proveedor; en particular, requisitos mínimos de seguridad de la información para cada tipo de información y tipo de acceso que sirvan de base para los acuerdos de proveedores individuales basados en las necesidades del negocioes y los criterios de riesgo de la organización;

i) indemnizaciones y reparación por incumplimiento de los requisitos del contratista;

j) requisitos y procedimientos de gestión de incidentes (especialmente notificación y colaboración durante la corrección de incidentes);

k) requisitos de formación y concienciación para procedimientos específicos y requisitos de seguridad de la información (por ejemplo, para la respuesta a incidentes, procedimientos de autorización);

l) Disposiciones pertinentes para la subcontratación, incluidos los controles que deberían aplicarse, tales como el acuerdo sobre el uso de los subproveedores (por ejemplo, exigir que se cumplan las mismas obligaciones del proveedor, exigir que se disponga de una lista de subproveedores y notificación antes de cualquier cambio);

m) contactos pertinentes, incluida una persona de contacto para problemas de seguridad de la información;

n) cualquier requisito de selección, cuando sea legalmente permisible, para el personal del proveedor, incluidas las responsabilidades para llevar a cabo los procedimientos de detección y notificación si no se ha completado la selección o si los resultados dan lugar a dudas o preocupaciones;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

o) los mecanismos de evidencio y garantía de las atestaciones de terceros sobre los requisitos pertinentes de seguridad de la información relacionados con los procesos del proveedor y un informe independiente sobre la eficacia de los controles;

p) derecho a auditar los procesos y controles del proveedor relacionados con el acuerdo;

q) obligación del proveedor de presentar periódicamente un informe sobre la eficacia de los controles y un acuerdo sobre la corrección oportuna de las cuestiones pertinentes planteadas en el informe;

r) resolución de defectos y procesos de resolución de conflictos;

s) proporcionar copias de seguridad alineadas con las necesidades de la organización (en términos de frecuencia, tipo y ubicación de almacenamiento);

t) asegurar la disponibilidad de una instalación alternativa (es decir, un sitio de recuperación ante desastres) que no esté sujeta a las mismas amenazas que la instalación principal y consideraciones para los controles de retorno (controles alternativos) en caso de que fallen los controles principales;

u) disponer de un proceso de gestión de cambios que garantice la notificación anticipada a la organización y la posibilidad de que la organización no acepte cambios;

v) controles de seguridad física acordes con la clasificación de la información;

w) controles de transferencia de información para proteger la información durante la transferencia física o la transmisión lógica;

x) cláusulas de terminación al concluir el acuerdo, incluida la gestión de registros, la devolución de activos, la eliminación segura de la información y otros activos asociados, así como cualquier obligación de confidencialidad en curso;

y) suministro de un método para destruir de forma segura la información de la organización almacenada por el proveedor en cuanto ya no sea necesaria;

z) asegurar, al final del contrato, el traspaso del apoyo a otro proveedor o a la organización misma.

La organización debería establecer y mantener un registro de acuerdos con partes externas (por ejemplo, contratos, memorando de entendimiento, acuerdos de intercambio de información) para hacer un seguimiento de dónde va su información. La organización también debería revisar, validar y actualizar regularmente sus acuerdos con partes externas para asegurarse de que siguen siendo necesarios y aptos para su propósito con las cláusulas de seguridad de la información pertinentes.

Otra información

Los acuerdos pueden variar considerablemente para las distintas organizaciones y entre los distintos tipos de proveedores. Por lo tanto, se debería tener cuidado de incluir todos los requisitos pertinentes para abordar los riesgos de seguridad de la información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Para obtener información detallada sobre los acuerdos con proveedores, véase el numeral la serie ISO/IEC 27036. Para obtener información sobre los acuerdos de servicios en la nube, véase el numeral la serie ISO/IEC 19086.

5.21 Gestión de la seguridad de la información en la cadena de suministro de las TIC

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad de las relaciones con los proveedores	#Gobierno_y_ ecosistema #Protección

Control

Debería definirse y aplicarse procesos y procedimientos para gestionar los riesgos de seguridad de la información asociados a la cadena de suministro de productos y servicios de TIC.

Objetivo

Mantener un nivel acordado de seguridad de la información en las relaciones con los proveedores.

Guía

Se deberían considerar los siguientes temas para abordar la seguridad de la información dentro de la seguridad de la cadena de suministro de TIC, además de los requisitos generales de seguridad de la información para las relaciones con los proveedores:

a) Definir los requisitos de seguridad de la información que se aplicarán a la adquisición de productos o servicios de TIC;

b) Exigir que los proveedores de servicios de TIC propaguen los requisitos de seguridad de la organización a lo largo de la cadena de suministro si subcontratan partes del servicio de TIC proporcionado a la organización;

c) Exigir que los proveedores de productos de TIC propaguen las prácticas de seguridad adecuadas a lo largo de la cadena de suministro si estos productos incluyen componentes comprados o adquiridos a otros proveedores u otras entidades (por ejemplo, desarrolladores de software subcontratados y proveedores de componentes de hardware);

d) Solicitar a los proveedores de productos TIC que proporcionen información que describa los componentes de software utilizados en los productos;

e) Solicitar a los proveedores de productos TIC que proporcionen información que describa las funciones de seguridad implementadas de su producto y la configuración necesaria para su funcionamiento seguro;

f) Implementar un proceso de monitoreo y métodos aceptables para validar que los productos y servicios de TIC entregados cumplan con los requisitos de seguridad establecidos. Ejemplos de dichos métodos de revisión de proveedores pueden incluir pruebas de penetración y pruebas o validación de atestación es de tercera parte para las operaciones de seguridad de la información del proveedor;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

g) implementar un proceso para identificar y documentar los componentes de productos o servicios que son críticos para mantener la funcionalidad y, por lo tanto, requieren mayor atención, escrutinio y seguimiento adicional cuando se crean fuera de la organización, especialmente si el proveedor subcontratan aspectos de los componentes de productos o servicios a otros proveedores;

h) obtener la garantía de que los componentes críticos y su origen pueden rastrearse a lo largo de la cadena de suministro;

i) obtener la garantía de que los productos TIC suministrados funcionan como se esperaba sin ninguna característica inesperada o no deseada;

j) implementar procesos para asegurar que los componentes de los proveedores sean auténticos y no se alteren de sus especificaciones. Entre las medidas de ejemplo se incluyen etiquetas antimanipulación, verificaciones cifradas de hash o firmas digitales. El monitoreo para detectar un desempeño fuera de las especificaciones puede ser un indicador de manipulación o falsificación. La prevención y la detección de manipulación deberían implementarse durante varias etapas del ciclo de vida del desarrollo del sistema, incluidos el diseño, el desarrollo, la integración, las operaciones y el mantenimiento;

k) obtener la garantía de que los productos TIC alcanzan los niveles de seguridad requeridos, por ejemplo, mediante una certificación formal o un esquema de evaluación como el Acuerdo Común de Reconocimiento de Criterios;

l) definir reglas para compartir información sobre la cadena de suministro y cualquier posible problema y compromiso entre la organización y los proveedores;

m) implementar procesos específicos para gestionar el ciclo de vida y la disponibilidad de los componentes de TIC y los riesgos de seguridad asociados. Esto incluye la gestión de los riesgos de los componentes que ya no estén disponibles debido a que los proveedores ya no están en el negocio o a que los proveedores ya no proporcionan estos componentes debido a los avances tecnológicos. Debería considerarse la identificación de un proveedor alternativo y el proceso de transferencia de software y competencia al proveedor alternativo.

Otra información

Las prácticas específicas de gestión de riesgos de la cadena de suministro de TIC se basan en prácticas generales de seguridad de la información, calidad, gestión de proyectos e ingeniería de sistemas, pero no las sustituyen.

Se recomienda a las organizaciones que trabajen con los proveedores para comprender la cadena de suministro de TIC y cualquier asunto que tenga un efecto importante en los productos y servicios que se proporcionan. La organización puede influir en las prácticas de seguridad de la información de la cadena de suministro de TIC al dejar en claro en los acuerdos con sus proveedores los asuntos que deberían abordar otros proveedores de la cadena de suministro de TIC.

Las TIC deberían adquirirse de fuentes de confianza. La fiabilidad del software y del hardware es una cuestión de control de calidad. Aunque generalmente no es posible que una organización inspeccione los sistemas de control de calidad de sus proveedores, puede hacer juicios confiables basados en la reputación del proveedor.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

La cadena de suministro de TIC, tal como se aborda aquí, incluye servicios en la nube. Ejemplos de cadenas de suministro de TIC son:

a) aprovisionamiento de servicios en la nube, donde el proveedor de servicios en la nube depende de los desarrolladores de software, los proveedores de servicios de telecomunicaciones y los proveedores de hardware;

b) IoT, donde el servicio implica a los fabricantes de dispositivos, a los proveedores de servicios en la nube (por ejemplo, los operadores de plataforma IoT), los desarrolladores de aplicaciones móviles y web, el proveedor de librerías de software;

c) servicios de alojamiento, en los que el proveedor depende de escritorios de servicio externos, incluidos el primero, el segundo y el tercer nivel de soporte.

Véase el numeral la norma ISO/IEC 27036-3 para obtener más detalles, incluida la guía de evaluación de riesgos.

Las etiquetas de identificación de software (SWID) también pueden ayudar a lograr una mejor seguridad de la información en la cadena de suministro, proporcionando información sobre la procedencia del software. Véase el numeral la norma ISO/IEC 19770-2 para obtener más información.

5.22 Monitoreo, revisión y gestión de cambios de los servicios de los proveedores

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad de las relaciones con los proveedores	#Gobierno_y_ ecosistema #Protección #Defensa #Aseguramiento_de_la_información

Control

La organización debería monitorear, revisar, evaluar y gestionar regularmente los cambios en las prácticas de seguridad de la información del proveedor y en la prestación de servicios.

Objetivo

Mantener un nivel acordado de seguridad de la información y prestación de servicios de acuerdo con los acuerdos con los proveedores.

Guía

El monitoreo, revisión y la gestión de cambios de los servicios de proveedores debería asegurar el cumplimiento de los términos y condiciones de seguridad de la información de los acuerdos, la gestión adecuada de los incidentes y problemas de seguridad de la información y los cambios en los servicios de proveedores o en el estado del negocio no afectan a la prestación de servicios.

Esto debería implicar un proceso para gestionar la relación entre la organización y el proveedor para:

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

a) monitorear los niveles de desempeño del servicio para verificar el cumplimiento de los acuerdos;

b) monitorear los cambios realizados por los proveedores, entre los que se incluyen:

1) mejoras en los servicios actuales ofrecidos;

2) desarrollo de cualquier aplicación y sistema nuevos;

3) modificaciones o actualizaciones de las políticas y procedimientos del proveedor;

4) controles nuevos o modificados para resolver incidentes de seguridad de la información y mejorar la seguridad de la información;

c) monitorear los cambios en los servicios del proveedor, incluidos:

1) cambios y mejoras en las redes;

2) utilización de nuevas tecnologías;

3) adopción de nuevos productos o versiones más recientes;

4) nuevas herramientas y entornos de desarrollo;

5) cambios en la ubicación física de las instalaciones de servicio;

6) cambio de subproveedores;

7) subcontratación con otro proveedor;

d) revisar los informes de servicio producidos por el proveedor y organizar reuniones periódicas de progreso según lo requerido por los acuerdos;

e) llevar a cabo auditorías de proveedores y subproveedores, junto con la revisión de los informes de auditores independientes, si están disponibles y el seguimiento de las cuestiones identificadas;

f) proporcionar información sobre incidentes de seguridad de la información y revisar esta información según lo requieran los acuerdos y las directrices y procedimientos de apoyo;

g) revisar los registros de auditoría de proveedores y los registros de eventos de seguridad de la información, problemas operativos, fallas, trazabilidad de fallas e interrupciones relacionados con el servicio prestado;

h) responder y gestionar cualquier incidente o evento de seguridad de la información identificado;

i) identificar las vulnerabilidades de seguridad de la información y gestionarlas;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

j) revisar los aspectos de seguridad de la información de las relaciones del proveedor con sus propios proveedores;

k) asegurarse de que el proveedor mantenga una capacidad de servicio suficiente junto con planes viables diseñados para Asegurar que se mantienen los niveles de continuidad del servicio acordados tras fallas de servicio o desastres importantes (véanse los numerales 5.29, 5.30, 5.35, 5.36, 8.14);

l) asegurar que los proveedores asignen responsabilidades para revisar el cumplimiento y hacer cumplir los requisitos de los acuerdos;

m) evaluar regularmente que los proveedores mantienen niveles adecuados de seguridad de la información.

La responsabilidad de gestionar las relaciones con los proveedores debería asignarse a un individuo o equipo designado. Deberían ponerse a disposición suficientes habilidades técnicas y recursos para monitorear que se cumplen los requisitos del acuerdo, en particular los requisitos de seguridad de la información. Se deberían tomar las medidas adecuadas cuando se observen deficiencias en la prestación de servicios.

Otra información

Véase la norma ISO/IEC 27036-3 para obtener más información.

5.23 Seguridad de la información para el uso de servicios en la nube

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad de las relaciones con los proveedores	#Gobierno_y_ ecosistema #Protección

Control

Los procesos de adquisición, uso, gestión y salida de los servicios en la nube deberían establecerse de acuerdo con los requisitos de seguridad de la información de la organización.

Objetivo

Especificar y gestionar la seguridad de la información para el uso de servicios en la nube.

Guía

La organización debería establecer y comunicar una política específica por tema sobre el uso de los servicios en la nube a todas las partes interesadas.

La organización debería definir y comunicar cómo pretende gestionar los riesgos de seguridad de la información asociados con el uso de servicios en la nube. Puede ser una extensión o parte del enfoque existente para la forma en que una organización administra los servicios prestados por partes externas (véanse los numerales 5.21 y 5.22).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

El uso de los servicios en la nube puede implicar una responsabilidad compartida en materia de seguridad de la información y un esfuerzo de colaboración entre el proveedor de servicios en la nube y la organización que actúa como cliente de dichos servicios. Es esencial que las responsabilidades tanto del proveedor de servicios en la nube como de la organización, que actúa como cliente de los servicios en la nube, se definan y apliquen adecuadamente.

La organización debería definir:

a) todos los requisitos de seguridad de la información pertinentes asociados con el uso de los servicios en la nube;

b) criterios de selección de servicios en la nube y alcance del uso del servicio en la nube;

c) roles y responsabilidades relacionadas con el uso y la gestión de servicios en la nube;

d) qué controles de seguridad de la información son gestionados por el proveedor de servicios en la nube y cuales son gestionados por la organización como cliente del servicio en la nube;

e) cómo obtener y utilizar las capacidades de seguridad de la información proporcionadas por el proveedor de servicios en la nube;

f) cómo obtener la garantía de los controles de seguridad de la información implementados por los proveedores de servicios en la nube;

g) cómo gestionar controles, interfaces y cambios en los servicios cuando una organización utiliza varios servicios en la nube, especialmente de distintos proveedores de servicios en la nube;

h) procedimientos para gestionar los incidentes de seguridad de la información que se producen en relación con el uso de servicios en la nube;

i) su enfoque para monitorear, revisar y evaluar el uso continuo de los servicios en la nube para gestionar los riesgos de seguridad de la información;

j) cómo cambiar o detener el uso de los servicios en la nube, incluidas las estrategias de salida de los servicios en la nube.

Los acuerdos de servicios en la nube suelen estar predefinidos y no están abiertos a la negociación. Para todos los servicios en la nube, la organización debería revisar los acuerdos de servicios en la nube con los proveedores de servicios en la nube. Un acuerdo de servicio en la nube debería abordar los requisitos de confidencialidad, integridad, disponibilidad y gestión de la información de la organización, con los objetivos de nivel de servicio en la nube y los objetivos cualitativos del servicio en la nube adecuados. La organización también debería realizar evaluaciones de riesgos pertinentes para identificar los riesgos asociados con el uso del servicio en la nube. Cualquier riesgo residual relacionado con el uso del servicio en la nube debería ser claramente identificado y aceptado por la dirección apropiada de la organización.

Un acuerdo entre el proveedor de servicios en la nube y la organización, que actúa como cliente de servicios en la nube, debería incluir las siguientes disposiciones para la protección de los datos de la organización y la disponibilidad de los servicios:

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

a) proporcionar soluciones basadas en normas aceptadas por la industria para arquitectura e infraestructura;

b) gestionar los controles de acceso del servicio en la nube para satisfacer los requisitos de la organización;

c) implementar soluciones de protección y supervisión de malware;

d) el procesamiento y almacenamiento de la información sensible de la organización en lugares aprobados (por ejemplo, un país o región en particular) o dentro de una jurisdicción determinada o sujeta a ella;

e) proporcionar asistencia especializada en caso de que se produzca un incidente de seguridad de la información en el entorno de servicios en la nube;

f) asegurar que se cumplen los requisitos de seguridad de la información de la organización en caso de que los servicios en la nube se subcontraten a un proveedor externo (o prohibir la subcontratación de servicios en la nube);

g) apoyar a la organización en la recopilación de evidencias digitales, tomando en consideración las leyes y regulación para evidencias digitales en diferentes jurisdicciones;

h) proporcionar soporte y disponibilidad adecuados de los servicios para un plazo de tiempo adecuado cuando la organización desea salir del servicio en la nube;

i) proporcionar la copia de seguridad necesaria de los datos y la información de configuración y gestionar de forma segura las copias de seguridad según corresponda, en función de las capacidades del proveedor de servicios en la nube que utiliza la organización, al actuar como cliente del servicio en la nube;

j) proporcionar y devolver información como archivos de configuración, código fuente y datos que son propiedad de la organización, actuando como cliente del servicio en la nube, cuando se solicite durante la prestación del servicio o al finalizar el servicio.

La organización, que actúa como cliente del servicio en la nube, debería considerar si el acuerdo debería exigir a los proveedores de servicios en la nube que proporcionen una notificación previa antes de que cualquier cliente importante afecte a los cambios que se realicen en la forma en que se entrega el servicio a la organización, incluidos:

a) cambios en la infraestructura técnica (por ejemplo, reubicación, reconfiguración o cambios en hardware o software) que afectan o modifican la oferta de servicios en la nube;

b) procesar o almacenar información en una nueva jurisdicción geográfica o jurídica;

c) uso de proveedores de servicios en la nube de pares u otros subcontratistas (incluido el cambio de proveedores existentes o el uso de nuevos proveedores).

La organización que utiliza servicios en la nube debería mantener un estrecho contacto con sus proveedores de servicios en la nube. Estos contactos permiten el intercambio mutuo de información sobre la seguridad de la información para el uso de los servicios en la nube, que incluye un

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

mecanismo para que tanto el proveedor de servicios en la nube como la organización, actúen como cliente del servicio en la nube, monitoreen cada característica del servicio e informen de fallas de los compromisos contenidos en los acuerdos.

Otra información

Este control considera la seguridad de la nube desde la perspectiva del cliente del servicio de nube.

Puede encontrar información adicional sobre los servicios en la nube en las normas ISO/IEC 17788, ISO/IEC 17789 e ISO/IEC 22123-1. Los detalles relacionados con la portabilidad de la nube en apoyo de las estrategias de salida se pueden encontrar en la norma ISO/IEC 19941. Los detalles relacionados con la seguridad de la información y los servicios de nube pública se describen en la norma ISO/IEC 27017. Se describen los detalles relacionados con la protección IIP en nubes públicas que actúan como procesador IIP la norma ISO/IEC 27018. Las relaciones con los proveedores de servicios en la nube están cubiertas por la ISO/IEC 27036-4 y los acuerdos de servicios en la nube y su contenido se trata en la serie ISO/IEC 19086, con seguridad y privacidad específicamente cubiertas por la ISO/IEC 19086-4.

5.24 Planificación y preparación de la gestión de incidentes de seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Responder #Recuperar	#Gobierno #Gestión de eventos de seguridad de la información	#Defensa

Control

La organización debería planificar y prepararse para gestionar los incidentes de seguridad de la información definiendo, estableciendo y comunicando los procesos, roles y responsabilidades de gestión de incidentes de seguridad de la información.

Objetivo

Asegurar una respuesta rápida, eficaz, coherente y ordenada a los incidentes de seguridad de la información, incluida la comunicación sobre los eventos de seguridad de la información.

Guía

Roles y responsabilidades

La organización debería establecer procesos apropiados de gestión de incidentes de seguridad de la información. Los roles y responsabilidades para llevar a cabo los procedimientos de gestión de incidentes deberían determinarse y comunicarse eficazmente a las partes interesadas internas y externas pertinentes.

Se debería considerar lo siguiente:

a) establecimiento de un método común para informar sobre eventos de seguridad de la información, que incluye el punto de contacto(Véase el numeral 6.8);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) establecer un proceso de gestión de incidencias para proporcionar a la organización la capacidad de gestionar los incidentes de seguridad de la información, que incluye la administración, la documentación, la detección, la clasificación, la priorización, análisis, comunicación y coordinación de las partes interesadas;

c) establecer un proceso de respuesta a incidentes para proporcionar a la organización la capacidad de evaluar, responder y aprender de los incidentes de seguridad de la información;

d) permitir que solo el personal competente se encargue de los problemas relacionados con los incidentes de seguridad de la información dentro de la organización. Dicho personal debería recibir documentación sobre procedimientos y capacitación periódica;

e) establecer un proceso para identificar la formación, la certificación y el desarrollo profesional continuo necesarios para el personal de respuesta a incidentes.

Procedimientos de gestión de incidentes.

Los objetivos de la gestión de incidentes de seguridad de la información deberían acordarse con la dirección y debería asegurarse de que los responsables de la gestión de incidentes de seguridad de la información comprendan las prioridades de la organización para manejar incidentes de seguridad de la información, que incluye el marco temporal de resolución basado en las consecuencias y la gravedad potenciales. Se deberían implementar procedimientos de gestión de incidentes para cumplir con estos objetivos y prioridades.

La dirección debería asegurarse de que se cree un plan de gestión de incidentes de seguridad de la información tomando en consideración los diferentes escenarios y procedimientos que se desarrollan e implementan para las siguientes actividades:

a) evaluación de los eventos de seguridad de la información según criterios para lo que constituye un incidente de seguridad de la información;

b) monitoreo (véanse los numerales 8,15 y 8,16), detección (véase el numeral 8.16), clasificación (véase el numeral 5,25), análisis e informes (véase el numeral 6.8) de los eventos e incidentes de seguridad de la información (por medios humanos o automáticos);

c) gestión de los incidentes de seguridad de la información hasta su conclusión, incluida la respuesta y la escalada (véase el numeral 5.26), según el tipo y la categoría del incidente, posible activación de la gestión de crisis y activación de planes de continuidad, recuperación controlada de un incidente y comunicación con partes interesadas internas y externas;

d) coordinación con partes interesadas internas y externas, tales como autoridades, grupos y foros de interés externos, proveedores y clientes (véanse los numerales 5.5 y 5.6);

e) registro de actividades de gestión de incidentes;

f) gestión de evidencia (véase el numeral 5.28);

g) análisis de la causa raíz o procedimientos post mortem;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

h) identificación de las lecciones aprendidas y cualquier mejora en los procedimientos de gestión de incidentes o en los controles de seguridad de la información en general que sean necesarios.

Procedimientos de presentación de informes

Los procedimientos de presentación de informes deberían incluir:

a) acciones a tomar en caso de un evento de seguridad de la información (por ejemplo, anotar todos los detalles pertinentes inmediatamente, como la aparición de errores de funcionamiento y mensajes en pantalla, informar inmediatamente al punto de contacto y solo tomar acciones coordinadas);

b) uso de formularios de incidentes para ayudar al personal a realizar todas las acciones necesarias al informar de incidentes de seguridad de la información;

c) procesos de retroalimentación adecuados para asegurar que las personas que informan sobre eventos de seguridad de la información sean notificadas, en la medida de lo posible, de los resultados una vez que se ha abordado y cerrado el problema;

d) creación de informes de incidentes.

Cualquier requisito externo sobre la notificación de incidentes a las partes interesadas pertinentes dentro del plazo definido (por ejemplo, los requisitos de notificación de infracciones a los reguladores) debería ser considerado al implementar los procedimientos de gestión de incidentes.

Otra información

Los incidentes de seguridad de la información pueden trascender las fronteras organizativas y nacionales. Para responder a tales incidentes, es conveniente coordinar la respuesta y compartir información sobre estos incidentes con organizaciones externas, según corresponda.

En la serie GTC-ISO/IEC 27035 se proporciona una guía detallada sobre la gestión de incidentes relacionados con la seguridad de la información.

5.25 Evaluación y decisión sobre eventos de seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Detección	#Confidencialidad #Integridad #Disponibilidad	#Detección #Respuesta	#Gestión de eventos de seguridad de la información	#Defensa

Control

La organización debería evaluar los eventos de seguridad de la información y decidir si se deberían clasificar como incidentes de seguridad de la información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Asegurar la categorización y priorización efectivas de los eventos de seguridad de la información.

Guía

ría acordarse un esquema de categorización y priorización de los incidentes de seguridad de la información para la identificación de las consecuencias y la prioridad de un incidente. El esquema debería incluir los criterios para clasificar los eventos como incidentes de seguridad de la información. El punto de contacto debería evaluar cada evento de seguridad de la información al utilizar el esquema acordado.

El personal responsable de coordinar y responder a los incidentes de seguridad de la información debería realizar la evaluación y tomar una decisión sobre los eventos de seguridad de la información.

Los resultados de la evaluación y la decisión deberían registrarse en detalle a efectos de futuras referencias y verificación.

Otra información

La serie GTC-ISO/IEC 27035 proporciona más guía sobre la gestión de incidentes.

5.26 Respuesta a los incidentes de seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Responder #Recuperar	#Gestión de eventos de seguridad de la información	#Defensa

Control

Los incidentes de seguridad de la información se deberían responder de conformidad con los procedimientos documentados.

Objetivo

Asegurar una respuesta eficaz a los incidentes de seguridad de la información.

Guía

La organización debería establecer y comunicar los procedimientos de respuesta a incidentes de seguridad de la información a todas las partes interesadas pertinentes.

Los incidentes de seguridad de la información deberían ser respondidos por un equipo designado con la competencia requerida (véase el numeral 5.24).

La respuesta debería incluir lo siguiente:

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

a) que contenga, si las consecuencias del incidente pueden extenderse, los sistemas afectados por el mismo;

b) recopilación de evidencia (véase el numeral 5.28) lo antes posible, después de la ocurrencia;

c) escalamiento, según sea necesario, que incluya actividades de gestión de crisis y posiblemente invocando planes de continuidad de negocio (véanse los numerales 5.29 y 5.30);

d) asegurar que todas las actividades de respuesta implicadas se registran correctamente para su posterior análisis;

e) comunicar la existencia del incidente de seguridad de la información o de cualquier detalle pertinente a todas las partes interesadas internas y externas pertinentes según el principio de necesidad de saber;

f) coordinar con las partes internas y externas como autoridades, grupos de interés y foros externos, proveedores y clientes para mejorar la eficacia de la respuesta y ayudar a minimizar las consecuencias para otras organizaciones;

g) una vez que el incidente ha sido abordado con éxito, cerrarlo formalmente y registrarlo;

h) realizar análisis forenses de seguridad de la información, según sea necesario (véase el numeral 5.28);

i) realización de análisis post-incidente para identificar la causa raíz. Asegurarse de que se documente y comunique de acuerdo con los procedimientos definidos (véase el numeral 5.27);

j) identificar y gestionar las vulnerabilidades y debilidades de seguridad de la información, lo que incluye las relacionadas con los controles que han causado, contribuido o no han podido prevenir el incidente.

Otra información

La serie GTC-ISO/IEC 27035 proporciona más guía sobre la gestión de incidentes.

5.27 Aprendizaje de los incidentes de seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Gestión de eventos de seguridad de la información	#Defensa

Control

Los conocimientos obtenidos de los incidentes de seguridad de la información deberían utilizarse para reforzar y mejorar los controles de seguridad de la información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Reducir la probabilidad o las consecuencias de futuros incidentes.

Guía

La organización debería establecer procedimientos para cuantificar y supervisar los tipos, volúmenes y costos de los incidentes de seguridad de la información.

La información obtenida de la evaluación de incidentes de seguridad de la información debería utilizarse para:

a) mejorar el plan de gestión de incidentes, incluidos los escenarios y procedimientos de incidentes (véase el numeral 5.24);

b) identificar incidentes recurrentes o graves y sus causas para actualizar la evaluación de riesgos de seguridad de la información de la organización y determinar e implementar los controles adicionales necesarios para reducir la probabilidad o consecuencias de futuros incidentes similares. Mecanismos que permitan recopilar, cuantificar y supervisar información sobre tipos, volúmenes y costes de incidentes;

c) mejorar el conocimiento y la formación de los usuarios (véase el numeral 6.3) proporcionando ejemplos de lo que puede suceder, cómo responder a dichos incidentes y cómo evitarlos en el futuro.

Otra información

La serie GTC-ISO/IEC 27035 proporciona más guía.

5.28 Recopilación de evidencias

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Detección #Respuesta	#Gestión de eventos de seguridad de la información	#Defensa

Control

La organización debería establecer e implementar procedimientos para la identificación, recolección, adquisición y preservación de pruebas relacionadas con eventos de seguridad de la información.

Objetivo

Asegurar una gestión coherente y eficaz de las pruebas relacionadas con los incidentes de seguridad de la información para los fines de las acciones disciplinarias y legales.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Guía

Se deberían desarrollar y seguir procedimientos internos cuando se trate de la evidenciar relacionadas con eventos de seguridad de la información para los propósitos de acciones disciplinarias y legales. Se deberían considerar los requisitos de las diferentes jurisdicciones para maximizar las posibilidades de admisión en las jurisdicciones pertinentes.

En general, estos procedimientos para la gestión de las evidencias deberían proporcionar instrucciones para la identificación, recopilación, adquisición y preservación de las pruebas de conformidad con los diferentes tipos de medios de almacenamiento, dispositivos y estado de los mismos (es decir, encendidos o apagados). Por lo general, las evidencias se deberían recopilar de manera que sean admisibles en los tribunales nacionales correspondientes o en otro foro disciplinario. Debería ser posible demostrar que:

a) los registros están completos y no se han manipulado de ninguna manera;

b) las copias de las pruebas electrónicas son probablemente idénticas a las originales;

c) cualquier sistema de información del que se hayan recopilado pruebas funcionaba correctamente en el momento en que se registraron dichas pruebas.

Cuando se disponga de ella, debería buscarse la certificación u otros medios pertinentes de calificación del personal y de los instrumentos, a fin de fortalecer el valor de las pruebas conservadas.

La evidencia digital puede trascender los límites organizativos o jurisdiccionales. En tales casos, debería Asegurarse que la organización tenga derecho a recopilar la información requerida como prueba digital.

Otra información

Cuando se detecta por primera vez un evento de seguridad de la información, no siempre es evidente si el evento dará lugar o no a una acción judicial. Por lo tanto, existe el peligro de que las evidencias necesarias se destruyan de forma intencionada o accidental antes de que se comprenda la gravedad del incidente. Se recomienda recurrir al asesoramiento jurídico o a las fuerzas de seguridad en una fase temprana de cualquier acción legal prevista y asesorarse sobre las pruebas necesarias.

La norma ISO/IEC 27037 proporciona definiciones y directrices para la identificación, recopilación, adquisición y conservación de pruebas digitales.

La serie ISO/IEC 27050 trata del descubrimiento electrónico, que implica el procesamiento de información almacenada electrónicamente como prueba.

5.29 Seguridad de la información durante la interrupción

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder	#Continuidad	#Protección #Resiliencia

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Control

La organización debería planificar cómo mantener la seguridad de la información en un nivel adecuado durante la interrupción.

Objetivo

Proteger la información y otros activos asociados durante la interrupción.

Guía

La organización debería determinar sus requisitos para adaptar los controles de seguridad de la información durante la interrupción. Los requisitos de seguridad de la información deberían incluirse en los procesos de gestión de la continuidad del negocio.

Se debería desarrollar, implementar, probar, revisar y evaluar planes para mantener o restaurar la seguridad de la información de los procesos del negocioes críticos tras una interrupción o una falla. La seguridad de la información debería restaurarse en el nivel requerido y en los plazos requeridos.

La organización debería implementar y mantener:

a) controles de seguridad de la información, sistemas y herramientas de apoyo dentro de los planes de continuidad del negocio y de las TIC;

b) los procesos para mantener los controles de seguridad de la información existentes durante la interrupción;

c) compensación de los controles de seguridad de la información que no se pueden mantener durante la interrupción.

Otra información

En el contexto de la continuidad del negocio y la planificación de la continuidad de las TIC, puede ser necesario adaptar los requisitos de seguridad de la información en función del tipo de interrupción, en comparación con las condiciones operativas normales. Como parte del análisis del impacto en el negocio y de la evaluación de riesgos realizada dentro de la gestión de la continuidad del negocio, se deberían considerar y priorizar las consecuencias de la pérdida de confidencialidad e integridad de la información, además de la necesidad de mantener la disponibilidad.

La información sobre los sistemas de gestión de la continuidad del negocio se encuentra en las normas ISO 22301 e ISO 22313. En la ISO/TS 22317 se puede encontrar más guía sobre el análisis de impacto del negocio (BIA).

5.30 Preparación de las TIC para la continuidad de la actividad

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Correctivo	#Disponibilidad.	#Responder	#Continuidad	#Resiliencia

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Control

La preparación para las TIC debería planificarse, implementarse, mantenerse y probarse sobre la base de los objetivos de continuidad del negocio y los requisitos de continuidad de las TIC.

Objetivo

Asegurar la disponibilidad de la información de la organización y de otros activos asociados durante la interrupción.

Guía

La preparación de las TIC para la continuidad del negocio es un componente importante en la gestión de la continuidad del negocio y la gestión de la seguridad de la información para Asegurar que los objetivos de la organización puedan seguir cumpliéndose durante la interrupción.

Los requisitos de continuidad de las TIC son el resultado del análisis de impacto de negocio (BIA, por sus iniciales en inglés). El proceso BIA debería utilizar tipos y criterios de impacto para evaluar los impactos a lo largo del tiempo resultantes de la interrupción de las actividades comerciales que ofrecen productos y servicios. La magnitud y la duración del impacto resultante deberían utilizarse para identificar las actividades prioritarias a las que se debería asignar un objetivo de tiempo de recuperación (RTO). LA BIA debería entonces determinar qué recursos se necesitan para apoyar las actividades prioritarias. También debería especificarse un RTO para estos recursos. Un subconjunto de estos recursos debería incluir los servicios de TIC.

LA BIA que implica servicios de TIC puede ampliarse para definir los requisitos de rendimiento y capacidad de los sistemas de TIC y los objetivos de punto de recuperación (RPO) de la información necesaria para apoyar las actividades durante la interrupción.

Sobre la base de los resultados de la BIA y de la evaluación de riesgos que implican los servicios de TIC, la organización debería identificar y seleccionar estrategias de continuidad de las TIC que consideren opciones para antes, durante y después de la interrupción. Las estrategias de continuidad del negocio pueden incluir una o más soluciones. Sobre la base de las estrategias, se deberían elaborar, aplicar y probar planes para satisfacer el nivel de disponibilidad requerido de los servicios de TIC y en los plazos requeridos tras la interrupción o el fracaso de los procesos críticos.

La organización debería asegurarse de que:

a) se ha establecido una estructura organizativa adecuada para preparar, mitigar y responder a una interrupción apoyada por el personal con la responsabilidad, autoridad y competencia necesarias;

b) Los planes de continuidad de las TIC, incluidos los procedimientos de respuesta y recuperación en los que se detalla cómo planea la organización gestionar una interrupción del servicio de las TIC, son:

   1) periódicamente evaluados mediante ejercicios y pruebas;

   2) aprobados por la dirección;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) Los planes de continuidad de las TIC incluyen la siguiente información de continuidad de las TIC:

1) Especificaciones de rendimiento y capacidad para cumplir los requisitos y objetivos de continuidad del negocio especificados en el BIA;

2) RTO de cada servicio de TIC priorizado y los procedimientos para restaurar esos componentes;

3) RPO de los recursos priorizados de TIC definidos como información y los procedimientos para restaurar la información.

Otra información

La gestión de la continuidad de las TIC es una parte clave de los requisitos de continuidad del negocio relativos a la disponibilidad para poder:

a) Responder y recuperarse de la interrupción de los servicios de TIC independientemente de la causa;

b) Asegurar que la continuidad de las actividades prioritarias sea apoyada por los servicios de TIC requeridos;

c) Responder antes de que se produzca una interrupción de los servicios de TIC y tras la detección de al menos un incidente que pueda provocar una interrupción de los servicios de TIC.

En la norma ISO/IEC 27031 se ofrecen más orientaciones sobre la preparación de las TIC para la continuidad de las actividades.

En las normas ISO 22301 e ISO 22313 se ofrecen más orientaciones sobre los sistemas de gestión de la continuidad de las actividades. En la norma ISO/TS 22317 se ofrecen más orientaciones sobre el BIA.

5.31 Requisitos legales, estatutarios, reglamentarios y contractuales

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Jurídica_y_conformidad	#Gobierno_y_ ecosistema #Protección

Control

Los requisitos legales, estatutarios, reglamentarios y contractuales relevantes para la seguridad de la información y el enfoque de la organización para cumplir con estos requisitos deberían ser identificados, documentados y actualizados.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Asegurar el cumplimiento de los requisitos estatutarios, reglamentarios y contractuales relacionados con la seguridad de la información.

Guía

General

Los requisitos externos, incluidos los legales, estatutarios, reglamentarios o contractuales, debería tenerse en cuenta cuando:

a) Se desarrollan políticas y procedimientos de seguridad de la información;

b) Se diseñan, aplican o modifican los controles de seguridad de la información;

c) Se clasifica la información y otros activos asociados como parte del proceso para establecer requisitos de seguridad de la información para necesidades internas o acuerdos con proveedores;

d) Se realizan evaluaciones de riesgos de seguridad de la información y se determinan las actividades de tratamiento de riesgos de seguridad de la información;

e) Se determinan los procesos junto con las funciones y responsabilidades relacionadas con la seguridad de la información;

f) Se determinan los requisitos contractuales de los proveedores pertinentes para la organización y el alcance del suministro de productos y servicios.

Legislación y regulaciones

La organización debería:

a) identificar toda la legislación y las normativas pertinentes a la seguridad de la información de la organización para conocer los requisitos de su tipo de negocio;

b) tomar en consideración el cumplimiento en todos los países pertinentes, si la organización:

- realiza negocios en otros países;
- utiliza productos y servicios de otros países en los que las leyes y normativas pueden afectar a la organización;
- transfiere información a través de fronteras jurisdiccionales donde las leyes y reglamentos pueden afectar a la organización;

c) revisar periódicamente la legislación y el reglamento identificados a fin de mantenerse al día con los cambios e identificar la nueva legislación;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

d) definir y documentar los procesos específicos y las responsabilidades individuales para cumplir con estos requisitos.

Cifrado

El campo del cifrado es un área que a menudo tiene requisitos legales específicos. Se debería tener en cuenta el cumplimiento de los acuerdos, leyes y reglamentos pertinentes relativos a los siguientes elementos:

a) restricciones a la importación o exportación de hardware y software informático para la realización de funciones de cifrado;

b) restricciones a la importación o exportación de hardware y software informático diseñado para que se le añadan funciones de cifrado;

c) restricciones al uso del cifrado;

d) métodos obligatorios o discrecionales de acceso de las autoridades de los países a la información cifrada;

e) validez de firmas digitales, sellos y certificados.

Se recomienda buscar asesoramiento jurídico para Asegurar el cumplimiento de la legislación y las normativas pertinentes, especialmente cuando la información cifrada o las herramientas de cifrado se desplazan a través de las fronteras jurisdiccionales.

Contratos

Los requisitos contractuales relacionados con la seguridad de la información deberían incluir los que se indican en:

a) contratos con clientes;

b) contratos con proveedores (véase el numeral 5.20);

c) contratos de seguros.

Otra información

No hay más información.

5.32 Derechos de propiedad intelectual

Tipo de control	Información Propiedades de seguridad	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Jurídica_y_conformidad	#Gobierno_y_ Ecosistema

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Control

La organización debería aplicar los procedimientos apropiados para proteger los derechos de propiedad intelectual.

Objetivo

Asegurar el cumplimiento de los requisitos legales, legales, reglamentarios y contractuales relacionados con los derechos de propiedad intelectual y el uso de productos propietarios.

Guía

Se ría considerar las siguientes directrices para proteger cualquier material que pueda considerarse propiedad intelectual:

a) definir y comunicar una política temática específica sobre la protección de los derechos de propiedad intelectual;

b) publicar procedimientos para el cumplimiento de los derechos de propiedad intelectual que definan el uso conforme del software y los productos de información;

c) la adquisición de software solo a través de fuentes conocidas y acreditadas, para Asegurar que no se infrinja el copyright;

d) mantener registros de activos adecuados e identificar todos los activos con requisitos para proteger los derechos de propiedad intelectual;

e) mantener pruebas y pruebas de la propiedad de licencias, manuales, etc.;

f) Asegurar que no se supere el número máximo de usuarios o recursos [por ejemplo, unidades de procesamiento central (CPU)] permitidos en la licencia;

g) llevar a cabo revisiones para Asegurar que solo se instalan el software autorizado y los productos con licencia;

h) proporcionar procedimientos para mantener las condiciones de licencia adecuadas;

i) proporcionar procedimientos para desechar o transferir software a otros;

j) el cumplimiento de los términos y condiciones del software y de la información obtenida de redes públicas y fuentes externas;

k) no duplicar, convertir a otro formato o extraer de grabaciones comerciales (video, audio) que no estén permitidas por la ley de copyright o las licencias aplicables;

l) no copiar, en su totalidad o en parte, normas (por ejemplo, normas internacionales ISO/IEC), libros, artículos, informes u otros documentos, distintos de los permitidos por la ley de derechos de autor o las licencias aplicables.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Otra información

Los derechos de propiedad intelectual incluyen los derechos de autor de software o documentos, los derechos de diseño, las marcas comerciales, las patentes y las licencias de código fuente.

Los productos de software propietario se suministran normalmente bajo un acuerdo de licencia que especifica los términos y condiciones de la licencia, por ejemplo, al limitar el uso de los productos a máquinas específicas o al limitar la copia a la creación de copias de seguridad solamente. Véase el numeral la serie ISO/IEC 19770 para obtener información detallada sobre la gestión de activos de TI.

Los datos se pueden obtener de fuentes externas. En general, se da el caso de que esos datos se obtengan en virtud de los términos de un acuerdo de intercambio de datos o de un instrumento jurídico similar. Dichos acuerdos de intercambio de datos deberían dejar claro qué procesamiento se permite para los datos adquiridos. También es aconsejable que se indique claramente la procedencia de los datos. Véase el numeral la norma ISO/IEC 23751[1)] para obtener detalles sobre los acuerdos de intercambio de datos.

Los requisitos legales, estatutarios, reglamentarios y contractuales pueden imponer restricciones a la copia de material propietario. En particular, pueden exigir que solo se pueda utilizar material desarrollado por la organización o autorizado o suministrado por el desarrollador a la organización. La infracción de los derechos de autor puede conducir a acciones legales, que pueden implicar multas y procedimientos penales.

Aparte de que la organización necesita cumplir con sus obligaciones con respecto a los derechos de propiedad intelectual de terceros, también deberían gestionarse los riesgos de que el personal y terceros no respeten los derechos de propiedad intelectual de la organización.

5.33 Protección de los registros

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Legal_y_conformidad #Gestión_de_activos #Protección_de_la_información	#Defensa

Control

Los registros deberían estar protegidos de pérdidas, destrucción, falsificación, acceso no autorizado y liberación no autorizada.

Objetivo

Asegurar el cumplimiento de los requisitos legales, legales, reglamentarios y contractuales, así como de las expectativas comunitarias o sociales relacionadas con la protección y disponibilidad de los registros.

1) En preparación. Etapa en el momento de la publicación: ISO/IEC PRF 23751:2022.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Guía

La organización debería tomar las siguientes medidas para proteger la autenticidad, fiabilidad, integridad y usabilidad de los registros, a medida que su contexto del negocio y los requisitos para su gestión cambien con el tiempo:

a) emitir directrices sobre el almacenamiento, la cadena de custodia y la disposición de los registros, lo que incluye la prevención de la manipulación de los registros. Estas directrices deberían estar alineadas con la política temática específica de la organización sobre gestión de registros y otros requisitos de registros;

b) elaborar un programa de retención que defina los registros y el período de tiempo durante el que deberían conservarse.

El sistema de almacenamiento y manipulación debería Asegurar la identificación de los registros y de su período de retención, tomando en consideración la legislación o los reglamentos nacionales o regionales, así como las expectativas de la comunidad o de la sociedad, si procede. Este sistema debería permitir la destrucción apropiada de los registros después de ese período si la organización no los necesita.

Al decidir sobre la protección de registros organizativos específicos, debería considerarse su clasificación de seguridad de la información correspondiente, basada en el esquema de clasificación de la organización. Los registros deberían clasificarse en tipos de registros (por ejemplo, registros contables, registros de transacciones comerciales, registros de personal, registros legales), cada uno con detalles de los períodos de retención y el tipo de medios de almacenamiento permitidos que pueden ser físicos o electrónicos.

Los sistemas de almacenamiento de datos deberían elegirse de forma que los registros necesarios puedan recuperarse en un marco de tiempo y formato aceptables, dependiendo de los requisitos que se cumplan.

Cuando se elijan medios de almacenamiento electrónicos, deberían establecerse procedimientos para Asegurar la capacidad de acceder a los registros (tanto medios de almacenamiento como legibilidad de formato) durante todo el período de retención, a fin de proteger contra las pérdidas debidas a futuros cambios tecnológicos. Todas las claves cifradas y los programas asociados a los archivos cifrados o a las firmas digitales también deberían conservarse para permitir el descifrado de los registros durante el tiempo que se conserven. (Véase el numeral 8.24).

Los procedimientos de almacenamiento y manipulación deberían aplicarse de conformidad con las recomendaciones proporcionadas por los fabricantes de medios de almacenamiento. Se debería considerar la posibilidad de deterioro de los medios utilizados para el almacenamiento de registros.

Otra información

Los registros documentan eventos o transacciones individuales o pueden formar agregaciones diseñadas para documentar procesos, actividades o funciones de trabajo. Éstos constituyen pruebas de la actividad del negocio y de los activos de información. Cualquier conjunto de información, independientemente de su estructura o formulario, se puede administrar como un registro. Esto incluye información en forma de documento, recopilación de datos u otros tipos de información digital o analógica que se crean, capturan y gestionan en el curso de la actividad del negocio.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

En la gestión de registros, los metadatos son datos que describen el contexto, el contenido y la estructura de los registros, así como su gestión a lo largo del tiempo. Los metadatos son un componente esencial de cualquier documento.

Puede ser necesario conservar algunos registros de forma segura para cumplir con los requisitos legales, estatutarios, reglamentarios o contractuales, así como para apoyar las actividades del negocioes esenciales. La legislación nacional puede establecer el período de tiempo y el contenido de los datos para la conservación de la información. Puede encontrar más información sobre la gestión de documentos en la norma ISO 15489.

5.34 Privacidad y protección de la IIP

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Protección_de_la_información #Legal_y_conformidad	#Protección

Control

La organización debería identificar y cumplir con los requisitos relativos a la preservación de la privacidad y la protección de la IIP de acuerdo con las leyes y reglamentos aplicables y los requisitos contractuales.

Objetivo

Asegurar el cumplimiento de los requisitos legales, estatutarios, reglamentarios y contractuales relacionados con los aspectos de seguridad de la información de la protección de la IIP.

Guía

La organización debería establecer y comunicar una política específica sobre privacidad y protección de la IIP a todas las partes interesadas pertinentes.

La organización debería desarrollar e implementar procedimientos para la preservación de la privacidad y la protección de la IIP. Estos procedimientos deberían comunicarse a todas las partes interesadas pertinentes que participen en el tratamiento de la información de identificación personal.

El cumplimiento de estos procedimientos y de toda la legislación y normativa pertinente relativa a la preservación de la privacidad y la protección de la IIP requiere funciones, responsabilidades y controles apropiados. A menudo, esto se consigue mejor con el nombramiento de una persona responsable, como un funcionario de privacidad, que debería proporcionar guía al personal, proveedores de servicios y otras partes interesadas sobre sus responsabilidades individuales y los procedimientos específicos que deberían seguirse.

La responsabilidad de la manipulación de la IIP debería abordarse tomando en consideración la legislación y los reglamentos pertinentes.

Deberían aplicarse medidas técnicas y organizativas apropiadas para proteger la IIP.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Otra información

Varios países han introducido una legislación que controla la recogida, el tratamiento, la transmisión y la supresión de la IIP. Dependiendo de la legislación nacional respectiva, tales controles pueden imponer obligaciones a los que recolectan, procesan y difunden la IIP y también pueden restringir la autoridad para transferir la IIP a otros países.

La norma ISO/IEC NTC-29100 proporciona un marco de alto nivel para la protección de la IIP en los sistemas de TIC. Puede encontrar más información sobre los sistemas de gestión de la información sobre la privacidad en la norma ISO/IEC 27701. En la norma ISO/IEC 27018 se puede encontrar información específica sobre la gestión de la información de privacidad para las nubes públicas que actúan como procesadores IIP.

La ISO/IEC 29134 proporciona directrices para la evaluación del impacto en la privacidad (PIA) y ofrece un ejemplo de la estructura y el contenido de un informe de PIA. En comparación con la norma ISO/IEC 27005, se centra en el procesamiento de la IIP y es pertinente para las organizaciones que procesan IIP. Esto puede ayudar a identificar riesgos de privacidad y posibles mitigaciones para reducir estos riesgos a niveles aceptables.

5.35 Revisión independiente de la seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Aseguramiento_de_la_información	#Gobierno_y_ Ecosistema

Control

El enfoque de la organización para gestionar la seguridad de la información y su implementación, incluidas las personas, los procesos y las tecnologías, debería revisarse de forma independiente a intervalos planificados o cuando se produzcan cambios significativos.

Objetivo

Asegurar la idoneidad, adecuación y eficacia continuas del enfoque de la organización para gestionar la seguridad de la información.

Guía

La organización debería tener procesos para realizar revisiones independientes.

La dirección debería planificar e iniciar revisiones independientes periódicas. Las revisiones deberían incluir la evaluación de las oportunidades de mejora y la necesidad de cambios en el enfoque de la seguridad de la información, lo que incluye la política de seguridad de la información, las políticas de temas específicos y otros controles.

Dichas revisiones deberían ser llevadas a cabo por personas independientes del área revisada (por ejemplo, la función de auditoría interna, un gestor independiente o una organización externa especializada en dichas revisiones). Las personas que lleven a cabo estas revisiones deberían tener

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

la competencia adecuada. La persona que lleve a cabo las revisiones no debería estar en la línea de autoridad para Asegurar que tenga la independencia necesaria para realizar una evaluación.

Los resultados de las revisiones independientes deberían comunicarse a los directivos que las iniciaron y, en su caso, a la alta dirección. Estos documentos deberían conservarse.

Si las revisiones independientes identifican que el enfoque y la implementación de la organización para administrar la seguridad de la información son inadecuados [por ejemplo, los objetivos y requisitos documentados no se cumplen o no se ajustan con la dirección de seguridad de la información indicada en la política de seguridad de la información y las políticas de temas específicos (véase el numeral 5.1)], la dirección debería iniciar acciones correctivas.

Además de las revisiones periódicas independientes, la organización debería considerar la posibilidad de realizar revisiones independientes cuando:

a) leyes y reglamentos que afectan al cambio de organización;

b) se producen incidentes significativos;

c) la organización inicia un nuevo negocio o cambia un negocio actual;

d) la organización comienza a utilizar un nuevo producto o servicio o cambia el uso de un producto o servicio actual;

e) la organización cambia significativamente los controles y procedimientos de seguridad de la información.

Otra información

Las normas ISO/IEC 27007 e ISO/IEC TS 27008 proporcionan guía para llevar a cabo revisiones independientes.

5.36 Cumplimiento de las políticas, reglas y normas de seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operacionales	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Seguridad_legal_y_cumplimiento #Seguridad_de_la_información	#Gobierno_y_ Ecosistema

Control

El cumplimiento de la política de seguridad de la información de la organización, las políticas, las reglas y los estándares específicos por tema deberían revisarse periódicamente.

Objetivo

Asegurar que la seguridad de la información se implementa y opera de acuerdo con la política de seguridad de la información de la organización, las políticas, reglas y normas específicas por tema.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Guía

Los administradores, los propietarios de servicios, productos o información deberían identificar cómo revisar que se cumplen los requisitos de seguridad de la información definidos en la directiva de seguridad de la información, las directivas específicas por tema, las reglas, las normas y otras regulaciones que sean aplicables. Se deberían considerar las herramientas automáticas de medición y elaboración de informes para una revisión periódica eficaz.

Si se encuentra alguna no conformidad como resultado de la revisión, los administradores deberían:

a) identificar las causas de la no conformidad;

b) evaluar la necesidad de medidas correctivas para lograr la conformidad;

c) implementar las acciones correctivas adecuadas;

d) revisar las medidas correctivas adoptadas para verificar su eficacia e identificar deficiencias o debilidades.

Se deberían registrar los resultados de las revisiones y acciones correctivas llevadas a cabo por los gerentes, los propietarios de servicios, productos o información y se deberían conservar estos documentos. Los administradores deberían informar los resultados a las personas que realizan revisiones independientes (véase el numeral 5.35) cuando se lleve a cabo una revisión independiente en el área de su responsabilidad.

Las acciones correctivas deberían completarse de manera oportuna, según corresponda al riesgo. Si no se completa en la próxima revisión programada, los progresos deberían abordarse al menos en esa revisión.

Otra información

El seguimiento operativo del uso del sistema se trata en los numerales 8.15, 8.16, 8.17.

5.37 Procedimientos operativos documentados

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Recuperar	#Gestión_de_activos #Seguridad_física #Seguridad_del_sistema_y_de_la_red #Seguridad_de_las_aplicaciones #Configuración_segura #Gestión_de_la_identidad_y_del_acceso #Gestión_de_las_amenazas_y_de_la_vulnerabilidad #Continuidad #Gestión_de_actos_de_seguridad_de_la_información	#Gobierno_y_ecosistema #Protección #Defensa

Control

Los procedimientos operativos para las instalaciones de procesamiento de la información deberían estar documentados y disponibles para el personal que los necesite.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Asegurar el funcionamiento correcto y seguro de las instalaciones de procesamiento de información.

Guía

Se deberían preparar los procedimientos documentados para las actividades operacionales de la organización asociadas con la seguridad de la información, por ejemplo:

a) cuando la actividad necesite ser realizada de la misma manera por muchas personas;

b) cuando la actividad se realiza en raras ocasiones y la siguiente vez que se realiza, es probable que se haya olvidado el procedimiento;

c) cuando la actividad es nueva y presenta un riesgo si no se realiza correctamente;

d) antes de entregar la actividad al nuevo personal.

Los procedimientos operativos deberían especificar:

a) las personas responsables;

b) la instalación y configuración seguras de los sistemas;

c) procesamiento y manejo de la información, tanto automatizada como manual;

d) respaldo (véase el numeral 8.13) y resiliencia;

e) requisitos de programación, incluidas las interdependencias con otros sistemas;

f) instrucciones para gestionar errores u otras condiciones excepcionales [por ejemplo, restricciones en el uso de programas de utilidad (véase el numeral 8.18)], que pueden surgir durante la ejecución del trabajo;

g) contactos de asistencia y escalada, incluidos contactos de asistencia externa en caso de dificultades técnicas u operativas inesperadas;

h) instrucciones de manipulación de los soportes de almacenamiento (véanse los numerales 7.10 y 7.14);

i) procedimientos de reinicio y recuperación del sistema para su uso en caso de falla del sistema;

j) la gestión de la información del registro de auditoría y del registro del sistema (véanse los numerales 8.15 y 8.17) y de los sistemas de monitoreo de video (véase el numeral 7.4);

k) procedimientos de monitoreo como la capacidad, el rendimiento y la seguridad (véanse los numerales 8.6 y 8.16);

l) instrucciones de mantenimiento.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Los procedimientos operativos documentados deberían revisarse y actualizarse cuando sea necesario. Se deberían autorizar los cambios en los procedimientos operativos documentados. Cuando sea técnicamente factible, los sistemas de información deberían gestionarse de manera coherente, al utilizar los mismos procedimientos, herramientas y servicios públicos.

Otra información

No hay más información.

6. CONTROLES DE PERSONAS

6.1 Selección

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobierno_y_ Ecosistema

Control

Las verificaciones de los antecedentes de todos los candidatos a convertirse en personal deberían llevarse a cabo antes de incorporarse a la organización y de forma continuada, tomando en consideración las leyes, los reglamentos y la ética aplicables y ser proporcionales a los requisitos de la empresa, la clasificación de la información a la que se va a acceder y los riesgos percibidos.

Objetivo

Asegurar que todo el personal es elegible y adecuado para las funciones para las que se considera y que sigue siendo elegible y adecuado durante su empleo.

Guía

Se debería realizar un proceso de selección para todo el personal, incluido el personal a tiempo completo, a tiempo parcial y temporal. Cuando estas personas se contraten a través de proveedores de servicios, los requisitos de selección se deberían incluir en los acuerdos contractuales entre la organización y los proveedores.

La información sobre todos los candidatos que se consideren para puestos dentro de la organización debería ser recogida y manejada tomando en consideración cualquier legislación apropiada existente en la jurisdicción pertinente. En algunas jurisdicciones, la organización puede ser legalmente requerida para informar a los candidatos previamente sobre las actividades de selección.

La verificación debería tener en cuenta toda la legislación pertinente en materia de privacidad, protección de la IIP y basada en el empleo y, cuando lo permita, debería incluir lo siguiente:

a) disponibilidad de referencias satisfactorias (por ejemplo, referencias comerciales y personales);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) una verificación (para la integridad y exactitud) del currículum vitae del solicitante;

c) confirmación de las calificaciones académicas y profesionales declaradas;

d) verificación independiente de la identidad (por ejemplo, pasaporte u otro documento aceptable expedido por las autoridades competentes);

e) una verificación más detallada, como la revisión de crédito o la revisión de registros criminales si el candidato asume un papel crítico.

Cuando se contrata a un individuo para una función específica de seguridad de la información, la organización debería asegurarse de que el candidato:

a) tenga la competencia necesaria para desempeñar el papel de seguridad;

b) se pueda confiar en él para asumir el rol, especialmente si el rol es crítico para la organización.

Cuando un puesto de trabajo ya sea en el momento del nombramiento inicial o de la promoción, implique que la persona tenga acceso a instalaciones de procesamiento de información y, en especial, si éstas implican el manejo de información confidencial (por ejemplo, información financiera, información personal o información médica), la organización también debería considerar la posibilidad de realizar verificaciones adicionales más detalladas.

Los procedimientos deberían definir criterios y limitaciones para las revisiones de verificación (por ejemplo, , quién puede seleccionar a las personas y cómo, cuándo y por qué se llevan a cabo las revisiones de verificación).

En situaciones en las que la verificación no se puede completar de forma oportuna, se deberían implementar controles atenuantes hasta que se haya terminado la revisión, por ejemplo:

a) retraso en la incorporación;

b) retraso en el despliegue de activos corporativos;

c) incorporación con acceso reducido;

d) terminación del empleo.

Los controles de verificación deberían repetirse periódicamente para confirmar la idoneidad continua del personal, dependiendo de la criticidad de la función de una persona.

Otra información

No hay más información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

6.2 Condiciones del empleo

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobierno_y_ Ecosistema

Control

Los acuerdos contractuales de empleo deberían indicar las responsabilidades del personal y de la organización en materia de seguridad de la información.

Objetivo

Asegurar que el personal comprenda sus responsabilidades de seguridad de la información para las funciones para las que se consideran.

Guía

Las obligaciones contractuales para el personal deberían tener en cuenta la política de seguridad de la información de la organización y las políticas pertinentes relativas a temas específicos. Además, se pueden aclarar y precisar los siguientes puntos:

a) acuerdos de confidencialidad o no divulgación que el personal al que se dé acceso a información confidencial debería firmar antes de que se le dé acceso a la información y otros activos asociados (véase el numeral 6.6);

b) responsabilidades y derechos legales [por ejemplo, con respecto a las leyes de derechos de autor o la legislación sobre protección de datos (véanse los numerales 5.32 y 5.34)];

c) responsabilidades para la clasificación de la información y la gestión de la información de la organización y otros activos asociados, instalaciones de procesamiento de información y servicios de información gestionados por el personal (véanse los numerales 5.9 al 5.13);

d) responsabilidades para el manejo de la información recibida de las partes interesadas;

e) acciones a tomar si el personal ignora los requisitos de seguridad de la organización (véase el numeral 6.4).

Las funciones y responsabilidades de seguridad de la información deberían comunicarse a los candidatos durante el proceso de precontratación.

La organización debería asegurarse de que el personal acepte los términos y condiciones relativos a la seguridad de la información. Estos términos y condiciones deberían ser apropiados a la naturaleza y el grado de acceso que tengan a los activos de la organización asociados con los sistemas y servicios de información. Los términos y condiciones relativos a la seguridad de la información deberían revisarse cuando cambien las leyes, reglamentos, la política de seguridad de la información o las políticas específicas por tema.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

En su caso, las responsabilidades contenidas en las condiciones de empleo deberían continuar durante un período determinado después del final del empleo (véase el numeral 6.5).

Otra información

Se puede utilizar un código de conducta para las responsabilidades de seguridad de la información del personal del estado en relación con la confidencialidad, la protección de la IIP, la ética, el uso apropiado de la información de la organización y otros activos asociados, así como las prácticas de reputación esperadas por la organización.

Una parte externa, con la que el personal del proveedor está asociado, puede estar obligado a celebrar acuerdos contractuales en nombre de la persona contratada.

Si la organización no es una entidad legal y no tiene empleados, el equivalente del acuerdo contractual y los términos y condiciones pueden considerarse de acuerdo con la directriz de este control.

6.3 Sensibilización, educación y formación en materia de seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobierno_y_ Ecosistema

Control

El personal de la organización y las partes interesadas pertinentes deberían recibir una sensibilización, educación y formación adecuadas en materia de seguridad de la información, así como actualizaciones periódicas de la política de seguridad de la información de la organización y de las políticas y procedimientos específicos, según sea pertinente para su función laboral.

Objetivo

Asegurar que el personal y las partes interesadas pertinentes conozcan y cumplan con sus responsabilidades en materia de seguridad de la información.

Guía

General

Se debería establecer un programa de sensibilización, educación y formación en materia de seguridad de la información en consonancia con la política de seguridad de la información de la organización, las políticas específicas por tema y los procedimientos pertinentes en materia de seguridad de la información, tomando en consideración la información de la organización que se debería proteger y los controles de seguridad de la información que se han aplicado para protegerla.

La sensibilización, la educación y la formación en materia de seguridad de la información deberían tener lugar periódicamente. La sensibilización inicial, la educación y la capacitación pueden aplicarse

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

al nuevo personal y a quienes se transfieren a nuevos puestos o funciones con requisitos de seguridad de la información sustancialmente diferentes.

La comprensión del personal debería evaluarse al final de una actividad de sensibilización, educación o capacitación para poner a prueba la transferencia de conocimientos y la eficacia del programa de sensibilización, educación y capacitación.

Sensibilización

Un programa de concientización sobre la seguridad de la información debería tener por objeto sensibilizar al personal acerca de sus responsabilidades en materia de seguridad de la información y de los medios por los que se han cumplido dichas responsabilidades.

El programa de sensibilización debería planificarse tomando en consideración las funciones del personal de la organización, incluido el personal interno y externo (por ejemplo, consultores externos, personal de proveedores). Las actividades del programa de sensibilización deberían programarse con el tiempo, preferiblemente regularmente, de modo que las actividades se repitan y abarquen al nuevo personal. También debería construirse sobre la base de las lecciones aprendidas de los incidentes de seguridad de la información.

El programa de sensibilización debería incluir una serie de actividades de sensibilización a través de canales físicos o virtuales apropiados, como campañas, folletos, carteles, boletines, sitios web, sesiones de información, sesiones informativas, módulos de e-learning y correos electrónicos.

El conocimiento de la seguridad de la información debería abarcar aspectos generales como:

a) el compromiso de la administración con la seguridad de la información en toda la organización;

b) familiaridad y necesidades de cumplimiento con respecto a las normas y obligaciones de seguridad de la información aplicables, tomando en consideración la política de seguridad de la información y las políticas, normas, leyes, estatutos, reglamentos específicos de cada tema, contratos y acuerdos;

c) responsabilidad personal por las propias acciones e inacciones y responsabilidades generales para asegurar o proteger la información que pertenece a la organización y a las partes interesadas;

d) procedimientos básicos de seguridad de la información [por ejemplo, informes de eventos de seguridad de la información (véase el numeral 6.8)] y controles de referencia [por ejemplo, seguridad mediante contraseña (véase el numeral 5.17)];

e) puntos de contacto y recursos para obtener información adicional y asesoramiento sobre cuestiones de seguridad de la información, incluidos otros materiales de sensibilización sobre seguridad de la información.

Educación y formación

La organización debería identificar, preparar e implementar un plan de capacitación apropiado para los equipos técnicos cuyas funciones requieren conjuntos de habilidades y experiencia específicos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Los equipos técnicos deberían tener las habilidades necesarias para configurar y mantener el nivel de seguridad necesario para dispositivos, sistemas, aplicaciones y servicios. Si faltan habilidades, la organización debería tomar medidas y obtenerlas

El programa de educación y formación debería contemplar diferentes formas [por ejemplo, conferencias o autoaprendizaje, ser asesorado por personal experto o consultores (formación en el puesto de trabajo), rotar a los miembros del personal para que sigan diferentes actividades, contratar a personas ya capacitadas y contratar consultores]. Puede utilizar diferentes medios de entrega, que incluyen clases, aprendizaje a distancia, basado en la web, autodidacta y otros. El personal técnico debería mantener sus conocimientos actualizados al suscribirse a boletines y revistas o asistiendo a conferencias y eventos dirigidos a la mejora técnica y profesional.

Otra información

Al redactar un programa de sensibilización, es importante no solo centrarse en el «qué» y el «cómo», sino también en el «por qué», cuando sea posible. Es importante que el personal comprenda el objetivo de la seguridad de la información y el efecto potencial, positivo y negativo, en la organización de su propio comportamiento.

La sensibilización, la educación y la formación en materia de seguridad de la información pueden formar parte de otras actividades, como la gestión general de la información, las TIC, la seguridad, la privacidad o la formación en materia de seguridad.

6.4 Proceso disciplinario

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder	#Seguridad_de_los_recursos_humanos	#Gobierno_y_ Ecosistema

Control

Se debería formalizar y comunicar un proceso disciplinario para tomar medidas contra el personal y otras partes interesadas pertinentes que hayan cometido una violación de la política de seguridad de la información.

Objetivo

Asegurar que el personal y otras partes interesadas comprendan las consecuencias de la violación de la política de seguridad de la información, para disuadir y tratar adecuadamente al personal y otras partes interesadas pertinentes que hayan cometido la violación.

Guía

El proceso disciplinario no debería iniciarse sin una verificación previa de que se ha producido una violación de la política de seguridad de la información (véase el numeral 5,28).

El proceso disciplinario formal debería proporcionar una respuesta graduada que tome en consideración factores tales como:

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

a) la naturaleza (quién, qué, cuándo, cómo) y la gravedad de la violación y sus consecuencias;

b) si el delito fue intencional (malicioso) o no intencional (accidental);

c) tanto si se trata de una primera infracción como de una reincidencia;

d) si el infractor estaba debidamente formado o no.

La respuesta debería tener en cuenta los requisitos legales, reglamentarios, contractuales y del negocioes pertinentes, así como otros factores según sea necesario. El proceso disciplinario también debería utilizarse como elemento disuasorio para evitar que el personal y otras partes interesadas pertinentes infrinjan la política de seguridad de la información, las políticas específicas del tema y los procedimientos de seguridad de la información. Las infracciones deliberadas de la política de seguridad de la información pueden requerir acciones inmediatas.

Otra información

Siempre que sea posible, la identidad de las personas sujetas a medidas disciplinarias debería protegerse de conformidad con los requisitos aplicables.

Si las personas demuestran un comportamiento excelente en materia de seguridad de la información, se les puede recompensar para promover la seguridad de la información y fomentar el buen comportamiento.

6.5 Responsabilidades tras el cese o el cambio de empleo

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos #Gestión de activos	#Gobierno_y_ Ecosistema

Control

Las responsabilidades y deberes de seguridad de la información que siguen siendo válidos después de la terminación o el cambio de empleo deberían definirse, aplicarse y comunicarse al personal pertinente y a otras partes interesadas.

Objetivo

Proteger los intereses de la organización como parte del proceso de cambio o terminación de empleo o contratos.

Guía

El proceso para administrar la terminación o el cambio de empleo debería definir qué responsabilidades y deberes de seguridad de la información deberían seguir siendo válidos después de la terminación o el cambio.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Esto puede incluir la confidencialidad de la información, la propiedad intelectual y otros conocimientos obtenidos, así como las responsabilidades contenidas en cualquier otro acuerdo de confidencialidad (véase el numeral 6,6). Las responsabilidades y deberes que siguen siendo válidos después de la terminación del empleo o del contrato deberían figurar en los términos y condiciones de empleo del individuo (véase el numeral 6,2), contrato o acuerdo. Otros contratos o acuerdos que continúen por un período definido después del final del empleo de la persona también pueden contener responsabilidades de seguridad de la información.

Los cambios de responsabilidad o de empleo deberían gestionarse como la terminación de la responsabilidad o del empleo actual, combinado con la iniciación de la nueva responsabilidad o empleo.

Las funciones y responsabilidades de seguridad de la información que tenga cualquier persona que abandone o cambie las funciones del trabajo deberían identificarse y transferirse a otra persona.

Debería establecerse un proceso para la comunicación de los cambios y de los procedimientos operativos al personal, a otras partes interesadas y a las personas de contacto pertinentes (por ejemplo, a clientes y proveedores).

El proceso para la terminación o el cambio de empleo también debería aplicarse al personal externo (es decir, a los proveedores) cuando se produce una terminación del personal, el contrato o el trabajo con la organización o cuando hay un cambio de trabajo dentro de la organización.

Otra información

En muchas organizaciones, la función de recursos humanos es generalmente responsable del proceso general de terminación y trabaja junto con el gerente supervisor de la persona en transición para administrar los aspectos de seguridad de la información de los procedimientos pertinentes. En el caso del personal proporcionado a través de una parte externa (por ejemplo, a través de un proveedor), este proceso de terminación es llevado a cabo por la parte externa de acuerdo con el contrato entre la organización y la parte externa.

6.6 Acuerdos de confidencialidad o no divulgación

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad	#Proteger	#Seguridad de los recursos humanos Protección de la información Relaciones con los proveedores	#Gobierno_y_ Ecosistema

Control

Los acuerdos de confidencialidad o no divulgación que reflejen las necesidades de la organización para la protección de la información deberían ser identificados, documentados, revisados y firmados regularmente por el personal y otras partes interesadas pertinentes.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Mantener la confidencialidad de la información accesible por el personal o terceros.

Guía

Los acuerdos de confidencialidad o no divulgación deberían abordar el requisito de proteger la información confidencial al utilizar términos legalmente exigibles. Los acuerdos de confidencialidad o no divulgación son aplicables a las partes interesadas y al personal de la organización. Sobre la base de los requisitos de seguridad de la información de una organización, los términos de los acuerdos deberían determinarse tomando en consideración el tipo de información que se tratará, su nivel de clasificación, su uso y el acceso permitido por la otra parte. Para identificar los requisitos para los acuerdos de confidencialidad o no divulgación, se deberían considerar los siguientes elementos:

a) una definición de la información que se va a proteger (por ejemplo, información confidencial);

b) la duración prevista de un acuerdo, incluidos los casos en que puede ser necesario mantener la confidencialidad indefinidamente o hasta que la información esté disponible públicamente;

c) las acciones necesarias cuando se termina un acuerdo;

d) las responsabilidades y acciones de los signatarios para evitar la divulgación de información no autorizada;

e) la propiedad de la información, los secretos comerciales y la propiedad intelectual y cómo se relaciona con la protección de la información confidencial;

f) el uso permitido de información confidencial y los derechos del signatario a utilizar la información;

g) el derecho a auditar y supervisar actividades que impliquen información confidencial en circunstancias muy sensibles;

h) el proceso para la notificación y notificación de revelación no autorizada o fuga de información confidencial;

i) los términos de la información que se devolverá o destruirá en el momento de la terminación del acuerdo;

j) las medidas previstas en caso de incumplimiento del acuerdo.

La organización debería tener en cuenta el cumplimiento de los acuerdos de confidencialidad y no divulgación de la jurisdicción a la que se aplican (véanse los numerales 5.31, 5.32, 5.33, 5.34).

Los requisitos para los acuerdos de confidencialidad y no divulgación deberían revisarse periódicamente y cuando se produzcan cambios que influyan en estos requisitos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Otra información

Los acuerdos de confidencialidad y no divulgación protegen la información de la organización e informan a los signatarios de su responsabilidad de proteger, utilizar y divulgar la información de una manera responsable y autorizada.

6.7 Trabajo remoto

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de activos #Protección_de_la_información #Seguridad_física #Seguridad_del_sistema_y_de_la_red	#Protección

Control

Las medidas de seguridad deberían implementarse cuando el personal trabaja de forma remota para proteger la información a la que se accede, procesa o almacena fuera de las instalaciones de la organización.

Objetivo

Asegurar la seguridad de la información cuando el personal trabaja de forma remota.

Guía

El trabajo a distancia ocurre siempre que el personal de la organización trabaja desde un lugar fuera de las instalaciones de la organización, al acceder a información ya sea en papel o electrónicamente a través de equipos de TIC. Los entornos de trabajo remoto incluyen los denominados “teletrabajo”, “trabajo a distancia”, “trabajo flexible”, “entornos de trabajo virtuales” y “mantenimiento remoto”.

NOTA Es posible que no todas las recomendaciones de esta guía se puedan aplicar debido a la legislación local y a las regulaciones en diferentes jurisdicciones.

Las organizaciones que permiten actividades de trabajo remoto deberían emitir una política específica sobre trabajo remoto que defina las condiciones y restricciones pertinentes. Cuando se considere aplicable, se deberían considerar los siguientes asuntos:

a) la seguridad física existente o propuesta del lugar de trabajo remoto, tomando en consideración la seguridad física de la ubicación y el entorno local, incluidas las diferentes jurisdicciones en las que se encuentra el personal;

b) reglas y mecanismos de seguridad para el entorno físico remoto, como archivadores bloqueables, transporte seguro entre ubicaciones y reglas para acceso remoto, escritorio transparente, impresión y eliminación de información y otros activos asociados, e informes de eventos de seguridad de la información (véase el numeral 6.8);

c) los entornos de trabajo remotos físicos esperados;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

d) los requisitos de seguridad de las comunicaciones, tomando en consideración la necesidad de acceso remoto a los sistemas de la organización, la sensibilidad de la información a la que se accede y se transmite a través del enlace de comunicaciones y la sensibilidad de los sistemas y aplicaciones;

e) el uso de acceso remoto, como el acceso a escritorios virtuales, que admite el procesamiento y almacenamiento de información en equipos de propiedad privada;

f) la amenaza del acceso no autorizado a la información o los recursos de otras personas en el lugar de trabajo remoto (por ejemplo, familiares y amigos);

g) la amenaza del acceso no autorizado a la información o a los recursos de otras personas en lugares públicos;

h) el uso de redes domésticas y redes públicas, así como los requisitos o restricciones en la configuración de servicios de red inalámbrica;

i) el uso de medidas de seguridad, como firewalls y protección contra malware;

j) mecanismos seguros para desplegar e inicializar sistemas de forma remota;

k) mecanismos seguros para la autenticación y la habilitación de privilegios de acceso tomando en consideración la vulnerabilidad de los mecanismos de autenticación de factor único en los que se permite el acceso remoto a la red de la empresa.

Las directrices y medidas que se deberían considerar deberían incluir:

a) el suministro de equipo y mobiliario de almacenamiento adecuados para las actividades de trabajo a distancia, cuando no se permite el uso de equipo de propiedad privada que no esté bajo el control de la organización;

b) una definición del trabajo permitido, la clasificación de la información que se puede mantener y los sistemas y servicios internos a los que está autorizado el trabajador remoto;

c) la formación de los que trabajan a distancia y de los que prestan apoyo. Esto debería incluir cómo llevar a cabo el negocio de forma segura mientras trabaja de forma remota;

d) el suministro de equipos de comunicación adecuados, incluidos métodos para Asegurar el acceso remoto, como requisitos sobre bloqueos de pantalla del dispositivo y temporizadores de inactividad; la activación del seguimiento de la ubicación del dispositivo; la instalación de capacidades de borrado remoto;

e) seguridad física;

f) normas y directrices sobre el acceso de la familia y los visitantes al equipo y a la información;

g) la prestación de asistencia y mantenimiento de hardware y software;

h) la provisión de seguros;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

i) los procedimientos de respaldo y continuidad del negocio;

j) auditoría y vigilancia de la seguridad;

k) revocación de la autoridad y los derechos de acceso y la devolución del equipo cuando se terminan las actividades de trabajo remoto.

Otra información

No hay más información.

6.8 Informes de eventos de seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Detección	#Confidencialidad #Integridad #Disponibilidad	#Detección	#Gestión de eventos de seguridad de la información	#Defensa

Control

La organización debería proporcionar un mecanismo para que el personal informe sobre los eventos de seguridad de la información observados o sospechosos a través de los canales apropiados de manera oportuna.

Objetivo

Apoyar la notificación oportuna, coherente y eficaz de los eventos de seguridad de la información que pueden ser identificados por el personal.

Guía

Todo el personal y los usuarios deberían ser conscientes de su responsabilidad de informar sobre los eventos de seguridad de la información lo antes posible para evitar o minimizar el efecto de los incidentes de seguridad de la información.

También debería tenerse en cuenta el procedimiento para informar sobre los eventos de seguridad de la información y el punto de contacto al que deberían notificarse los eventos. El mecanismo de presentación de informes debería ser lo más fácil, accesible y disponible posible. Los eventos de seguridad de la información incluyen incidentes, infracciones y vulnerabilidades.

Entre las situaciones que se deberían tener en cuenta para los informes de eventos de seguridad de la información se incluyen:

a) controles de seguridad de la información ineficaces;

b) incumplimiento de las expectativas de confidencialidad, integridad o disponibilidad de la información;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) errores humanos;

d) incumplimiento de la política de seguridad de la información, las directivas de temas específicos o las normas aplicables;

e) infracciones de las medidas de seguridad física;

f) cambios del sistema que no han pasado por el proceso de gestión de cambios;

g) fallas de funcionamiento u otro comportamiento anómalo del software o hardware en el sistema;

h) infracciones de acceso;

i) vulnerabilidades;

j) sospecha de infección de malware.

Se le debería aconsejar al personal y a los usuarios que no intenten probar posibles vulnerabilidades de seguridad de la información. Las vulnerabilidades de prueba se pueden interpretar como un posible mal uso del sistema y también pueden causar daños al sistema o servicio de información y pueden dañar u ocultar las pruebas digitales. En última instancia, esto puede resultar en responsabilidad legal para el individuo que realiza la prueba.

Otra información

Véase el numeral la serie GTC-ISO/IEC 27035 para obtener información adicional.

7. CONTROLES FÍSICOS

7.1 Perímetros de seguridad física

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física	#Protección

Control

Los perímetros de seguridad deberían definirse y utilizarse para proteger las áreas que contienen información y otros activos asociados.

Objetivo

Evitar el acceso físico no autorizado, los daños y las interferencias en la información de la organización y otros activos asociados.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Guía

Las siguientes directrices deberían considerarse e implementarse cuando sea apropiado para los perímetros de seguridad física:

a) definir los perímetros de seguridad y el emplazamiento y la fuerza de cada uno de los perímetros de acuerdo con los requisitos de seguridad de la información relacionados con los activos dentro del perímetro;

b) tener perímetros físicamente sólidos para un edificio o sitio que contenga instalaciones de procesamiento de información (es decir, no debería haber espacios en el perímetro o áreas donde pueda ocurrir fácilmente una ruptura). Los techos exteriores, las paredes, los techos y el suelo del emplazamiento debería ser de construcción sólida y todas las puertas exteriores deberían estar adecuadamente protegidas contra el acceso no autorizado con mecanismos de control (por ejemplo, barras, alarmas, cerraduras). Las puertas y ventanas deberían bloquearse cuando no estén vigiladas y se debería considerar la protección externa para las ventanas, especialmente a nivel del suelo; también deberían considerarse los puntos de ventilación;

c) alarmas, monitoreo y prueba de todas las puertas contra incendios en un perímetro de seguridad junto con las paredes para establecer el nivel requerido de resistencia de acuerdo con estándares adecuados. Deberían funcionar de forma segura.

Otra información

La protección física se puede lograr creando una o más barreras físicas alrededor de las instalaciones de la organización y las instalaciones de procesamiento de información.

Una zona segura puede ser una oficina con cerradura o varias salas rodeadas por una barrera de seguridad física interna continua. Pueden ser necesarias barreras y perímetros adicionales para controlar el acceso físico entre áreas con diferentes requisitos de seguridad dentro del perímetro de seguridad. La organización debería considerar la posibilidad de adoptar medidas de seguridad física que puedan fortalecerse durante situaciones de mayor amenaza.

7.2 Entrada física

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad física #Gestión_de_la_identidad_y_del_acceso	#Protección

Control

Las áreas seguras deberían protegerse mediante controles de entrada y puntos de acceso adecuados.

Objetivo

Asegurar que solo se produce el acceso físico autorizado a la información de la organización y a otros activos asociados.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Guía

General

Los puntos de acceso, como las zonas de entrega y carga y otros puntos en los que personas no autorizadas puedan entrar en las instalaciones, deberían controlarse y, si es posible, aislarse de las instalaciones de procesamiento de información para evitar el acceso no autorizado.

Se deberían tomar en consideración las siguientes directrices:

a) restringir el acceso a los sitios y edificios solo al personal autorizado. El proceso de gestión de los derechos de acceso a las áreas físicas debería incluir la provisión, revisión periódica, actualización y revocación de autorizaciones (véase el numeral 5,18);

b) mantener y supervisar de forma segura un libro de registro físico o un registro de auditoría electrónico de todos los accesos y proteger todos los registros (véase el numeral 5,33) y la información confidencial de autenticación;

c) establecer e implementar un proceso y mecanismos técnicos para la gestión del acceso a las áreas donde se procesa o almacena la información. Los mecanismos de autenticación incluyen el uso de tarjetas de acceso, biometría o autenticación de dos factores, como una tarjeta de acceso y un PIN secreto. Para el acceso a zonas sensibles debería considerarse puertas de seguridad dobles;

d) establecer un área de recepción supervisada por el personal u otros medios para controlar el acceso físico al sitio o al edificio;

e) inspeccionar y examinar las pertenencias personales del personal y de las partes interesadas en el momento de la entrada y salida;

NOTA Pueden existir legislaciones y normativas locales sobre la posibilidad de inspeccionar los objetos personales.

f) requerir a todo el personal y a las partes interesadas que lleven algún tipo de identificación visible y que notifiquen inmediatamente al personal de seguridad si se encuentran con visitantes no escoltados y alguien que no lleve identificación visible. Debería considerarse insignias fácilmente distinguibles para identificar mejor a los empleados, proveedores y visitantes permanentes;

g) conceder al personal del proveedor acceso restringido a áreas seguras o instalaciones de procesamiento de información solo cuando sea necesario. Este acceso debería autorizarse y supervisarse;

h) prestar especial atención a la seguridad del acceso físico en el caso de los edificios que tienen activos para múltiples organizaciones;

i) diseñar medidas de seguridad física para que puedan reforzarse cuando aumente la probabilidad de incidentes físicos;

j) asegurar otros puntos de entrada, como salidas de emergencia, frente a accesos no autorizados;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

k) configurar un proceso de gestión de claves para Asegurar la gestión de las claves físicas o la información de autenticación (por ejemplo, , códigos de bloqueo, bloqueos combinados a oficinas, salas e instalaciones como armarios de llaves) y Asegurar un libro de registro o una auditoría de claves anual y el acceso a la información física las claves o la información de autenticación se controlan (véase el numeral 5,17 para obtener más información sobre la autenticación).

Visitantes

Se deberían tomar en consideración las siguientes directrices:

a) la autenticación de la identidad de los visitantes por un medio apropiado;

b) registrar la fecha y hora de entrada y salida de los visitantes;

c) conceder acceso únicamente a los visitantes con fines específicos y autorizados y con instrucciones sobre los requisitos de seguridad de la zona y sobre los procedimientos de emergencia;

d) supervisar a todos los visitantes, a menos que se conceda una excepción explícita. Áreas de entrega y carga y material entrante

Se deberían tomar en consideración las siguientes directrices:

a) restringir el acceso a las zonas de entrega y carga desde fuera del edificio al personal identificado y autorizado;

b) diseñar las áreas de entrega y carga para que las entregas puedan cargarse y descargarse sin que el personal de entrega tenga acceso no autorizado a otras partes del edificio;

c) asegurar las puertas externas de las zonas de entrega y carga cuando se abren las puertas a zonas restringidas;

d) inspeccionar y examinar las entregas entrantes en busca de explosivos, productos químicos u otros materiales peligrosos antes de trasladarlas de las zonas de entrega y carga;

e) registrar las entregas entrantes de acuerdo con los procedimientos de gestión de activos (véanse 5,9 y 7,10) en el momento de la entrada en el emplazamiento;

f) separar físicamente los envíos entrantes y salientes, siempre que sea posible;

g) inspección de las entregas entrantes para comprobar si hay indicios de manipulación en el camino. Si se descubre la manipulación, se debería informar inmediatamente al personal de seguridad.

Otra información

No hay más información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

7.3 Protección de oficinas, salas e instalaciones

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad física #Gestión de activos	#Protección

Control

Se debería diseñar e implementar la seguridad física de las oficinas, salas e instalaciones.

Objetivo

Impedir el acceso físico no autorizado, los daños y las interferencias en la información de la organización y otros activos asociados en oficinas, salas e instalaciones.

Guía

Se deberían considerar las siguientes directrices para asegurar oficinas, salas e instalaciones:

a) la ubicación de instalaciones críticas para evitar el acceso del público;

b) cuando sea aplicable, Asegurar que los edificios sean discretos y dar una indicación mínima de su propósito, sin señales obvias, fuera o dentro del edificio, identificando la presencia de actividades de procesamiento de información;

c) configurar las funciones para evitar que la información confidencial o las actividades sean visibles y audibles desde el exterior. El blindaje electromagnético también debería considerarse apropiado;

d) no hacer directorios, guías telefónicas internas y mapas accesibles en línea que identifiquen ubicaciones de instalaciones de procesamiento de información confidencial fácilmente disponibles para cualquier persona no autorizada.

Otra información

No hay más información.

7.4 Monitoreo de la seguridad física

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención #Detección	#Confidencialidad #Integridad #Disponibilidad	#Protección #Detección	#Seguridad_física	#Protección #Defensa

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Control

Las instalaciones deberían ser vigiladas continuamente para el acceso físico no autorizado.

Objetivo

Detectar y disuadir el acceso físico no autorizado.

Guía

Las instalaciones físicas deberían ser supervisadas por sistemas de vigilancia, que pueden incluir guardias, alarmas de intrusos, sistemas de monitoreo de video como la televisión de circuito cerrado y software de gestión de información de seguridad física administrado internamente o por un proveedor de servicios de monitoreo.

El acceso a los edificios que albergan sistemas críticos debería supervisarse continuamente para detectar accesos no autorizados o comportamientos sospechosos mediante:

a) instalar sistemas de supervisión de video, como la televisión de circuito cerrado, para ver y grabar el acceso a áreas sensibles dentro y fuera de las instalaciones de una organización;

b) instalar, de acuerdo con las normas aplicables pertinentes y probar periódicamente detectores de contacto, sonido o movimiento para activar una alarma de intrusión como:

   1) instalación de detectores de contacto que activan una alarma cuando se hace o rompe un contacto en cualquier lugar donde se pueda hacer o romper un contacto (como ventanas y puertas y debajo de objetos) para su uso como alarma de emergencia;

   2) detectores de movimiento basados en tecnología de infrarrojos que activan una alarma cuando un objeto pasa por su campo de visión;

   3) instalación de sensores sensibles al sonido de rotura de cristal que se pueden utilizar para activar una alarma para alertar al personal de seguridad;

c) utilizar estas alarmas para cubrir todas las puertas externas y ventanas accesibles. Las zonas desocupadas deberían estar con alarmas activadas en todo momento; también debería cubrirse otras zonas (por ejemplo, salas de computadores o de comunicaciones).

El diseño de los sistemas de vigilancia debería mantenerse confidencial ya que la divulgación puede facilitar las roturas no detectadas.

Los sistemas de supervisión deberían protegerse del acceso no autorizado para evitar que personas no autorizadas o sistemas que se deshabiliten de forma remota accedan a la información de vigilancia, como las fuentes de video.

El panel de control del sistema de alarma debería colocarse en una zona de alarma y, para alarmas de seguridad, en un lugar que permita una ruta de salida fácil para la persona que establece la alarma. El panel de control y los detectores deberían tener mecanismos a prueba de manipulaciones. El sistema se debería probar regularmente para asegurarse de que funciona correctamente, especialmente si sus componentes funcionan con batería.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Cualquier mecanismo de supervisión y grabación debería utilizarse tomando en consideración las leyes y normativas locales, incluida la protección de datos y la legislación de protección de IIP, especialmente en lo que respecta a la supervisión del personal y los períodos de retención de video grabado.

Otra información

No hay más información.

7.5 Protección contra las amenazas físicas y medioambientales

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física	#Protección

Control

Debería diseñarse y aplicarse la protección contra las amenazas físicas y ambientales, como los desastres naturales y otras amenazas físicas intencionales o no intencionales a la infraestructura.

Objetivo

Prevenir o reducir las consecuencias de los eventos originados por amenazas físicas y ambientales.

Guía

Las evaluaciones de riesgos para identificar las consecuencias potenciales de las amenazas físicas y ambientales deberían realizarse antes de iniciar operaciones críticas en un sitio físico y a intervalos regulares. Se deberían aplicar las salvaguardias necesarias y se deberían supervisar los cambios en las amenazas. Se debería obtener asesoramiento especializado sobre cómo gestionar los riesgos derivados de amenazas físicas y ambientales como incendios, inundaciones, terremotos, explosiones, disturbios civiles, desechos tóxicos, emisiones ambientales y otras formas de desastres naturales o desastres causados por seres humanos.

La ubicación y la construcción de las instalaciones físicas deberían tener en cuenta:

a) La topografía local, como elevación apropiada, cuerpos de agua y líneas de falla tectónica;

b) Las amenazas urbanas, como lugares con un alto perfil para atraer disturbios políticos, actividades delictivas o ataques terroristas.

Sobre la base de los resultados de la evaluación de riesgos, deberían identificarse las amenazas físicas y ambientales pertinentes y considerarse los controles apropiados en los siguientes contextos como ejemplos:

a) fuego: instalación y configuración de sistemas capaces de detectar incendios en una fase temprana para enviar alarmas o activar sistemas de extinción de incendios con el fin de evitar daños por incendio en los medios de almacenamiento y en los sistemas de procesamiento

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

de información relacionados. La extinción de incendios debería realizarse al utilizar la sustancia más apropiada con respecto al entorno circundante (por ejemplo, gas en espacios confinados);

b) inundaciones: instalación de sistemas capaces de detectar inundaciones en una etapa temprana bajo los pisos de áreas que contienen medios de almacenamiento o sistemas de procesamiento de información. Las bombas de agua o los medios equivalentes deberían estar disponibles fácilmente en caso de que ocurra una inundación;

c) sobretensiones eléctricas: adoptar sistemas capaces de proteger tanto los sistemas de información de servidor como de cliente contra sobretensiones eléctricas o eventos similares para minimizar las consecuencias de tales eventos;

d) explosivos y armas: realización de inspecciones aleatorias por la presencia de explosivos o armas en personal, vehículos o mercancías que entran en instalaciones de procesamiento de información sensible.

Otra información

Las cajas fuertes u otras formas de instalaciones seguras de almacenamiento pueden proteger la información almacenada en ellas contra desastres tales como incendios, terremotos, inundaciones o explosiones.

Las organizaciones pueden considerar los conceptos de prevención del delito a través del diseño ambiental al diseñar los controles para asegurar su medio ambiente y reducir las amenazas urbanas. Por ejemplo, en lugar de utilizar balizas, las estatuas o los elementos de agua pueden servir tanto de característica como de barrera física.

7.6 Trabajo en zonas seguras

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física	#Protección

Control

Deberían diseñarse y aplicarse medidas de seguridad para trabajar en zonas seguras.

Objetivo

Proteger la información y otros activos asociados en áreas seguras contra daños e interferencias no autorizadas por parte del personal que trabaja en estas áreas.

Guía

Las medidas de seguridad para trabajar en zonas seguras deberían aplicarse a todo el personal y abarcar todas las actividades que se realicen en la zona segura.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Se deberían tomar en consideración las siguientes directrices:

a) hacer que el personal sea consciente solo de la existencia o actividades dentro de un área segura, según la necesidad de saber;

b) evitar el trabajo no supervisado en áreas seguras tanto por razones de seguridad como para reducir las posibilidades de actividades malintencionadas;

c) bloqueo físico e inspección periódica de las áreas seguras vacías;

d) no permitir el uso de equipos de grabación, de video, audio o de fotografía, como cámaras en dispositivos finales de usuario, a menos que estén autorizados;

e) controlar adecuadamente el transporte y el uso de los dispositivos de punto final del usuario en zonas seguras; f) publicar procedimientos de emergencia de forma fácilmente visible o accesible.

Otra información

No hay más información.

7.7 Escritorio limpio y pantalla limpia

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad	#Proteger	#Seguridad_física	#Protección

Control

Se deberían definir y aplicar de forma adecuada reglas de escritorio claras para papeles y medios de almacenamiento extraíbles, así como reglas de pantalla clara para las instalaciones de procesamiento de información.

Objetivo

Reducir los riesgos de acceso no autorizado, pérdida y daños a la información en escritorios, pantallas y otros lugares accesibles durante y fuera del horario de trabajo normal.

Guía

La organización debería establecer y comunicar a todas las partes interesadas una política específica sobre el tema de la mesa de trabajo y la pantalla clara.

Se deberían tomar en consideración las siguientes directrices:

a) bloquear la información del negocio confidencial o crítica (por ejemplo, en papel o en medios de almacenamiento electrónicos) (idealmente en una caja fuerte, armario u otro tipo de mobiliario de seguridad) cuando no sea necesario, especialmente cuando la oficina está desocupada;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) protección de los dispositivos finales de usuario mediante bloqueos de llave u otros medios de seguridad cuando no se utilizan o están desatendidos;

c) dejar los dispositivos de punto final de usuario desconectados o protegidos con un mecanismo de bloqueo de pantalla y teclado controlado por un mecanismo de autenticación de usuario cuando no están atendidos. Todos los equipos y sistemas deberían configurarse con una función de tiempo de espera o cierre de sesión automático;

d) hacer que el originador recopile inmediatamente las salidas de impresoras o dispositivos multifunción. El uso de impresoras con una función de autenticación, por lo que los creadores son los únicos que pueden obtener sus impresiones y solo cuando se encuentran junto a la impresora;

e) almacenar de forma segura documentos y medios de almacenamiento extraíbles que contengan información confidencial y, cuando ya no sea necesario, desecharlos mediante mecanismos de eliminación seguros;

f) establecer y comunicar reglas y directrices para la configuración de ventanas emergentes en las pantallas (por ejemplo, , desactivar las nuevas ventanas emergentes de correo electrónico y mensajería, si es posible, durante las presentaciones, el uso compartido de pantalla o en un área pública);

g) borrado de información sensible o crítica en pizarras blancas y otros tipos de pantalla cuando ya no sea necesario.

La organización debería disponer de procedimientos al desocupar las instalaciones, incluida la realización de un barrido final antes de salir para Asegurar que los activos de la organización no se queden atrás (por ejemplo, documentos caídos detrás de cajones o muebles).

Otra información

No hay más información.

7.8 Ubicación y protección de los equipos

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad física #Gestión de activos	#Protección

Control

El equipo debería estar colocado de forma segura y protegido.

Objetivo

Reducir los riesgos derivados de amenazas físicas y ambientales, así como del acceso y los daños no autorizados.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Guía

Se deberían tomar en consideración las siguientes directrices para proteger el equipo:

a) colocación de equipos para minimizar el acceso innecesario a las zonas de trabajo y evitar el acceso no autorizado;

b) colocar cuidadosamente las instalaciones de procesamiento de información que manipulan datos sensibles para reducir el riesgo de que personas no autorizadas vean la información durante su uso;

c) adoptar controles para minimizar el riesgo de posibles amenazas físicas y ambientales [por ejemplo, robo, incendio, explosivos, humo, agua (o falla del suministro de agua), polvo, vibraciones, efectos químicos, interferencias en el suministro eléctrico, interferencias de comunicaciones, radiación electromagnética y vandalismo];

d) establecer directrices para comer, beber y fumar en proximidad a las instalaciones de procesamiento de información;

e) controlar las condiciones ambientales, como la temperatura y la humedad, para condiciones que puedan afectar negativamente al funcionamiento de las instalaciones de procesamiento de información;

f) aplicar protección contra rayos a todos los edificios e instalar filtros de protección contra rayos en todas las líneas de alimentación y comunicaciones entrantes;

g) considerando el uso de métodos de protección especiales, como membranas de teclado, para equipos en entornos industriales;

h) protección del equipo que procesa información confidencial para minimizar el riesgo de fuga de información debido a emanaciones electromagnéticas;

i) separar físicamente las instalaciones de procesamiento de información gestionadas por la organización de las no gestionadas por la organización.

Otra información

No hay más información.

7.9 Seguridad de los activos fuera de las instalaciones

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad física #Gestión de activos	#Protección

Control

Los activos fuera de las instalaciones debería estar protegidos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Para evitar pérdidas, daños, robos o riesgos de dispositivos externos e interrupciones en las operaciones de la empresa.

Guía

Cualquier dispositivo utilizado fuera de las instalaciones de la empresa que almacene o procese información (por ejemplo, dispositivos móviles), incluidos los dispositivos propiedad de la empresa y los dispositivos de propiedad privada y utilizados en nombre de la empresa [traiga su propio dispositivo (BYOD)] necesita protección. La administración debería autorizar el uso de estos dispositivos.

Se deberían tener en cuenta las siguientes directrices para la protección de los dispositivos que almacenan o procesan información fuera de las instalaciones de la organización:

a) no dejar el equipo y los medios de almacenamiento sin supervisión en lugares públicos y no protegidos;

b) observar las instrucciones del fabricante para proteger los equipos en todo momento (por ejemplo, protección contra la exposición a campos electromagnéticos fuertes, agua, calor, humedad, polvo);

c) cuando el equipo fuera de las instalaciones se transfiere entre diferentes personas o partes interesadas, manteniendo un registro que defina la cadena de custodia del equipo, incluidos al menos los nombres y organizaciones de los responsables del equipo. La información que no necesita transferirse con el activo debería eliminarse de forma segura antes de la transferencia;

d) cuando sea necesario y práctico, que requiera autorización para retirar el equipo y los medios de comunicación de las instalaciones de la organización y que se mantenga un registro de dichas retiradas a fin de mantener un registro de auditoría (véase el numeral 5,14);

e) protección contra la visualización de información en un dispositivo (por ejemplo, móvil o portátil) en transporte público y los riesgos asociados con el fisgoneo por encima del hombro

f) implementación del seguimiento de ubicación y capacidad para el borrado remoto de dispositivos.

La instalación permanente de equipos fuera de las instalaciones de la organización [como antenas y cajeros automáticos (ATM)] puede estar sujeta a un mayor riesgo de daños, robo o espionaje. Estos riesgos pueden variar considerablemente de un lugar a otro y deberían tenerse en cuenta al determinar las medidas más adecuadas. Al situar este equipo fuera de las instalaciones de la organización, deberían tenerse en cuenta las siguientes directrices:

a) supervisión de la seguridad física (véase el numeral 7,4);

b) protección contra las amenazas físicas y medioambientales (véase el numeral 7.5);

c) controles de acceso físico y de prueba de manipulación;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

d) control de acceso lógico.

Otra información

Puede encontrar más información sobre otros aspectos de la protección de equipos de almacenamiento y procesamiento de información y dispositivos finales de usuario en los numerales 8.1 y 6.7.

7.10 Medios de almacenamiento

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad física #Gestión de activos	#Protección

Control

Los medios de almacenamiento deberían gestionarse a través de su ciclo de vida de adquisición, uso, transporte y eliminación de acuerdo con el esquema de clasificación y los requisitos de manipulación de la organización.

Objetivo

Asegurar únicamente la divulgación, modificación, eliminación o destrucción autorizada de la información en los medios de almacenamiento.

Guía

Medios de almacenamiento extraíbles.

Se deberían tener en cuenta las siguientes directrices para la gestión de medios de almacenamiento extraíbles:

a) establecer una política específica de un tema sobre la administración de medios de almacenamiento extraíbles y comunicar dicha política específica de un tema a cualquier persona que utilice o gestione medios de almacenamiento extraíbles;

b) cuando resulte necesario y práctico, exigir la autorización para la retirada de los soportes de almacenamiento de la organización y mantener un registro de dichas retiradas con el fin de conservar un registro de auditoría;

c) almacenar todos los medios de almacenamiento en un entorno seguro y seguro según su clasificación de información y protegerlos contra amenazas ambientales (como calor, humedad, humedad, campo electrónico o envejecimiento), de conformidad con las especificaciones de los fabricantes;

d) si la confidencialidad o integridad de la información son consideraciones importantes, utilizar técnicas cifradas para proteger la información en medios de almacenamiento extraíbles;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

e) para mitigar el riesgo de degradación de los medios de almacenamiento mientras aún se necesita información almacenada, transfiera la información a medios de almacenamiento nuevos antes de que sea ilegible;

f) almacenar varias copias de información valiosa en medios de almacenamiento independientes para reducir aún más el riesgo de daños o pérdidas de información fortuita;

g) considerar el registro de medios de almacenamiento extraíbles para limitar la posibilidad de pérdida de información;

h) solo habilitar puertos de medios de almacenamiento extraíbles [por ejemplo, ranuras para tarjetas Secure Digital (SD) y puertos USB (bus universal en serie)] si existe un motivo de organización para su uso;

i) cuando sea necesario utilizar medios de almacenamiento extraíbles, supervisando la transferencia de información a dichos medios de almacenamiento;

j) la información puede ser vulnerable al acceso no autorizado, al uso indebido o a la corrupción durante el transporte físico, por ejemplo, al enviar medios de almacenamiento a través del servicio postal o a través del servicio de mensajería.

En este control, el material incluye documentos impresos. Al transferir medios de almacenamiento físicos, aplique medidas de seguridad en el numeral 5.14.

Reutilización o disposición segura

Deberían establecerse procedimientos para la reutilización o eliminación segura de los medios de almacenamiento a fin de reducir al mínimo el riesgo de fuga de información confidencial a personas no autorizadas. Los procedimientos para la reutilización o eliminación segura de los medios de almacenamiento que contienen información confidencial debería ser proporcionales a la sensibilidad de dicha información. Se deberían tomar en consideración los siguientes factores:

a) si es necesario reutilizar los medios de almacenamiento que contienen información confidencial dentro de la organización, elimine los datos de forma segura o formatee los medios de almacenamiento antes de volver a utilizarlos (véase el numeral 8.10);

b) desechar los medios de almacenamiento que contienen información confidencial de forma segura cuando ya no sea necesario (por ejemplo, destruir, triturar o eliminar el contenido de forma segura);

c) disponer de procedimientos para identificar los elementos que pueden requerir una eliminación segura;

d) muchas organizaciones ofrecen servicios de recogida y eliminación de medios de almacenamiento. Se debería tener cuidado al seleccionar un proveedor externo adecuado con controles y experiencia adecuados;

e) registrar la eliminación de elementos sensibles para mantener un registro de auditoría;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

f) al acumular medios de almacenamiento para su eliminación, tomando en consideración el efecto de agregación, que puede hacer que una gran cantidad de información no confidencial se vuelva sensible.

Se debería realizar una evaluación de riesgos en los dispositivos dañados que contengan datos sensibles para determinar si los elementos deberían destruirse físicamente en lugar de enviarse para su reparación o descartarse (véase el numeral 7.14).

Otra información

Cuando la información confidencial de los medios de almacenamiento no está cifrada, debería considerarse la protección física adicional de los medios de almacenamiento.

7.11 Servicios públicos de respaldo

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención #Detección	#Integridad #Disponibilidad	#Protección #Detección	#Seguridad_física	#Protección

Control

Las instalaciones de procesamiento de la información deberían estar protegidas contra los cortes de energía y otras interrupciones causadas por fallas en los servicios públicos de respaldo.

Objetivo

Evitar la pérdida, daño o compromiso de información y otros activos asociados o la interrupción de las operaciones de la organización debido al fracaso y la interrupción de los servicios públicos de respaldo.

Guía

Las organizaciones dependen de los servicios públicos (por ejemplo, electricidad, telecomunicaciones, suministro de agua, gas, aguas residuales, ventilación y aire acondicionado) para apoyar sus instalaciones de procesamiento de información. Por lo tanto, la organización debería:

a) asegurarse de que el equipo que soporta las utilidades está configurado operado y mantenido de acuerdo con las especificaciones del fabricante correspondiente;

b) Asegurar que los servicios públicos sean evaluados periódicamente en cuanto a su capacidad para satisfacer el crecimiento de la empresa y las interacciones con otros servicios de respaldo;

c) Asegurar que los equipos de soporte de los servicios públicos se inspeccionen y prueben regularmente para Asegurar su correcto funcionamiento;

d) si es necesario, levantar alarmas para detectar fallas de funcionamiento de los servicios públicos;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

e) si es necesario, asegurarse de que los servicios públicos tienen varias fuentes con enrutamiento físico diverso;

f) Asegurar que los equipos que soportan los servicios públicos estén en una red separada de las instalaciones de procesamiento de la información, si están conectadas a una red;

g) Asegurar que los equipos que soportan los servicios públicos se conecten a Internet solo cuando sea necesario y de forma segura.

Se debería proporcionar iluminación de emergencia y comunicaciones. Los interruptores y válvulas de emergencia para cortar la alimentación, el agua, el gas u otros servicios públicos deberían estar ubicados cerca de las salidas de emergencia o de las salas de equipos. Los datos de contacto de emergencia deberían registrarse y ponerse a disposición del personal en caso de interrupción del servicio.

Otra información

Se puede obtener redundancia adicional para la conectividad de red mediante varias rutas de más de un proveedor de servicios públicos.

7.12 Seguridad del cableado

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Disponibilidad	#Proteger	#Seguridad_física	#Protección

Control

Los cables que transportan energía, datos o servicios de información de respaldo deberían estar protegidos contra la interceptación, las interferencias o los daños.

Objetivo

Evitar la pérdida, daño o compromiso de información y otros activos asociados o la interrupción de las operaciones de la organización debido al cableado de alimentación y comunicaciones.

Guía

Se deberían tener en cuenta las siguientes directrices para la seguridad del cableado:

a) líneas de energía y telecomunicaciones en instalaciones de procesamiento de información bajo tierra siempre que sea posible o sometidas a una protección alternativa adecuada, como el protector de cables de suelo y el polo de servicio; si los cables están bajo tierra, deberían estar protegidos de cortes accidentales (por ejemplo, con conductos blindados o señales de presencia);

b) separar los cables de alimentación de los cables de comunicaciones para evitar interferencias;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) para sistemas sensibles o críticos otros controles a considerar incluyen:

1) instalación de conductos blindados y salas o cajas bloqueadas y alarmas en los puntos de inspección y terminación;

2) uso de blindaje electromagnético para proteger los cables;

3) barridos técnicos periódicos e inspecciones físicas para detectar dispositivos no autorizados que se conectan a los cables;

4) Acceso controlado a paneles de conexiones y salas de cables (por ejemplo, con llaves mecánicas o PINES);

5) uso de cables de fibra óptica;

d) etiquetar los cables en cada extremo con suficientes detalles de origen y destino para permitir la identificación física y la inspección del cable.

Se debería solicitar asesoramiento especializado sobre cómo gestionar los riesgos derivados de incidentes o fallas de funcionamiento del cableado.

Otra información

A veces, el cableado de energía y telecomunicaciones es un recurso compartido para más de una organización que ocupa instalaciones ubicadas en una misma ubicación.

7.13 Mantenimiento del equipo

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad física #Gestión de activos	#Protección #Resiliencia

Control

El equipo debería mantenerse correctamente para Asegurar la disponibilidad, integridad y confidencialidad de la información.

Objetivo

Evitar la pérdida, daño o compromiso de información y otros activos asociados o la interrupción de las operaciones de la organización debido al cableado de alimentación y comunicaciones.

Guía

Se deberían tener en cuenta las siguientes directrices para el mantenimiento del equipo:

a) mantener el equipo de acuerdo con la frecuencia de servicio y las especificaciones recomendadas por el proveedor;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) ejecución y seguimiento de un programa de mantenimiento por parte de la organización;

c) solo el personal de mantenimiento autorizado puede realizar las reparaciones y el mantenimiento de los equipos;

d) mantener registros de todas las averías sospechosas o reales, así como de todo mantenimiento preventivo y correctivo;

e) implementar controles adecuados cuando el equipo esté programado para el mantenimiento, tomando en consideración si este mantenimiento lo realiza el personal del emplazamiento o externo a la organización; someter al personal de mantenimiento a un acuerdo de confidencialidad adecuado;

f) supervisar al personal de mantenimiento durante el mantenimiento en el sitio;

g) autorizar y controlar el acceso para el mantenimiento remoto;

h) la aplicación de medidas de seguridad para los activos fuera de las instalaciones (véase el numeral 7.9) si el equipo que contiene información se desocupa de las instalaciones para su mantenimiento;

i) el cumplimiento de todos los requisitos de mantenimiento impuestos por el seguro;

j) antes de volver a poner el equipo en funcionamiento después del mantenimiento, se debería inspeccionar para asegurarse de que el equipo no se ha manipulado y funciona correctamente;

k) aplicar medidas para la eliminación o reutilización seguras del equipo (véase el numeral 7.14) si se determina que el equipo se va a desechar.

Otra información

El equipo incluye componentes técnicos de instalaciones de procesamiento de información, sistemas de alimentación ininterrumpida (UPS) y baterías, generadores de energía, alternadores y convertidores de potencia, sistemas y alarmas de detección de intrusiones físicas, detectores de humo, extintores de incendios, aire acondicionado y ascensores.

7.14 Eliminación segura o reutilización del equipo

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad	#Proteger	#Seguridad física #Gestión de activos	#Protección

Control

Los elementos del equipo que contienen medios de almacenamiento deberían verificarse para Asegurar que los datos confidenciales y el software con licencia se han eliminado o sobrescrito de forma segura antes de desecharlos o volver a utilizarlos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Evitar fugas de información del equipo que se va a desechar o reutilizar.

Guía

El equipo se debería verificar para asegurarse de que los medios de almacenamiento están contenidos o no antes de su eliminación o reutilización.

Los medios de almacenamiento que contienen información confidencial o protegida por derechos de autor deberían destruirse físicamente o la información debería destruirse, eliminarse o sobrescribirse al utilizar técnicas para que la información original no pueda recuperarse en lugar de utilizar la función de eliminación convencional. Véase el numeral 7.10 para obtener guía detallada sobre la eliminación segura de los medios de almacenamiento y el 8.10 para obtener guía sobre la eliminación de información.

Las etiquetas y las marcas que identifiquen a la organización o indiquen la clasificación, propietario, sistema o red, deberían eliminarse antes de su disposición final, esto incluye la reventa o donación a una organización benéfica.

La organización debería considerar la eliminación de los controles de seguridad, como los controles de acceso o los equipos de vigilancia, al final del contrato de arrendamiento o cuando se traslade de las instalaciones. Esto depende de factores como:

a) su contrato de arrendamiento para devolver la instalación a su condición original;

b) minimizar el riesgo de dejar sistemas con información confidencial para el siguiente arrendatario (por ejemplo, listas de acceso de usuarios, archivos de video o de imágenes);

c) la capacidad de reutilizar los controles en la siguiente instalación.

Otra información

Los equipos dañados que contienen medios de almacenamiento pueden requerir una evaluación de riesgos para determinar si los elementos deberían destruirse físicamente en lugar de enviarse para su reparación o descartarse. La información puede verse comprometida por la eliminación descuidada o la reutilización del equipo.

Además de la eliminación segura del disco, el cifrado de disco completo reduce el riesgo de revelación de información confidencial cuando se desecha o se vuelve a implementar el equipo, siempre que:

a) el proceso de cifrado sea suficientemente sólido y cubra todo el disco (incluido el espacio libre, los archivos de intercambio);

b) las claves cifradas sean lo suficientemente largas como para resistir los ataques de fuerza bruta;

c) las claves cifradas se mantienen en sí mismas como confidenciales (por ejemplo, nunca se almacenan en el mismo disco). Para más consejos sobre cifrado, véase el numeral 8.24.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Las técnicas para sobrescribir de forma segura los medios de almacenamiento difieren según la tecnología de los medios de almacenamiento y el nivel de clasificación de la información contenida en los medios de almacenamiento. Las herramientas de sobreescritura deberían revisarse para asegurarse de que sean aplicables a la tecnología de los medios de almacenamiento.

Véase el numeral la norma ISO/IEC 27040 para obtener información detallada sobre los métodos de desinfección de los medios de almacenamiento.

8. CONTROLES TECNOLÓGICOS

8.1 Dispositivos finales del usuario

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de activos Protección de la información	#Protección

Control

La información almacenada, procesada o accesible a través de los dispositivos de punto final del usuario debería estar protegida.

Objetivo

Proteger la información contra los riesgos introducidos mediante el uso de dispositivos finales de usuario.

Guía

General

La organización debería establecer una política específica de un tema sobre la configuración y el manejo seguros de los dispositivos finales de usuario. La política específica del tema debería comunicarse a todo el personal pertinente y considerar lo siguiente:

a) el tipo de información y el nivel de clasificación que los dispositivos de punto final del usuario pueden gestionar, procesar, almacenar o admitir;

b) registro de dispositivos finales del usuario;

c) requisitos de protección física;

d) restricción de la instalación de software (por ejemplo, controlado de forma remota por los administradores del sistema);

e) requisitos para el software del dispositivo de punto final del usuario (incluidas las versiones de software) y para aplicar actualizaciones (por ejemplo, , actualización automática activa);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

f) normas para la conexión a servicios de información, redes públicas o cualquier otra red fuera de las instalaciones (por ejemplo, que requiera el uso de cortafuegos personal);

g) controles de acceso;

i) cifrado de dispositivos de almacenamiento;

j) protección contra malware;

k) desactivación, eliminación o bloqueo remotos;

l) copias de seguridad;

m) uso de servicios web y aplicaciones web;

n) análisis del comportamiento del usuario final (véase el numeral 8.16);

o) el uso de dispositivos extraíbles, incluidos dispositivos de memoria extraíbles y la posibilidad de desactivar puertos físicos (por ejemplo, Puertos USB);

p) el uso de capacidades de partición, si es compatible con el dispositivo final del usuario, que puede separar de forma segura la información de la empresa y otros activos asociados (por ejemplo, software) de otra información y otros activos asociados del dispositivo.

Se debería considerar si cierta información es tan sensible que solo se puede acceder a ella a través de dispositivos de punto final de usuario, pero no se puede almacenar en dichos dispositivos. En tales casos, se pueden requerir protecciones técnicas adicionales en el dispositivo. Por ejemplo, asegurarse de que la descarga de archivos para trabajar sin conexión está desactivada y de que el almacenamiento local, como la tarjeta SD, está desactivado.

En la medida de lo posible, las recomendaciones sobre este control se deberían aplicar mediante la administración de la configuración (véase el numeral 8.9) o mediante herramientas automatizadas.

Responsabilidades del usuario

Todos los usuarios deberían ser conscientes de los requisitos y procedimientos de seguridad para proteger los dispositivos finales de los usuarios, así como de sus responsabilidades para implementar dichas medidas de seguridad. Se debería aconsejar a los usuarios lo siguiente:

a) cerrar la sesión activa y terminar servicios cuando ya no sean necesarios;

b) proteger los dispositivos de punto final del usuario de un uso no autorizado con un control físico (por ejemplo, bloqueo con llave o bloqueos especiales) y un control lógico (por ejemplo, acceso con contraseña) cuando no se estén al utilizar; no dejar desatendidos los dispositivos que lleven información del negocio importante, sensible o crítica;

c) utilizar dispositivos con especial cuidado en lugares públicos oficinas abiertas, lugares de reunión y otras áreas no protegidas (por ejemplo, evitar la lectura de información confidencial si las personas pueden leer desde la parte posterior, utilizar filtros de pantalla de privacidad);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

d) proteger físicamente los dispositivos finales de usuario contra robos (por ejemplo, en automóviles y otras formas de transporte, habitaciones de hotel, centros de conferencias y lugares de reunión).

Para los casos de robo o pérdida de dispositivos final de usuario se debería establecer un procedimiento específico que tenga en cuenta los requisitos legales, legales, reglamentarios, contractuales (incluidos los seguros) y otros requisitos de seguridad de la organización.

Uso de dispositivos personales

Cuando la empresa permite el uso de dispositivos personales (a veces conocidos como BYOD), además de las directrices proporcionadas en este control, se debería tener en cuenta lo siguiente:

a) separación del uso personal y del negocio de los dispositivos, incluido el uso de software para admitir dicha separación y proteger los datos del negocioes en un dispositivo privado;

b) proporcionar acceso a la información del negocio solo después de que los usuarios hayan reconocido sus obligaciones (protección física, actualización de software, etc.), renunciar a la propiedad de los datos del negocioes, permitir el borrado remoto de los datos por parte de la organización en caso de robo o pérdida del dispositivo o cuando ya no esté autorizado a utilizar el servicio. En tales casos, debería considerarse la legislación de protección de la IIP;

c) políticas y procedimientos específicos para prevenir controversias relativas a los derechos de propiedad intelectual sobre equipos de propiedad privada;

d) el acceso a equipos de propiedad privada (para verificar la seguridad de la máquina o durante una investigación), que puede ser impedido por la legislación;

e) acuerdos de licencia de software que son tales que las organizaciones pueden hacerse responsables de la licencia del software cliente en dispositivos finales de usuario propiedad privada del personal o de usuarios externos.

Conexiones inalámbricas

La organización debería establecer procedimientos para:

a) la configuración de las conexiones inalámbricas en los dispositivos (por ejemplo, desactivar protocolos vulnerables);

b) utilizar conexiones inalámbricas o con cable con el ancho de banda adecuado de acuerdo con las políticas específicas por tema (por ejemplo, porque se necesitan copias de seguridad o actualizaciones de software).

Otra información

Los controles para proteger la información de los dispositivos finales de usuario dependen de si el dispositivo final de usuario se utiliza solo dentro de las instalaciones seguras y las conexiones de red de la empresa o si está expuesto a mayores amenazas físicas y relacionadas con la red fuera de la organización.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Las conexiones inalámbricas para los dispositivos de punto final de usuario son similares a otros tipos de conexiones de red, pero tienen diferencias importantes que deberían tenerse en cuenta al identificar los controles. En particular, la copia de seguridad de la información almacenada en los dispositivos finales de usuario puede fallar a veces debido a un ancho de banda de red limitado o porque los dispositivos finales de usuario no están conectados en el momento en que se programan las copias de seguridad.

Para algunos puertos USB, como USB-C, no es posible desactivar el puerto USB porque se utiliza para otros fines (por ejemplo, suministro de energía y salida de pantalla).

8.2 Derechos de acceso privilegiados

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Responsabilidades operacionales	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de la identidad y del acceso	#Protección

Control

La asignación y el uso de los derechos de acceso privilegiado deberían ser restringidos y gestionados.

Objetivo

Asegurar que solo los usuarios autorizados, los componentes de software y los servicios se proporcionan con derechos de acceso con privilegios.

Guía

La asignación de derechos de acceso privilegiado debería controlarse mediante un proceso de autorización de acuerdo con la política de control de acceso específica para cada tema (véase el numeral 5.15). Se debería considerar lo siguiente:

a) identificar a los usuarios que necesitan derechos de acceso con privilegios para cada sistema o proceso (por ejemplo, sistemas operativos, sistemas de gestión de bases de datos y aplicaciones);

b) asignación de derechos de acceso con privilegios a los usuarios según sea necesario y evento por evento, de acuerdo con la política de control de acceso específica de cada tema (véase el numeral 5.15) (es decir, solo a personas con la competencia necesaria para realizar actividades que requieran acceso con privilegios y basadas en el requisito mínimo de sus funciones funcionales);

c) mantener un proceso de autorización (es decir, determinar quién puede aprobar los derechos de acceso con privilegios o no conceder derechos de acceso con privilegios hasta que se complete el proceso de autorización) y un registro de todos los privilegios asignados;

d) definir e implementar los requisitos para la expiración de los derechos de acceso privilegiado;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

e) tomar medidas para Asegurar que los usuarios conozcan sus derechos de acceso privilegiado y cuando se encuentren en modo de acceso privilegiado. Entre las posibles medidas se incluyen el uso de identidades de usuario específicas, la configuración de la interfaz de usuario o incluso un equipo específico;

f) los requisitos de autenticación para los derechos de acceso con privilegios pueden ser superiores a los requisitos para los derechos de acceso normales. Es posible que sea necesario volver a realizar la autenticación o la autenticación antes de trabajar con derechos de acceso con privilegios;

g) regularmente y después de cualquier cambio en la organización, revisar a los usuarios que trabajan con derechos de acceso con privilegios para verificar si sus deberes, funciones, responsabilidades y competencias aún los califican para trabajar con derechos de acceso con privilegios (véase el numeral 5.18);

h) Establecer reglas específicas para evitar el uso de ID de usuario de administración genéricos (como “root”), dependiendo de las capacidades de configuración de los sistemas. Administrar y proteger la información de autenticación de dichas identidades (véase el numeral 5.17);

i) conceder acceso temporal con privilegios solo durante el período de tiempo necesario para implementar cambios o actividades aprobados (por ejemplo, para actividades de mantenimiento o algunos cambios críticos), en lugar de conceder derechos de acceso con privilegios de forma permanente. A menudo, esto se denomina procedimiento de ventanilla y a menudo está automatizado mediante tecnologías de gestión de acceso de privilegios;

j) registrar todo acceso privilegiado a los sistemas con fines de auditoría;

k) no compartir o vincular identidades con derechos de acceso con privilegios a varias personas, asignando a cada persona una identidad independiente que permita asignar derechos de acceso con privilegios específicos. Las identidades se pueden agrupar (por ejemplo, mediante la definición de un grupo de administradores) para simplificar la gestión de los derechos de acceso con privilegios;

l) solo utilizar identidades con derechos de acceso con privilegios para realizar tareas administrativas y no para tareas generales diarias [es decir, comprobar el correo electrónico, acceder a la web (los usuarios deberían tener una identidad de red normal independiente para estas actividades)].

Otra información

Los derechos de acceso con privilegios son derechos de acceso proporcionados a una identidad, una función o un proceso que permite realizar actividades que los usuarios o procesos típicos no pueden realizar. Las funciones de administrador del sistema normalmente requieren derechos de acceso con privilegios.

El uso inapropiado de los privilegios del administrador del sistema (cualquier característica o facilidad de un sistema de información que permita al usuario anular los controles del sistema o de la aplicación) es un factor importante que contribuye a las fallas o incumplimientos de los sistemas.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Más información relacionada con la gestión del acceso y la gestión segura del acceso a la información y a los recursos de tecnologías de la información y las comunicaciones puede encontrarse en la norma ISO/IEC 29146.

8.3 Restricción del acceso a la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de la identidad y del acceso	#Protección

Control

El acceso a la información y a otros activos asociados deberían restringirse de conformidad con la política establecida sobre el control del acceso relativa a temas específicos.

Objetivo

Asegurar únicamente el acceso autorizado y evitar el acceso no autorizado a la información y otros activos asociados.

Guía

El acceso a la información y a otros activos asociados debería restringirse de conformidad con las políticas establecidas sobre temas específicos. Se debería tener en cuenta lo siguiente para admitir los requisitos de restricción de acceso:

a) no permitir el acceso a información confidencial por identidades de usuario desconocidas o anónimas. El acceso público o anónimo solo debería concederse a ubicaciones de almacenamiento que no contengan información confidencial;

b) proporcionar mecanismos de configuración para controlar el acceso a la información en sistemas, aplicaciones y servicios;

c) controlar a qué datos puede acceder un usuario concreto;

d) controlar qué identidades o grupos de identidades tienen acceso, como lectura, escritura, eliminación y ejecución;

e) proporcionar controles de acceso físicos o lógicos para el aislamiento de aplicaciones, datos de aplicaciones o sistemas confidenciales.

Además, las técnicas y procesos de gestión de acceso dinámico para proteger la información confidencial que tiene un alto valor para la organización deberían considerarse cuando la organización:

a) necesita un control granular sobre quién puede acceder a dicha información durante qué período y de qué manera;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) desea compartir dicha información con personas ajenas a la organización y mantener el control sobre quién puede acceder a ella;

c) desea gestionar dinámicamente, en tiempo real, el uso y la distribución de dicha información;

d) desea proteger dicha información contra cambios, copias y distribución no autorizados (incluida la impresión);

e) quiere controlar el uso de la información;

f) desea registrar cualquier cambio en dicha información que tenga lugar en caso de que se requiera una investigación futura.

Las técnicas de gestión dinámica de acceso deberían proteger la información a lo largo de su ciclo de vida (es decir, creación, procesamiento, almacenamiento, transmisión y eliminación), incluidos:

a) establecer reglas sobre la gestión del acceso dinámico basadas en casos de uso específicos considerando:

   1) conceder permisos de acceso basados en la identidad, el dispositivo, la ubicación o la aplicación;

   2) aprovechar el esquema de clasificación para determinar qué información necesita protegerse con técnicas de gestión de acceso dinámico;

b) establecimiento de procesos operacionales, de supervisión y de presentación de informes y de infraestructura técnica de apoyo.

Los sistemas de gestión de acceso dinámico deberían proteger la información mediante:

a) solicitud de autenticación, credenciales adecuadas o un certificado para acceder a la información;

b) restricción del acceso, por ejemplo, a un plazo de tiempo especificado (por ejemplo, después de una fecha determinada o hasta una fecha determinada);

c) uso del cifrado para proteger la información;

d) definición de los permisos de impresión para la información;

e) registro de quién accede a la información y cómo se utiliza; f) aumento de alertas si se detectan intentos de hacer un uso incorrecto de la información.

Otra información

Las técnicas de gestión de acceso dinámico y otras tecnologías de protección dinámica de la información pueden admitir la protección de la información incluso cuando los datos se comparten más allá de la organización de origen, donde no se pueden aplicar los controles de acceso tradicionales. Se puede aplicar a documentos, correos electrónicos u otros archivos que contengan

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

información para limitar quién puede acceder al contenido y de qué manera. Puede ser a nivel granular y ser adaptado a lo largo del ciclo de vida de la información.

Las técnicas de gestión dinámica de acceso no sustituyen a la gestión clásica de acceso [por ejemplo, el uso de listas de control de acceso (ACL)], sino que pueden añadir más factores para la condicionalidad, la evaluación en tiempo real, la reducción de datos justo a tiempo y otras mejoras que pueden ser útiles para la información más sensible. Ofrece una forma de controlar el acceso fuera del entorno de la organización. Las técnicas de gestión de acceso dinámico pueden admitir la respuesta a incidentes ya que los permisos se pueden modificar o revocar en cualquier momento.

En la norma ISO/IEC 29146 se proporciona información adicional sobre un marco para la gestión del acceso.

8.4 Acceso al código fuente

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de identidades y accesos #Seguridad_de_las_aplicaciones #Configuración_segura	#Protección

Control

El acceso de lectura y escritura al código fuente, las herramientas de desarrollo y las bibliotecas de software se deberían administrar adecuadamente.

Objetivo

Para evitar la introducción de funciones no autorizadas, evite cambios no intencionados o malintencionados y mantenga la confidencialidad de la propiedad intelectual valiosa.

Guía

El acceso al código fuente y a los elementos asociados (como diseños, especificaciones, planes de verificación y planes de validación) y a las herramientas de desarrollo (por ejemplo, compiladores, constructores, herramientas de integración, plataformas de prueba y entornos) deberían controlarse rigurosamente.

Para el código fuente, esto se puede lograr al controlar el almacenamiento central de dicho código, preferiblemente en el sistema de gestión del código fuente.

El acceso de lectura y escritura al código fuente puede variar en función de la función del personal. Por ejemplo, el acceso de lectura al código fuente se puede proporcionar ampliamente dentro de la organización, pero el acceso de escritura al código fuente solo está disponible para el personal con privilegios o los propietarios designados. Cuando varios desarrolladores de una organización utilizan componentes de código, se debería implementar el acceso de lectura a un repositorio de código centralizado. Además, si se utiliza código de código abierto o componentes de código de terceros dentro de una organización, se puede proporcionar acceso de lectura a dichos repositorios de código externo. Sin embargo, el acceso de escritura debería seguir estando restringido.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Se deberían considerar las siguientes directrices para controlar el acceso a las bibliotecas de origen de programas a fin de reducir el potencial de corrupción de los programas informáticos:

a) administrar el acceso al código fuente del programa y a las bibliotecas de origen del programa según los procedimientos establecidos;

b) conceder acceso de lectura y escritura al código fuente en función de las necesidades del negocioes y gestionar para abordar los riesgos de alteración o uso indebido y de acuerdo con los procedimientos establecidos;

c) actualizar el código fuente y los elementos asociados y conceder acceso al código fuente de acuerdo con los procedimientos de control de cambios (véase el numeral 8.32) y realizarlo solo después de recibir la autorización adecuada;

d) no conceder a los desarrolladores acceso directo al repositorio de código fuente, sino a través de herramientas de desarrollo que controlan las actividades y autorizaciones en el código fuente;

e) mantener listas de programas en un entorno seguro, donde el acceso de lectura y escritura debería gestionarse y asignarse de forma adecuada;

f) mantener un registro de auditoría de todos los accesos y de todos los cambios realizados en el código fuente.

Si se pretende publicar el código fuente del programa, debería considerarse controles adicionales para Asegurar su integridad (por ejemplo, la firma digital).

Otra información

Si el acceso al código fuente no se controla correctamente, el código fuente se puede modificar o algunos datos del entorno de desarrollo (por ejemplo, copias de datos de producción, detalles de configuración) pueden ser recuperados por personas no autorizadas.

8.5 Autenticación de seguridad

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de la identidad y del acceso	#Protección

Control

Las tecnologías y los procedimientos de autenticación segura deberían implementarse en función de las restricciones de acceso a la información y de la política de control de acceso específica del tema.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Asegurar que un usuario o una entidad se autentique de forma segura cuando se conceda acceso a sistemas, aplicaciones y servicios.

Guía

Debería elegirse una técnica de autenticación adecuada para fundamentar la identidad reclamada de un usuario, software, mensajes y otras entidades.

La solidez de la autenticación debería ser adecuada para la clasificación de la información a la que se va a acceder. Cuando se requiere autenticación y verificación de identidad sólidas, se utilizan métodos de autenticación se debería utilizar una alternativa a las contraseñas, como certificados digitales, tarjetas inteligentes, tokens o medios biométricos.

La información de autenticación debería ir acompañada de factores de autenticación adicionales para acceder a los sistemas de información críticos (también conocidos como autenticación de varios factores). El uso de una combinación de varios factores de autenticación, como lo que sabe, lo que tiene y lo que es, reduce las posibilidades de accesos no autorizados. La autenticación de varios factores se puede combinar con otras técnicas para requerir factores adicionales en circunstancias específicas, basados en reglas y patrones predefinidos, como el acceso desde una ubicación inusual, desde un dispositivo inusual o en un momento inusual.

La información de autenticación biométrica debería invalidarse si alguna vez se ve comprometida. La autenticación biométrica puede no estar disponible dependiendo de las condiciones de uso (por ejemplo, humedad o envejecimiento). Para prepararse para estos problemas, la autenticación biométrica debería ir acompañada de al menos una técnica de autenticación alternativa.

El procedimiento para iniciar sesión en un sistema o aplicación debería diseñarse para minimizar el riesgo de acceso no autorizado. Los procedimientos y tecnologías de inicio de sesión deberían implementarse tomando en consideración lo siguiente:

a) no mostrar información confidencial del sistema o de la aplicación hasta que el proceso de inicio de sesión se haya completado correctamente para evitar que un usuario no autorizado reciba asistencia innecesaria;

b) mostrar un aviso general advirtiendo de que el sistema, la aplicación o el servicio solo deberían ser accesibles por usuarios autorizados;

c) no proporcionar mensajes de ayuda durante el procedimiento de inicio de sesión que ayuden a un usuario no autorizado (por ejemplo, si se produce una condición de error, el sistema no debería indicar qué parte de los datos es correcta o incorrecta);

d) validar la información de inicio de sesión solo cuando se completen todos los datos de entrada;

e) Protección contra intentos de inicio de sesión de forzada en nombres de usuario y contraseñas [por ejemplo, mediante una prueba de Turing pública y automática para distinguir a los computadores de los humanos (CAPTCHA), que requiere el restablecimiento

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

de la contraseña después de un número predefinido de intentos fallidos o que bloquea al usuario después de un número máximo de errores];

f) registro de intentos fallidos y correctos;

g) provocar un evento de seguridad si se detecta un posible intento o incumplimiento satisfactorio de los controles de inicio de sesión (por ejemplo, enviar una alerta al usuario y a los administradores del sistema de la empresa cuando se ha alcanzado un número determinado de intentos de contraseña incorrectos);

h) visualización o envío de la siguiente información en un canal separado al finalizar un inicio de sesión correcto:

1) fecha y hora del inicio de sesión anterior correcto;

2) detalles de cualquier intento de inicio de sesión incorrecto desde el último inicio de sesión correcto;

i) no mostrar una contraseña en texto no cifrado al introducirla; en algunos casos, puede ser necesario desactivar esta función para facilitar el inicio de sesión del usuario (por ejemplo, por motivos de accesibilidad o para evitar bloquear a los usuarios debido a errores repetidos);

j) no transmitir contraseñas en texto no cifrado a través de una red para evitar ser capturadas por un programa de rastreador de red;

k) finalizar sesiones inactivas después de un período definido de inactividad, especialmente en ubicaciones de alto riesgo, como áreas públicas o externas fuera de la gestión de seguridad de la organización o en dispositivos finales de usuario;

l) restringir los tiempos de duración de la conexión para proporcionar seguridad adicional a las aplicaciones de alto riesgo y reducir la oportunidad de acceso no autorizado.

Otra información

Se puede encontrar información adicional sobre la garantía de autenticación de entidades en la norma ISO/IEC 29115.

8.6 Gestión de capacidad

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención #Detección	#Integridad #Disponibilidad	#Identificar#Protección #Detección	#Continuidad	#Gobierno_y_ ecosistema #Protección

Control

La utilización de los recursos debería supervisarse y ajustarse de conformidad con las necesidades de capacidad actuales y previstas.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Asegurar la capacidad necesaria de los servicios de procesamiento de información, los recursos humanos, las oficinas y otros servicios.

Guía

Deberían determinarse las necesidades de capacidad para las instalaciones de procesamiento de información, los recursos humanos, las oficinas y otras instalaciones, tomando en consideración la importancia del negocio de los sistemas y procesos en cuestión.

El ajuste y la supervisión del sistema deberían aplicarse para Asegurar y, en caso necesario, mejorar la disponibilidad y la eficiencia de los sistemas.

La organización debería realizar pruebas de esfuerzo de los sistemas y servicios para confirmar que hay suficiente capacidad del sistema para satisfacer los requisitos de rendimiento máximo.

Los controles de detectives deberían ponerse en marcha para indicar problemas a su debido tiempo.

Las proyecciones de los futuros requisitos de capacidad deberían tener en cuenta los nuevos requisitos del negocioes y del sistema, así como las tendencias actuales y proyectadas de las capacidades de procesamiento de información de la organización.

Se debería prestar especial atención a los recursos con plazos de entrega largos o costos elevados. Por lo tanto, los administradores, los propietarios de servicios o productos deberían supervisar la utilización de los recursos clave del sistema.

Los administradores deberían utilizar la información de capacidad para identificar y evitar posibles limitaciones de recursos y dependencia del personal clave que pueda representar una amenaza para la seguridad o los servicios del sistema y planificar las medidas apropiadas.

Se puede lograr una capacidad suficiente aumentando la capacidad o reduciendo la demanda. Se deberían tomar en consideración las siguientes directrices para aumentar la capacidad:

a) contratación de nuevo personal;

b) obtención de nuevas instalaciones o espacio;

c) adquisición de sistemas de procesamiento, memoria y almacenamiento más potentes;

d) uso de computación en la nube (*cloud computing*), que tiene características inherentes que abordan directamente los problemas de capacidad. La computación en nube tiene elasticidad y escalabilidad que permiten una rápida expansión y reducción bajo demanda de los recursos disponibles para aplicaciones y servicios específicos.

Para reducir la demanda de los recursos de la organización, se debería tener en cuenta lo siguiente:

a) eliminación de datos obsoletos (espacio en disco);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) eliminación de registros impresos que hayan cumplido su período de retención (liberar espacio para estanterías);

c) clausura de aplicaciones, sistemas, bases de datos o entornos;

d) optimización de procesos por lotes y programaciones;

e) Optimización del código de aplicación o de las consultas a la base de datos;

f) rechazo o restricción del ancho de banda para servicios que consumen recursos si no son críticos (por ejemplo, transmisión de video).

Debería considerarse un plan de gestión de la capacidad documentado para los sistemas de misión crítica.

Otra información

Para obtener más información sobre la elasticidad y escalabilidad de la computación en la nube, véase el numeral la norma ISO/IEC TS 23167.

8.7 Protección contra malware

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención #Detección #Corrección	#Confidencialidad #Integridad #Disponibilidad	#Protección #Detección	#Seguridad del sistema y de la red #Protección de la información	#Protección #Defensa

Control

La protección contra el malware debería implementarse y respaldarse con el conocimiento adecuado del usuario.

Objetivo

Asegurar que la información y otros activos asociados estén protegidos contra malware.

Guía

La protección contra el malware debería basarse en software de detección y reparación de malware, conocimiento de la seguridad de la información, acceso adecuado al sistema y controles de gestión de cambios. El uso de software de detección y reparación de malware por sí solo no suele ser adecuado. Se debería tomar en consideración las siguientes directrices:

a) implementar reglas y controles que impidan o detecten el uso de software no autorizado [por ejemplo, lista de aplicaciones permitidas (por ejemplo, utilizar una lista que proporcione aplicaciones permitidas)] (véanse los numerales 8.19 y 8.32);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) implementar controles que impidan o detecten el uso de sitios web maliciosos conocidos o sospechosos (por ejemplo, listas de bloqueo);

c) reducir las vulnerabilidades que pueden ser explotadas por malware [por ejemplo, mediante la gestión de vulnerabilidades técnicas (véanse los numerales 8.8 y 8.19)];

d) realizar una validación automatizada regular del software y del contenido de datos de los sistemas, especialmente para los sistemas que soportan procesos del negocioes críticos; investigar la presencia de archivos no aprobados o modificaciones no autorizadas;

e) establecer medidas de protección contra los riesgos asociados a la obtención de archivos y software ya sea desde o a través de redes externas o en cualquier otro medio;

f) instalación y actualización periódica de software de detección y reparación de malware para analizar computadores y medios de almacenamiento electrónicos. Realización de exploraciones regulares que incluyen:

   1) analizar cualquier dato recibido a través de redes o a través de cualquier medio de almacenamiento electrónico en busca de malware antes de su uso;

   2) analizar archivos adjuntos y descargas de correo electrónico y mensajería instantánea en busca de malware antes de su uso. Realizar este análisis en diferentes lugares (por ejemplo, en servidores de correo electrónico computadores de escritorio) y al entrar en la red de la organización;

   3) analizar páginas web en busca de malware cuando se accede a ellas;

g) determinar la ubicación y configuración de las herramientas de detección y reparación de malware en función de los resultados de la evaluación de riesgos y considerar:

   1) defensa en profundidad principios en los que serían más eficaces. Por ejemplo, esto puede llevar a la detección de malware en una puerta de enlace de red (en varios protocolos de aplicación como correo electrónico, transferencia de archivos y web), así como en dispositivos y servidores de extremo de usuario;

   2) las técnicas evasivas de los atacantes (por ejemplo, el uso de archivos cifrados) para ofrecer malware o el uso de protocolos de cifrado para transmitir malware;

h) cuidar de la protección contra la introducción de malware durante el mantenimiento y los procedimientos de emergencia, que pueden eludir los controles normales contra el malware;

i) la implementación de un proceso para autorizar temporalmente o permanentemente la desactivación de algunas o todas las medidas contra el malware, incluidas las autoridades de aprobación de excepciones, la justificación documentada y la fecha de revisión. Esto puede ser necesario cuando la protección contra el malware provoca interrupciones en las operaciones normales;

j) preparar planes de continuidad del negocio adecuados para la recuperación de ataques de malware, incluidos todos los datos y copias de seguridad de software necesarios (incluidas

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

las copias de seguridad online y offline) y las medidas de recuperación (véase el numeral 8.13);

k) aislamiento de entornos en los que pueden producirse consecuencias catastróficas;

l) definir procedimientos y responsabilidades para tratar la protección contra el malware en los sistemas, incluida la formación sobre su uso, la elaboración de informes y la recuperación de ataques de malware;

m) Proporcionar conocimientos o formación (véase el numeral 6.3) a todos los usuarios sobre cómo identificar y mitigar potencialmente la recepción, el envío o la instalación de correos electrónicos, archivos o programas infectados por malware [la información recopilada en n) y o) puede utilizarse para Asegurar que la concienciación y la formación se mantienen al día];

n) implementar procedimientos para recopilar periódicamente información sobre nuevos programas maliciosos, como la suscripción a listas de correo o la revisión de sitios web relevantes;

o) verificar que la información relacionada con el malware, como los boletines de advertencia, proviene de fuentes calificadas y fiables (por ejemplo, sitios de internet fiables o proveedores de software de detección de malware) y es precisa e informativa.

Otra información

No siempre es posible instalar software que proteja contra el malware en algunos sistemas (por ejemplo, algunos sistemas de control industrial). Algunas formas de malware infectan los sistemas operativos del computador y el firmware del computador, de forma que los controles de malware comunes no pueden limpiar el sistema y es necesario volver a crear una imagen completa del software del sistema operativo y, a veces, el firmware del computador para volver a un estado seguro.

8.8 gestión de las vulnerabilidades técnicas

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #Proteger	#Gestión_de_amenazas_y_de_vulnerabilidades	#Gobierno_y_ecosistema #Protección #Defensa

Control

Se debería obtener información sobre las vulnerabilidades técnicas de los sistemas de información en uso, se debería evaluar la exposición de la organización a esas vulnerabilidades y se deberían adoptar las medidas apropiadas.

Objetivo

Evitar la explotación de vulnerabilidades técnicas.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Guía

Identificación de vulnerabilidades técnicas

La organización debería tener un inventario preciso de los activos (véanse los numerales 5.9 al 5.14) como requisito previo para una gestión eficaz de la vulnerabilidad técnica; el inventario debería incluir el proveedor del software, el nombre del software, los números de versión, el estado actual de la implementación (por ejemplo, qué software está instalado en qué sistemas) y la persona o personas dentro de la organización responsable del software.

Para identificar vulnerabilidades técnicas, la organización debería considerar:

a) definir y establecer las funciones y responsabilidades asociadas con la gestión técnica de la vulnerabilidad, incluida la supervisión de la vulnerabilidad, la evaluación del riesgo de vulnerabilidad, la actualización, el seguimiento de los activos y las responsabilidades de coordinación necesarias;

b) para el software y otras tecnologías (según la lista de inventario de activos, véase el numeral 5.9), al identificar los recursos de información que se utilizarán para identificar las vulnerabilidades técnicas relevantes y mantener la conciencia sobre ellas. Actualizar la lista de recursos de información en función de los cambios en el inventario o cuando se encuentren otros recursos nuevos o útiles;

c) exigir a los proveedores del sistema de información (incluidos sus componentes) que garanticen la notificación, el tratamiento y la divulgación de vulnerabilidades, incluidos los requisitos de los contratos aplicables (véase el numeral 5.20);

d) utilizar herramientas de análisis de vulnerabilidades adecuadas para las tecnologías en uso para identificar vulnerabilidades y comprobar si la aplicación de parches de vulnerabilidades se ha realizado correctamente;

e) realización de pruebas de penetración o evaluaciones de vulnerabilidad planificadas, documentadas y repetibles por parte de personas competentes y autorizadas para apoyar la identificación de vulnerabilidades. Actuar con cautela ya que tales actividades pueden conducir a un compromiso de la seguridad del sistema;

f) realizar un seguimiento del uso de bibliotecas de terceros y del código fuente en busca de vulnerabilidades. Esto debería ser incluido en la codificación segura (véase el numeral 8.28).

La organización debería desarrollar procedimientos y capacidades para:

a) detectar la existencia de vulnerabilidades en sus productos y servicios, incluido cualquier componente externo utilizado en ellos;

b) recibir informes de vulnerabilidad de fuentes internas o externas.

La organización debería proporcionar un punto de contacto público como parte de una política específica de temas sobre la divulgación de la vulnerabilidad para que los investigadores y otras personas puedan informar de los problemas. La organización debería establecer procedimientos de notificación de vulnerabilidades, formularios de presentación de informes en línea y hacer uso de la

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

inteligencia de amenazas apropiada o foros de intercambio de información. La organización también debería considerar programas de recompensa de errores donde se ofrecen recompensas como incentivo para ayudar a las organizaciones a identificar vulnerabilidades con el fin de remediarlas adecuadamente. La organización también debería compartir información con los organismos industriales competentes u otras partes interesadas.

Evaluación de vulnerabilidades técnicas

Para evaluar las vulnerabilidades técnicas identificadas, se debería tener en cuenta la siguiente guía:

a) analizar y verificar los informes para determinar qué respuesta y actividad de corrección son necesarias;

b) una vez identificada una posible vulnerabilidad técnica, se identifican los riesgos asociados y las medidas que se deberían tomar. Estas acciones pueden implicar la actualización de sistemas vulnerables o la aplicación de otros controles.

Tomar las medidas adecuadas para abordar las vulnerabilidades técnicas.

Se debería implementar un proceso de gestión de actualizaciones de software para Asegurar que se instalan los parches y actualizaciones de aplicaciones aprobados más actualizados para todo el software autorizado. Si es necesario realizar cambios, se debería conservar el software original y aplicar los cambios a una copia designada. Todos los cambios deberían probarse y documentarse por completo, de modo que se puedan volver a aplicar, si es necesario, a futuras actualizaciones de software. Si es necesario, las modificaciones deberían ser probadas y validadas por un organismo de evaluación independiente.

Se debería tener en cuenta la siguiente guía para abordar las vulnerabilidades técnicas:

a) adoptar medidas apropiadas y oportunas en respuesta a la identificación de posibles vulnerabilidades técnicas; definir un calendario para reaccionar a las notificaciones de vulnerabilidades técnicas potencialmente relevantes;

b) dependiendo de la urgencia con que se deba abordar una vulnerabilidad técnica, llevar a cabo la acción de acuerdo con los controles relacionados con la gestión de cambios (véase el numeral 8.32) o siguiendo los procedimientos de respuesta a incidentes de seguridad de la información (véase el numeral 5.26);

c) solo utilizar actualizaciones de fuentes legítimas (que pueden ser internas o externas a la organización);

d) probar y evaluar las actualizaciones antes de instalarlas para asegurarse de que son efectivas y no producen efectos secundarios que no se pueden tolerar [es decir, si hay una actualización disponible, evaluando los riesgos asociados con la instalación de la actualización (los riesgos que plantea la vulnerabilidad deberían compararse con el riesgo de instalar la actualización)];

e) abordar primero los sistemas de alto riesgo;

f) desarrollar soluciones (normalmente actualizaciones de software o parches);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

g) prueba para confirmar si la remediación o mitigación es efectiva;

h) proporcionar mecanismos para verificar la autenticidad de la corrección;

i) si no hay ninguna actualización disponible o la actualización no se puede instalar, tomando en consideración otros controles, como:

1) aplicar cualquier solución sugerida por el proveedor del software u otras fuentes relevantes;

2) desactivar servicios o capacidades relacionados con la vulnerabilidad;

3) adaptar o añadir controles de acceso (por ejemplo, firewalls) en los límites de la red (véanse los numerales 8.20 a 8.22);

4) protección de sistemas, dispositivos o aplicaciones vulnerables frente a ataques mediante la implementación de filtros de tráfico adecuados (a veces denominados parches virtuales);

5) aumentar la supervisión para detectar ataques reales;

6) sensibilización sobre la vulnerabilidad.

En el caso del software adquirido, si los proveedores regularmente liberan información sobre las actualizaciones de seguridad de su software y proporcionan una instalación para instalar dichas actualizaciones automáticamente, la organización debería decidir si se debería utilizar o no la actualización automática.

Otras consideraciones

Se debería mantener un registro de auditoría para todos los pasos emprendidos en la gestión técnica de vulnerabilidades.

El proceso de gestión de la vulnerabilidad técnica debería ser supervisado y evaluado periódicamente para asegurar su eficacia y eficiencia.

Un proceso de gestión de vulnerabilidad técnica eficaz debería estar alineado con las actividades de gestión de incidentes, para comunicar datos sobre vulnerabilidades a la función de respuesta a incidentes y proporcionar procedimientos técnicos que se deberían llevar a cabo en caso de que se produzca un incidente.

Cuando la organización utiliza un servicio en la nube proporcionado por un proveedor de servicios en la nube de terceros, el proveedor de servicios en la nube debería Asegurar la gestión de vulnerabilidades técnicas de los recursos del proveedor de servicios en la nube. Las responsabilidades del proveedor de servicios en la nube para la gestión de vulnerabilidades técnicas deberían formar parte del acuerdo de servicios en la nube y esto debería incluir procesos para informar de las acciones del proveedor de servicios en la nube relacionadas con vulnerabilidades técnicas (véase el numeral 5.23). Para algunos servicios en la nube, existen responsabilidades respectivas para el proveedor de servicios en la nube y el cliente de servicios en la nube. Por

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

ejemplo, el cliente del servicio en la nube es responsable de la gestión de vulnerabilidades de sus propios activos utilizados para los servicios en la nube.

Otra información

La gestión técnica de la vulnerabilidad puede considerarse una subfunción de la gestión del cambio y, como tal, puede aprovechar los procesos y procedimientos de gestión del cambio (véase el numeral 8.32).

Existe la posibilidad de que una actualización no aborde el problema adecuadamente y tenga efectos secundarios negativos. Además, en algunos casos, la desinstalación de una actualización no se puede realizar fácilmente una vez aplicada la actualización.

Si no es posible realizar pruebas adecuadas de las actualizaciones (por ejemplo, debido a los costos o a la falta de recursos), se puede considerar un retraso en la actualización para evaluar los riesgos asociados, en función de la experiencia reportada por otros usuarios. El uso de la norma ISO/IEC 27031 puede ser beneficioso.

Cuando se produzcan parches o actualizaciones de software, la organización puede considerar la posibilidad de proporcionar un proceso de actualización automatizado en el que estas actualizaciones se instalen en los sistemas o productos afectados sin necesidad de intervención del cliente o del usuario. Si se ofrece un proceso de actualización automatizado, puede permitirle al cliente o usuario elegir una opción para desactivar la actualización automática o controlar el momento de la instalación de la actualización.

Cuando el proveedor proporciona un proceso de actualización automatizado y las actualizaciones se pueden instalar en los sistemas o productos afectados sin necesidad de intervención, la organización determina si aplica o no el proceso automatizado. Una razón por la que no se elige la actualización automática es mantener el control cuando se realiza la actualización. Por ejemplo, un software utilizado para una operación de negocio no se puede actualizar hasta que la operación se haya completado.

Un punto débil del análisis de vulnerabilidades es que es posible que no tenga en cuenta completamente la defensa en profundidad: Dos contramedidas que siempre se invocan en secuencia pueden tener vulnerabilidades enmascaradas por puntos fuertes en la otra. La medida compensada compuesta no es vulnerable, mientras que un analizador de vulnerabilidades puede informar de que ambos componentes son vulnerables. Por lo tanto, la organización debería tener cuidado al examinar y actuar en relación con los informes de vulnerabilidad.

Muchas organizaciones suministran software, sistemas, productos y servicios no solo dentro de la organización, sino también a partes interesadas como clientes, socios u otros usuarios. Este software, sistemas, productos y servicios pueden tener vulnerabilidades de seguridad de la información que afectan a la seguridad de los usuarios.

Las organizaciones pueden publicar soluciones y divulgar información sobre vulnerabilidades a los usuarios (normalmente a través de un asesoramiento público) y proporcionar información adecuada para los servicios de base de datos de vulnerabilidades de software.

Para obtener más información sobre la gestión de vulnerabilidades técnicas al utilizar computación en la nube, véase el numeral las series ISO/IEC 19086 e ISO/IEC 27017.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

La norma ISO/IEC 29147 proporciona información detallada sobre la recepción de informes de vulnerabilidad y la publicación de avisos de vulnerabilidad. La norma ISO/IEC 30111 proporciona información detallada sobre el manejo y la resolución de vulnerabilidades reportadas.

8.9 Gestión de la configuración

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Configuración_segura	#Protección

Control

Las configuraciones, incluidas las configuraciones de seguridad, de hardware, software, servicios y redes deberían establecerse, documentarse, implementarse, supervisarse y revisarse.

Objetivo

Para Asegurar que el hardware, el software, los servicios y las redes funcionan correctamente con la configuración de seguridad requerida y la configuración no se ve alterada por cambios no autorizados o incorrectos.

Guía

General

La organización debería definir e implementar procesos y herramientas para aplicar las configuraciones definidas (incluidas las configuraciones de seguridad) para hardware, software, servicios (por ejemplo, servicios en la nube) y redes, para sistemas recién instalados y para sistemas operativos a lo largo de su vida útil.

Debería establecerse funciones, responsabilidades y procedimientos para Asegurar un control satisfactorio de todos los cambios de configuración.

Plantillas estándar

Se debería definir plantillas estándar para la configuración segura de hardware, software, servicios y redes:

a) Al utilizar orientaciones disponibles públicamente (por ejemplo, plantillas predefinidas de proveedores y de organizaciones de seguridad independientes);

b) Al considerar el nivel de protección necesario para determinar un nivel suficiente de seguridad;

c) Al apoyar la política de seguridad de la información de la organización, a las políticas de temas específicos, a las normas y a otros requisitos de seguridad;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

d) Al considerar la viabilidad y aplicabilidad de las configuraciones de seguridad en el contexto de la organización.

Las plantillas deberían revisarse periódicamente y actualizarse cuando sea necesario abordar nuevas amenazas o vulnerabilidades o cuando se introduzcan nuevas versiones de software o hardware.

Se debería tener en cuenta lo siguiente para establecer plantillas estándar para la configuración segura de hardware, software, servicios y redes:

a) minimizar el número de identidades con derechos de acceso a nivel de administrador o con privilegios;

b) deshabilitar identidades innecesarias, no utilizadas o inseguras;

c) deshabilitar o restringir funciones y servicios innecesarios;

d) restringir el acceso a potentes programas de utilidad y a la configuración de parámetros de host;

e) sincronización de relojes;

f) cambiar la información de autenticación predeterminada del proveedor, como las contraseñas predeterminadas, inmediatamente después de la instalación y revisar otros parámetros importantes relacionados con la seguridad predeterminada;

g) invocar las funciones de tiempo de espera que desconectan automáticamente los dispositivos informáticos después de un período predeterminado de inactividad;

h) verificación de que se han cumplido los requisitos de licencia (véase el numeral 5.32).

Gestión de configuraciones

Se debería registrar las configuraciones establecidas de hardware, software, servicios y redes y se debería mantener un registro de todos los cambios de configuración. Estos registros deberían almacenarse de forma segura. Esto se puede lograr de varias maneras, como bases de datos de configuración o plantillas de configuración.

Los cambios en las configuraciones deberían seguir el proceso de administración de cambios (véase el numeral 8.32). Los registros de configuración pueden contener, según corresponda:

a) información actualizada del propietario o punto de contacto del activo;

b) fecha del último cambio de configuración;

c) versión de la plantilla de configuración;

d) relación con las configuraciones de otros activos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Configuraciones de monitoreo

Las configuraciones deberían monitorearse con un conjunto completo de herramientas de administración del sistema (por ejemplo, , servicios de mantenimiento, soporte remoto, herramientas de administración de la empresa, software de copia de seguridad y restauración) y deberían revisarse periódicamente para verificar la configuración, evaluar la intensidad de la contraseña y evaluar las actividades realizadas. Las configuraciones reales se pueden comparar con las plantillas de destino definidas. Cualquier desviación debería ser tratada ya sea mediante la aplicación automática de la configuración de blanco definida o mediante el análisis manual de la desviación seguida de acciones correctivas.

Otra información

La documentación de los sistemas suele registrar detalles sobre la configuración tanto del hardware como del software.

El endurecimiento del sistema es una parte representativa de la gestión de la configuración.

La gestión de la configuración se puede integrar con los procesos de gestión de activos y las herramientas asociadas. La automatización suele ser más eficaz para gestionar la configuración de la seguridad (por ejemplo, al utilizar la infraestructura como código).

Las plantillas de configuración y los destinos pueden ser información confidencial y deberían protegerse del acceso no autorizado en consecuencia.

8.10 Eliminación de información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad	#Proteger	#Protección_de_la_información #Legal_y_cumplimiento	#Protección

Control

La información almacenada en sistemas de información, dispositivos o cualquier otro medio de almacenamiento debería eliminarse cuando ya no sea necesario.

Objetivo

Evitar la exposición innecesaria de información confidencial y cumplir con los requisitos legales, legales, reglamentarios y contractuales para la eliminación de información.

Guía

General

La información confidencial no debería conservarse durante más tiempo del necesario para reducir el riesgo de divulgación indeseable.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Al eliminar información sobre sistemas, aplicaciones y servicios, se debería tener en cuenta lo siguiente:

a) selección de un método de borrado (por ejemplo, sobreescritura electrónica o borrado cifrado) de acuerdo con los requisitos de la empresa y tomando en consideración las leyes y reglamentos pertinentes;

b) Registro de los resultados de la eliminación como prueba;

c) cuando se utilicen proveedores de servicios de eliminación de información obtener de ellos pruebas de la eliminación de dicha información.

Cuando terceros almacenen la información de la organización en su nombre, la organización debería considerar la inclusión de requisitos sobre la eliminación de información en los acuerdos de terceros para aplicarla durante y al terminar dichos servicios.

Métodos de eliminación

De conformidad con la política temática específica de la organización sobre la retención de datos y tomando en consideración la legislación y los reglamentos pertinentes, la información confidencial debería eliminarse cuando ya no sea necesaria mediante:

a) Configuración de sistemas para destruir información de forma segura cuando ya no sea necesaria (por ejemplo, después de un período definido sujeto a la política específica del tema sobre la retención de datos o por solicitud de acceso del sujeto);

b) eliminación de versiones obsoletas, copias y archivos temporales dondequiera que se encuentren;

c) uso de software de eliminación seguro aprobado para eliminar información de forma permanente para Asegurar que la información no se pueda recuperar mediante herramientas forenses o de recuperación especializada;

d) uso de proveedores autorizados y certificados de servicios de eliminación segura;

e) uso de mecanismos de eliminación adecuados para el tipo de medio de almacenamiento que se va a desechar (por ejemplo, desmagnetización de unidades de disco duro y otros medios de almacenamiento magnético).

Cuando se utilizan servicios en la nube, la organización debería comprobar si el método de eliminación proporcionado por el proveedor de servicios en la nube es aceptable y, en caso afirmativo, la organización debería utilizarlo o solicitar que el proveedor de servicios en la nube elimine la información. Estos procesos de eliminación se deberían automatizar de acuerdo con las políticas específicas del tema, cuando estén disponibles y sean aplicables. En función de la sensibilidad de la información eliminada, los registros pueden realizar un seguimiento o verificar que se han producido estos procesos de eliminación.

Para evitar la exposición accidental de información confidencial cuando el equipo se regresa a los proveedores, la información confidencial debería protegerse eliminando almacenamientos auxiliares

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

(por ejemplo, unidades de disco duro) y la memoria antes de que el equipo salga de las instalaciones de la organización.

Tomando en consideración que la eliminación segura de algunos dispositivos (por ejemplo, smartphones) solo se puede lograr mediante la destrucción o el uso de las funciones integradas en estos dispositivos (por ejemplo “restaurar ajustes de fábrica”), la organización debería elegir el método apropiado de acuerdo con la clasificación de la información que manejan dichos dispositivos.

Las medidas de control descritas en el numeral 7.14 deberían aplicarse para destruir físicamente el dispositivo de almacenamiento y eliminar simultáneamente la información que contiene.

Un registro oficial de eliminación de información es útil al analizar la causa de un posible evento de fuga de información.

Otra información

La información sobre la eliminación de datos de usuario en los servicios en la nube se encuentra en la ISO/IEC 27017. En la norma ISO/IEC 27555 se puede encontrar información sobre la eliminación de la IIP.

8.11 Enmascaramiento de datos

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad	#Proteger	#Protección_de_información	#Protección

Control

El enmascaramiento de datos debería utilizarse de acuerdo con la política de la organización sobre el control de acceso y otras políticas específicas de temas relacionados, así como con los requisitos del negocioes, tomando en consideración la legislación aplicable.

Objetivo

Limitar la exposición de datos sensibles, incluida la IIP y cumplir con los requisitos legales, estatutario, reglamentarios y contractuales.

Guía

Cuando la protección de datos sensibles (por ejemplo, IIP) es una preocupación, la organización debería considerar la posibilidad de ocultar tales datos mediante técnicas como el enmascaramiento de datos, la pseudoanonimización o la anonimización.

Las técnicas de pseudoanonimización o anonimización pueden ocultar la IIP ocultar la verdadera identidad de los principales de la IIP u otra información sensible y desconectar el vínculo entre la IIP y la identidad del principal de la IIP o el vínculo entre otra información sensible.

Cuando se utilicen técnicas de pseudoanonimización o anonimización, debería verificarse que los datos han sido adecuadamente pseudoanonimizados o anonimizados. La anonimización de los datos

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

debería considerar que todos los elementos de la información confidencial son eficaces. Por ejemplo, si no se considera adecuadamente, una persona puede ser identificada aunque los datos que pueden identificarla directamente sean anónimos, por la presencia de otros datos que permiten identificarla indirectamente.

Entre las técnicas adicionales para el enmascaramiento de datos se incluyen:

a) cifrado (que requiere que los usuarios autorizados tengan una clave);

b) anular o eliminar caracteres (impedir que los usuarios no autorizados vean mensajes completos);

c) números y fechas variables;

d) sustitución (cambiar un valor por otro para ocultar datos confidenciales);

e) reemplazar valores con su hash.

Al implementar técnicas de enmascaramiento de datos, se debería tener en cuenta lo siguiente:

a) no conceder a todos los usuarios acceso a todos los datos, por lo tanto, diseñar consultas y máscaras para mostrar solo los datos mínimos necesarios para el usuario;

b) hay casos en los que algunos datos no deberían ser visibles al usuario para algunos registros de un conjunto de datos; en este caso, diseñar e implementar un mecanismo de ofuscación de datos (por ejemplo, si un paciente no quiere que el personal del hospital pueda ver todos sus historiales, incluso en caso de emergencia, entonces el personal del hospital se presenta con datos parcialmente ofuscados y solo puede acceder a los datos el personal con roles específicos si contiene información útil para el tratamiento adecuado);

c) Cuando los datos están ofuscados, lo que da al principal de PII la posibilidad de exigir que los usuarios no puedan ver si los datos están enmascarados (ocultación del enmascaramiento; esto se utiliza en los centros de salud, por ejemplo, si el paciente no desea que el personal vea que se ha ocultado información sensible como embarazos o resultados de exámenes de sangre);

d) cualquier requisito legal o reglamentario (por ejemplo, que requiera el enmascaramiento de la información de las tarjetas de pago durante el procesamiento o almacenamiento).

A la hora de utilizar el enmascaramiento, la pseudoanonimización o la anonimización de los datos debería tenerse en cuenta lo siguiente:

a) nivel de intensidad del enmascaramiento de datos, pseudoanonimización o anonimización según el uso de los datos procesados;

b) controles de acceso a los datos procesados;

c) acuerdos o restricciones sobre el uso de los datos procesados;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

d) la imposibilidad de cotejar los datos procesados con otra información para identificar al titular de la IIP;

e) realizar un seguimiento de la provisión y recepción de los datos procesados.

Otra información

La anonimización altera irreversiblemente la IIP de tal manera que el principal de la IIP ya no puede identificarse directa o indirectamente.

La pseudoanonimización sustituye la información de identificación por un alias. El conocimiento del algoritmo (en ocasiones denominado “información adicional”) utilizado para realizar la pseudoanonimización permite al menos alguna forma de identificación del principal de la IIP. Por consiguiente, esa “información adicional” debería mantenerse separada y protegida.

Mientras que la pseudoanonimización es, por lo tanto, más débil que la anonimización, los conjuntos de datos pseudoanonimizados pueden ser más útiles en la investigación estadística.

El enmascaramiento de datos es un conjunto de técnicas para ocultar, sustituir u ocultar elementos de datos confidenciales. El enmascaramiento de datos puede ser estático (cuando los elementos de datos están enmascarados en la base de datos original), dinámico (mediante automatización y reglas para proteger los datos en tiempo real) o sobre la marcha (con datos enmascarados en la memoria de una aplicación).

Las funciones hash se pueden utilizar para convertir en anónimo la IIP. Con el fin de evitar los ataques de enumeración, siempre deberían combinarse con una función “Salt”.

La IIP en los identificadores de recursos y sus atributos [por ejemplo, nombres de archivo, localizadores de recursos uniformes (URL)] se debería evitar o se debería anonimizar de forma adecuada.

En la norma ISO/IEC 27018 se ofrecen controles adicionales sobre la protección de la IIP en las nubes públicas.

En la norma ISO/IEC 20889 se ofrece información adicional sobre las técnicas de desidentificación.

8.12 Prevención de la fuga de datos

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención #Detección	#Confidencialidad	#Protección #Detección	#Protección de la información	#Protección #Defensa

Control

Las medidas de prevención de fugas de datos deberían aplicarse a los sistemas, redes y cualquier otro dispositivo que procese, almacene o transmita información confidencial.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Objetivo

Detectar y prevenir la divulgación y extracción no autorizada de información por parte de individuos o sistemas.

Guía

La organización debería considerar lo siguiente para reducir el riesgo de fuga de datos:

a) identificación y clasificación de información para proteger contra fugas (por ejemplo, información personal, modelos de precios y diseños de productos);

b) supervisar los canales de fuga de datos (por ejemplo, correo electrónico, transferencias de archivos, dispositivos móviles y dispositivos de almacenamiento portátiles);

c) actuar para evitar que se filtre información (por ejemplo, correos electrónicos de cuarentena que contengan información confidencial).

Se deberían utilizar herramientas de prevención de fugas de datos para:

a) identificar y supervisar la información confidencial en riesgo de divulgación no autorizada (por ejemplo, en datos no estructurados del sistema de un usuario);

b) detectar la divulgación de información confidencial (por ejemplo, cuando la información se carga en servicios en la nube de terceros que no son de confianza o se envía por correo electrónico);

c) bloquear las acciones de los usuarios o las transmisiones de red que exponen información confidencial (por ejemplo, impedir la copia de entradas de la base de datos en una hoja de cálculo).

La organización debería determinar si es necesario restringir la capacidad de un usuario para copiar y pegar o cargar datos en servicios, dispositivos y medios de almacenamiento fuera de la organización. Si ese es el caso, la organización debería implementar tecnología como herramientas de prevención de fugas de datos o la configuración de herramientas existentes que permitan a los usuarios ver y manipular los datos almacenados de forma remota, pero que impidan la copia y el pegado fuera del control de la organización.

Si se requiere la exportación de datos, se debería permitir al propietario de los datos aprobar la exportación y hacer que los usuarios sean responsables de sus acciones.

La realización de capturas de pantalla o fotografías de la pantalla debería abordarse mediante los términos y condiciones de uso, formación y auditoría.

Cuando se realiza una copia de seguridad de los datos, se debería tener cuidado de Asegurar la protección de la información confidencial mediante medidas como el cifrado, el control de acceso y la protección física de los medios de almacenamiento que contienen la copia de seguridad.

La prevención de fugas de datos también debería considerarse para proteger contra las acciones de inteligencia de un adversario de la obtención de información confidencial o secreta (geopolítica,

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

humana, financiera, comercial, científica o de cualquier otra índole) que pueda ser de interés para el espionaje o puede ser crítica para la comunidad. Las acciones de prevención de fugas de datos deberían orientarse a confundir las decisiones del adversario, por ejemplo, sustituyendo la información auténtica por información falsa ya sea como una acción independiente o como respuesta a las acciones de inteligencia del adversario. Ejemplos de este tipo de acciones son la ingeniería social inversa o el uso de “honeypots” para atraer atacantes.

Otra información

Las herramientas de prevención de fugas de datos están diseñadas para identificar datos, supervisar el uso y el movimiento de datos y tomar medidas para evitar que se produzcan fugas de datos (por ejemplo, alertar a los usuarios sobre su comportamiento arriesgado y bloquear la transferencia de datos a dispositivos de almacenamiento portátiles).

La prevención de fugas de datos implica de forma inherente la supervisión de las comunicaciones del personal y de las actividades en línea y por extensión de los mensajes de terceros externos, lo que plantea problemas legales que deberían considerarse antes de implementar herramientas de prevención de fugas de datos. Existe una variedad de legislación relativa a la privacidad, la protección de datos, el empleo, la interceptación de datos y las telecomunicaciones que se aplica al seguimiento y el procesamiento de datos en el contexto de la prevención de fugas de datos.

La prevención de fugas de datos se puede admitir mediante controles de seguridad estándar, como directivas específicas de temas sobre control de acceso y gestión segura de documentos (véanse los numerales 5.12 y 5.15).

8.13 Copia de seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Correctivo	#Integridad #Disponibilidad	#Recuperar	#Continuidad	#Protección

Control

Las copias de seguridad de la información, el software y los sistemas deberían mantenerse y probarse periódicamente de conformidad con la política de copia de seguridad específica del tema acordado.

Objetivo

Permitir la recuperación de la pérdida de datos o sistemas.

Guía

Se debería establecer una política de copia de seguridad específica de un tema para abordar los requisitos de retención de datos y seguridad de la información de la organización.

Se deberían proporcionar las instalaciones de copia de seguridad adecuadas para Asegurar que toda la información y el software esenciales se puedan recuperar tras un incidente, falla o pérdida de los medios de almacenamiento.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Se deberían desarrollar e implementar planes para la forma en que la organización realizará copias de seguridad de la información, el software y los sistemas, para abordar la política específica del tema sobre copias de seguridad.

Al diseñar un plan de copia de seguridad, se deberían tener en cuenta los siguientes elementos:

a) producir registros precisos y completos de las copias de seguridad y procedimientos de restauración documentados;

b) reflejar los requisitos del negocioes de la organización (por ejemplo, el objetivo del punto de recuperación, véase el numeral 5,30), los requisitos de seguridad de la información implicada y la importancia de la información para el funcionamiento continuo de la organización en la medida (por ejemplo, copia de seguridad completa o diferencial) y la frecuencia de las copias de seguridad;

c) almacenar las copias de seguridad en una ubicación remota segura y a una distancia suficiente para evitar cualquier daño causado por un desastre en el sitio principal;

d) Proporcionar a la información de copia de seguridad un nivel adecuado de protección física y ambiental (véase el numeral la Cláusula 7 y 8.1) coherente con las normas aplicadas en el sitio principal;

e) probar regularmente los medios de copia de seguridad para Asegurar que se pueden confiar en ellos para su uso de emergencia cuando sea necesario. Probar la capacidad de restaurar los datos de copia de seguridad en un sistema de prueba, no sobrescribiendo los medios de almacenamiento originales en caso de que el proceso de copia de seguridad o restauración falle y cause daños o pérdidas irreparables en los datos;

f) proteger las copias de seguridad mediante cifrado de acuerdo con los riesgos identificados (por ejemplo, en situaciones en las que la confidencialidad es importante);

g) asegúrese de que se detecte una pérdida de datos inadvertida antes de realizar la copia de seguridad.

Los procedimientos operativos deberían supervisar la ejecución de las copias de seguridad y solucionar las fallas de las copias de seguridad programadas para Asegurar la integridad de las copias de seguridad de acuerdo con la política de copias de seguridad específica del tema.

Las medidas de respaldo para sistemas y servicios individuales deberían ser probadas regularmente para asegurar que cumplen con los objetivos de respuesta a incidentes y planes de continuidad del negocio (véase el numeral 5.30). Esto debería combinarse con una prueba de los procedimientos de restauración y verificarse con el tiempo de restauración requerido por el plan de continuidad del negocio. En el caso de los sistemas y servicios críticos, las medidas de copia de seguridad deberían abarcar toda la información, las aplicaciones y los datos de los sistemas necesarios para recuperar todo el sistema en caso de desastre.

Cuando la organización utiliza un servicio en la nube, se deberían realizar copias de seguridad de la información, las aplicaciones y los sistemas de la organización en el entorno del servicio en la nube. La organización debería determinar si se cumplen los requisitos de copia de seguridad y cómo se cumplen al utilizar el servicio de copia de seguridad de información proporcionado como parte del servicio en la nube.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Se debería determinar el período de retención de la información del negocio esencial, tomando en consideración cualquier requisito de retención de copias archivadas. La organización debería considerar la eliminación de información (véase el numeral 8.10) en los medios de almacenamiento utilizados para la copia de seguridad una vez que el período de retención de la información expire y debería tener en cuenta la legislación y las regulaciones.

Otra información

Para obtener más información sobre la seguridad del almacenamiento, incluida la consideración de la retención, véase el numeral la norma ISO/IEC 27040.

8.14 Redundancia de las instalaciones de tratamiento de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Disponibilidad.	#Proteger	#Continuidad #Gestión_de_activos	#Protección #Resiliencia

Control

Las instalaciones de procesamiento de información deberían implementarse con redundancia suficiente para satisfacer los requisitos de disponibilidad.

Objetivo

Asegurar el funcionamiento continuo de las instalaciones de procesamiento de información.

Guía

La organización debería identificar los requisitos para la disponibilidad de servicios del negocioes y sistemas de información. La organización debería diseñar e implementar una arquitectura de sistemas con redundancia adecuada para satisfacer estos requisitos.

La redundancia se puede introducir duplicando las instalaciones de procesamiento de información en parte o en su totalidad (por ejemplo, componentes de repuesto o tener dos de todo). La organización debería planificar e implementar procedimientos para la activación de los componentes redundantes y las instalaciones de procesamiento. Los procedimientos deberían establecer si los componentes redundantes y las actividades de procesamiento siempre están activados o en caso de emergencia, se activan automática o manualmente. Los componentes redundantes y las instalaciones de procesamiento de la información deberían Asegurar el mismo nivel de seguridad que los principales.

Deberían existir mecanismos para alertar a la organización de cualquier falla en las instalaciones de procesamiento de información, permitir la ejecución del procedimiento planificado y permitir una disponibilidad continua mientras se reparan o reemplazan las instalaciones de procesamiento de información.

La organización debería tener en cuenta lo siguiente al implementar sistemas redundantes:

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

a) contratar con dos o más proveedores de redes e instalaciones de procesamiento de información crítica, como proveedores de servicios de internet;

b) uso de redes redundantes;

c) utilizar dos centros de datos separados geográficamente con sistemas duplicados;

d) uso de fuentes de energía o fuentes físicamente redundantes;

e) utilizar varias instancias paralelas de componentes de software, con equilibrio de carga automático entre ellos (entre instancias en el mismo centro de datos o en diferentes centros de datos);

f) tener componentes duplicados en los sistemas (por ejemplo, CPU, discos duros, memorias) o en redes (por ejemplo, *firewalls, routers, switches*).

Cuando sea aplicable, preferiblemente en modo de producción, se deberían probar sistemas de información redundantes para Asegurar que la conmutación por error de un componente a otro funciona según lo previsto.

Otra información

Existe una fuerte relación entre la redundancia y la preparación de las TIC para la continuidad del negocio (véase el numeral 5,30), especialmente si se requieren tiempos de recuperación cortos. Muchas de las medidas de redundancia pueden formar parte de las estrategias y soluciones de continuidad de las TIC.

La implementación de redundancias puede generar riesgos para la integridad (por ejemplo, los procesos de copia de datos en componentes duplicados pueden introducir errores) o la confidencialidad (por ejemplo, un control débil de la seguridad de los componentes duplicados puede llevar a un compromiso) de los sistemas de información y de información, que debería tenerse en cuenta al diseñar sistemas de información.

La redundancia en las instalaciones de procesamiento de información normalmente no aborda la indisponibilidad de las aplicaciones debido a fallas dentro de una aplicación.

Con el uso de computación en la nube pública, es posible disponer de varias versiones en directo de las instalaciones de procesamiento de información, que existen en varias ubicaciones físicas independientes con failover automático (o conmutación por error) y equilibrio de carga entre ellas.

Algunas de las tecnologías y técnicas para proporcionar redundancia y failover automático en el contexto de los servicios en la nube se analizan en la ISO/IEC TS 23167.

8.15 Registros

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Detección	#Confidencialidad #Integridad #Disponibilidad	#Detección	#Gestión de eventos de seguridad de la información	#Protección #Defensa

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Control

Debería producirse, almacenarse, protegerse y analizarse los registros que recogen las actividades, las excepciones, los fallas y otros eventos relevantes.

Objetivo

Para registrar eventos, generar pruebas, Asegurar la integridad de la información de registro, evitar el acceso no autorizado, identificar eventos de seguridad de la información que pueden dar lugar a un incidente de seguridad de la información y respaldar las investigaciones.

Guía

General

La organización debería determinar el propósito para el que se crean los registros, los datos que se recopilan y registran y los requisitos específicos del registro para proteger y gestionar los datos del registro. Esto debería documentarse en una directiva específica sobre el registro.

Los registros de eventos deberían incluir para cada evento, según corresponda:

a) ID de usuario;

b) actividades del sistema;

c) fechas, horas y detalles de los eventos relevantes (por ejemplo, inicio y cierre de sesión);

d) identidad del dispositivo, identificador del sistema y ubicación;

e) direcciones de red y protocolos.

Los siguientes eventos deberían ser considerados para el registro:

a) intentos de acceso al sistema exitosos y rechazados;

b) datos correctos y rechazados y otros intentos de acceso a recursos;

c) cambios en la configuración del sistema;

d) uso de privilegios;

e) uso de programas y aplicaciones de utilidad;

f) los archivos a los que se accede y el tipo de acceso, incluida la eliminación de archivos de datos importantes;

g) alarmas generadas por el sistema de control de acceso;

h) activación y desactivación de sistemas de seguridad, como sistemas antivirus y sistemas de detección de intrusiones;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

i) creación, modificación o eliminación de identidades;

j) transacciones ejecutadas por usuarios en aplicaciones. En algunos casos, las aplicaciones son un servicio o producto proporcionado o ejecutado por un tercero.

Es importante que todos los sistemas tengan orígenes de tiempo sincronizados (véase el numeral 8.17) ya que esto permite la correlación de registros entre sistemas para el análisis, las alertas y la investigación de un incidente.

Protección de registros

Los usuarios, incluidos aquellos con derechos de acceso con privilegios, no deberían tener permiso para eliminar o desactivar registros de sus propias actividades. Pueden manipular potencialmente los registros de las instalaciones de procesamiento de información bajo su control directo. Por lo tanto, es necesario proteger y revisar los registros para mantener la responsabilidad de los usuarios con privilegios.

Los controles deberían tener como objetivo proteger contra cambios no autorizados en la información de registro y problemas operativos con la instalación de registro, incluidos:

a) modificaciones de los tipos de mensajes que se graban;

b) archivos de registro que se están editando o eliminando;

c) error al grabar eventos o sobreescritura de eventos grabados pasados si se excede el medio de almacenamiento que contiene un archivo de registro.

Para la protección de registros, se debería considerar el uso de las siguientes técnicas: Hash de cifrado, grabación en un archivo de solo anexión y de solo lectura, grabación en un archivo de transparencia pública.

Algunos registros de auditoría pueden ser necesarios para archivarse debido a los requisitos de retención de datos o a los requisitos para recopilar y conservar pruebas (véase el numeral 5,28).

Cuando la organización necesite enviar registros del sistema o de la aplicación a un proveedor para ayudar con la depuración o la solución de errores, los registros debería desidentificarse siempre que sea posible mediante técnicas de enmascaramiento de datos (véase el numeral 8,11) para obtener información como nombres de usuario, direcciones de protocolo de Internet (IP), nombres de host o nombre de la organización, antes de enviarlos al proveedor.

Los registros de eventos pueden contener datos confidenciales e información de identificación personal. Deberían adoptarse medidas adecuadas de protección de la intimidad (véase el numeral 5,34).

Análisis de registro

El análisis de los registros debería abarcar el análisis y la interpretación de los eventos de seguridad de la información, para ayudar a identificar actividades inusuales o comportamientos anómalos, que pueden representar indicadores de compromiso.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

El análisis de los eventos debería realizarse tomando en consideración:

a) las habilidades necesarias para los expertos que realizan el análisis;

b) determinar el procedimiento de análisis de registros;

c) los atributos necesarios por evento relacionado con la seguridad;

d) Excepciones identificadas mediante el uso de reglas predeterminadas [por ejemplo, información de seguridad y gestión de eventos (SIEM) o reglas de firewall y sistemas de detección de intrusiones (IDS) o firmas de malware];

e) Patrones de comportamiento conocidos y tráfico de red estándar en comparación con la actividad y el comportamiento anómalos [análisis de comportamiento de usuarios y entidades (UEBA)];

f) resultados del análisis de tendencias o patrones (por ejemplo, como resultado del uso de análisis de datos, técnicas de big data y herramientas de análisis especializadas);

g) inteligencia de amenazas disponible.

El análisis de registros debería estar respaldado por actividades de supervisión específicas para ayudar a identificar y analizar el comportamiento anómalo, que incluye:

a) Revisar los intentos correctos e incorrectos de acceder a los recursos protegidos [por ejemplo, servidores del sistema de nombres de dominio (DNS), portales web y recursos compartidos de archivos];

b) Comprobar los registros DNS para identificar las conexiones de red salientes a servidores malintencionados, como los asociados a los servidores de control y comandos botnet;

c) examinar los informes de uso de los proveedores de servicios (por ejemplo, facturas o informes de servicio) para determinar si hay actividad inusual en los sistemas y las redes (por ejemplo, revisando los patrones de actividad);

d) incluye registros de eventos de monitoreo físico, como entrada y salida, para Asegurar una detección y análisis de incidentes más precisos;

e) correlacionar registros para permitir un análisis eficiente y muy preciso.

Los incidentes de seguridad de la información sospechosos y reales deberían identificarse (por ejemplo, infección por programa maligno o sondeo de firewalls) y estar sujetos a una investigación más exhaustiva (por ejemplo, como parte de un proceso de gestión de incidentes de seguridad de la información, véase el numeral 5,25).

Otra información

Los registros del sistema suelen contener un gran volumen de información, gran parte de la cual es ajena a la supervisión de la seguridad de la información. Para ayudar a identificar eventos significativos

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

con fines de supervisión de la seguridad de la información, se puede considerar el uso de programas de utilidad o herramientas de auditoría adecuados para realizar la interrogación de archivos.

El registro de eventos sienta las bases de los sistemas de supervisión automatizados (véase el numeral 8,16), que son capaces de generar informes consolidados y alertas sobre la seguridad del sistema.

Se puede utilizar una herramienta SIEM o un servicio equivalente para almacenar, correlacionar, normalizar y analizar la información de registro, así como para generar alertas. Los SIEM tienden a requerir una configuración cuidadosa para optimizar sus beneficios. Las configuraciones a considerar incluyen identificación y selección de fuentes de registro apropiadas, ajuste y prueba de reglas y desarrollo de casos de uso.

Los archivos de transparencia pública para el registro de registros se utilizan, por ejemplo, en sistemas de transparencia de certificados. Estos archivos pueden proporcionar un mecanismo de detección adicional útil para proteger contra la manipulación de registros.

En los entornos de nube, las responsabilidades de gestión de registros se pueden compartir entre el cliente del servicio de nube y el proveedor de servicios de nube. Las responsabilidades varían en función del tipo de servicio en la nube que se utilice. En la norma ISO/IEC 27017 se puede encontrar más información.

8.16 Actividades de monitoreo

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Detección #Corrección	#Confidencialidad #Integridad #Disponibilidad	#Detección #Respuesta	#Gestión de eventos de seguridad de la información	#Defensa

Control

Las redes, los sistemas y las aplicaciones deberían ser monitoreados para detectar comportamientos anómalos y tomar las medidas apropiadas para evaluar posibles incidentes de seguridad de la información.

Objetivo

Detectar comportamientos anómalos y posibles incidentes de seguridad de la información.

Guía

El alcance y el nivel de supervisión deberían determinarse de conformidad con los requisitos de seguridad de la empresa y la información y tomando en consideración las leyes y reglamentos pertinentes. Los registros de supervisión deberían mantenerse para los períodos de retención definidos.

Se debería considerar la inclusión de los siguientes elementos en el sistema de supervisión:

a) tráfico de red, sistema y aplicaciones salientes y entrantes;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) acceso a sistemas, servidores, equipos de red, sistema de supervisión, aplicaciones críticas, etc.;

c) archivos de configuración del sistema y de la red de nivel crítico o administrativo;

d) Registros de herramientas de seguridad [por ejemplo, antivirus, IDS, sistema de prevención de intrusiones (IPS), filtros web, firewalls, prevención de fugas de datos];

e) registros de eventos relacionados con la actividad del sistema y de la red;

f) comprobar que el código que se está ejecutando está autorizado a ejecutarse en el sistema y que no se ha manipulado (por ejemplo, mediante recompilación para añadir código no deseado adicional);

g) uso de los recursos (por ejemplo, CPU, discos duros, memoria, ancho de banda) y su rendimiento.

La organización debería establecer una línea de base de comportamiento normal y vigilar contra esta línea de base para detectar anomalías. Al establecer una línea base, se debería tener en cuenta lo siguiente:

a) revisar la utilización de los sistemas en períodos normales y máximos;

b) hora habitual de acceso, ubicación del acceso, frecuencia de acceso para cada usuario o grupo de usuarios.

El sistema de supervisión debería configurarse con respecto a la línea base establecida para identificar el comportamiento anómalo, como:

a) terminación no planificada de procesos o aplicaciones;

b) Actividad normalmente asociada con malware o tráfico procedente de direcciones IP o dominios de red maliciosos conocidos (por ejemplo, , los asociados con los servidores de comando y control de botnet);

c) características de ataque conocidas (por ejemplo, denegación de servicio y desbordamientos de búfer);

d) comportamiento inusual del sistema (por ejemplo, registro de pulsaciones de teclas, inyección de procesos y desviaciones en el uso de protocolos estándar);

e) cuellos de botella y sobrecargas (por ejemplo, colas de red, niveles de latencia y fluctuación de red);

f) acceso no autorizado (real o tentativo) a sistemas o información;

g) análisis no autorizado de aplicaciones, sistemas y redes del negocioes;

h) intentos correctos e incorrectos de acceder a los recursos protegidos (por ejemplo, servidores DNS, portales web y recursos compartidos de archivos);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

i) comportamiento inusual del usuario y del sistema en relación con el comportamiento esperado.

Se debería utilizar el monitoreo continuo a través de una herramienta de monitoreo. El monitoreo debería realizarse en tiempo real o en intervalos periódicos, sujeto a las necesidades y capacidades de la organización. Las herramientas de supervisión deberían incluir la capacidad de gestionar grandes cantidades de datos, adaptarse a un panorama de amenazas en constante cambio y permitir la notificación en tiempo real. Las herramientas también deberían ser capaces de reconocer firmas y datos específicos o patrones de comportamiento de red o aplicaciones.

El software de supervisión automatizada debería configurarse para generar alertas (por ejemplo, mediante consolas de administración, mensajes de correo electrónico o sistemas de mensajería instantánea) basándose en umbrales predefinidos. El sistema de alerta debería ser ajustado y entrenado en la línea de base de la organización para minimizar falsos positivos. El personal debería estar dedicado a responder a las alertas y debería estar debidamente capacitado para interpretar con precisión los posibles incidentes. Debería haber sistemas y procesos redundantes para recibir y responder a las notificaciones de alerta.

Los eventos anormales deberían comunicarse a las partes relevantes para mejorar las siguientes actividades: Auditoría, evaluación de la seguridad, análisis y monitoreo de vulnerabilidades (ver 5,25). Deberían establecerse procedimientos para responder oportunamente a los indicadores positivos del sistema de vigilancia, a fin de minimizar el efecto de los eventos adversos (véase el numeral 5,26) en la seguridad de la información. También deberían establecerse procedimientos para identificar y abordar falsos positivos, incluido el ajuste del software de supervisión para reducir el número de falsos positivos futuros.

Otra información

La supervisión de la seguridad se puede mejorar mediante:

a) aprovechar los sistemas de inteligencia frente a amenazas (véase el numeral 5,7);

b) aprovechar las capacidades de aprendizaje automático e inteligencia artificial;

c) al utilizar listas de bloqueo o listas de permisos;

d) realizar una serie de evaluaciones técnicas de seguridad (por ejemplo, evaluaciones de vulnerabilidad, pruebas de penetración, simulaciones de ciberataques y ejercicios de respuesta cibernética) y utilizar los resultados de estas evaluaciones para ayudar a determinar las líneas de base o el comportamiento aceptable;

e) utilizar sistemas de supervisión del rendimiento para ayudar a establecer y detectar comportamientos anómalos; f) aprovechar los registros en combinación con los sistemas de supervisión.

Las actividades de supervisión se realizan a menudo al utilizar software especializado, como sistemas de detección de intrusiones. Se pueden configurar en una línea de base de las actividades normales, aceptables y esperadas del sistema y de la red.

El monitoreo de comunicaciones anómalas ayuda a identificar botnets (es decir, un conjunto de dispositivos bajo el control malicioso del propietario de botnet, que se suele utilizar para montar

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

ataques distribuidos de denegación de servicio en otros equipos de otras organizaciones). Si el equipo está controlado por un dispositivo externo, existe una comunicación entre el dispositivo infectado y el controlador. Por lo tanto, la organización debería emplear tecnologías para vigilar las comunicaciones anómalas y adoptar las medidas necesarias.

8.17 Sincronización del reloj

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Detección	#Integridad	#Protección #Detección	#Gestión de eventos de seguridad de la información	#Protección #Defensa

Control

Los relojes de los sistemas de procesamiento de información utilizados por la organización deberían sincronizarse con las fuentes de tiempo aprobadas.

Objetivo

Permitir la correlación y el análisis de los eventos relacionados con la seguridad y otros datos registrados y apoyar las investigaciones sobre incidentes de seguridad de la información.

Guía

Se deberían documentar e implementar los requisitos externos e internos de representación de tiempo, sincronización fiable y precisión. Tales requisitos pueden ser legales, legales, reglamentarias, contractuales, de normas y de supervisión interna. Se debería definir y considerar un tiempo de referencia estándar para su uso dentro de la organización para todos los sistemas, incluidos los sistemas de gestión de edificios, los sistemas de entrada y salida y otros que puedan utilizarse para ayudar en las investigaciones.

Un reloj vinculado a una emisión de hora de radio desde un reloj atómico nacional o un sistema de posicionamiento global (GPS) debería utilizarse como reloj de referencia para los sistemas de registro; una fuente de fecha y hora coherente y fiable para Asegurar la precisión de las marcas de hora. Los protocolos como el protocolo de hora de red (NTP) o el protocolo de hora de precisión (PTP) deberían utilizarse para mantener todos los sistemas conectados en red sincronizados con un reloj de referencia.

La organización puede utilizar dos fuentes de tiempo externas al mismo tiempo para mejorar la fiabilidad de los relojes externos y gestionar de forma adecuada cualquier variación.

La sincronización del reloj puede ser difícil cuando se utilizan varios servicios en la nube o cuando se utilizan servicios en la nube y en las instalaciones. En este caso, se debería supervisar el reloj de cada servicio y registrar la diferencia para mitigar los riesgos derivados de las discrepancias.

Otra información

La configuración correcta de los relojes de computador es importante para Asegurar la precisión de los registros de eventos, que puede ser requerido para investigaciones o como evidencia en casos

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

legales y disciplinarios. Los registros de auditoría inexactos pueden obstaculizar dichas investigaciones y dañar la credibilidad de dichas pruebas.

8.18 Uso de programas de utilidad privilegiados

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_del_sistema_y_de_la_red #Configuración_segura #Seguridad_de_las_aplicaciones	#Protección

Control

El uso de programas de utilidad que pueden ser capaces de anular los controles del sistema y de las aplicaciones debería estar restringido y controlado de forma estricta.

Objetivo

Asegurar que el uso de programas de utilidad no perjudique los controles del sistema y de las aplicaciones para la seguridad de la información.

Guía

Se deberían tener en cuenta las siguientes directrices para el uso de programas de utilidad que pueden ser capaces de anular los controles del sistema y de la aplicación:

a) limitación del uso de programas de utilidad al número mínimo práctico de usuarios confiables y autorizados (Véase el numeral 8.2);

b) el uso de procedimientos de identificación, autenticación y autorización para programas de utilidad, incluyendo la identificación única de la persona que utiliza el programa de utilidad;

c) definir y documentar los niveles de autorización para los programas de utilidad;

d) autorización para el uso ad hoc de programas de utilidad;

e) no poner los programas de utilidad a disposición de los usuarios que tengan acceso a las aplicaciones en sistemas donde se requiera la separación de tareas;

f) eliminar o desactivar todos los programas de utilidad innecesarios;

g) como mínimo, la segregación lógica de los programas de utilidad del software de aplicación. Cuando sea práctico, separar las comunicaciones de red para dichos programas del tráfico de aplicaciones;

h) limitación de la disponibilidad de los programas de utilidad (por ejemplo, durante la duración de un cambio autorizado);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

i) registro de todo uso de programas de utilidad.

Otra información

La mayoría de los sistemas de información tienen uno o más programas de utilidad que pueden ser capaces de anular los controles del sistema y de las aplicaciones, por ejemplo, diagnósticos, parches, antivirus, desfragmentadores de disco, depuradores, backup y herramientas de red.

8.19 Instalación de software en sistemas operativos

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Configuración_segura #Seguridad_de_las_aplicaciones	#Protección

Control

Deberían implementarse procedimientos y medidas para administrar de forma segura la instalación de software en sistemas operativos.

Objetivo

Asegurar la integridad de los sistemas operativos y evitar la explotación de las vulnerabilidades técnicas.

Guía

Se debería tener en cuenta las siguientes directrices para gestionar de forma segura los cambios y la instalación del software en los sistemas operativos:

a) realizar actualizaciones del software operativo solo por parte de administradores formados con la autorización de administración adecuada (véase el numeral 8,5);

b) Asegurar que solo se instala código ejecutable aprobado y ningún código de desarrollo o compiladores en los sistemas operativos;

c) solo instalar y actualizar el software después de realizar pruebas exhaustivas y satisfactorias (véase el numeral 8,29 y 8,31);

d) actualizar todas las bibliotecas de origen de programas correspondientes;

e) utilizar un sistema de control de configuración para mantener el control de todo el software operativo, así como de la documentación del sistema;

f) definir una estrategia de reversión antes de implementar los cambios;

g) mantener un registro de auditoría de todas las actualizaciones del software operativo;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

h) archivado de versiones antiguas de software, junto con toda la información y parámetros necesarios, procedimientos, detalles de configuración y software de soporte como medida de contingencia y durante el tiempo que el software sea necesario para leer o procesar datos archivados.

Cualquier decisión de actualizar a una nueva versión debería tener en cuenta los requisitos del negocioes para el cambio y la seguridad de la versión (por ejemplo, la introducción de nuevas funciones de seguridad de la información o el número y la gravedad de las vulnerabilidades de seguridad de la información que afectan a la versión actual). Los parches de software se deberían aplicar cuando puedan ayudar a eliminar o reducir las vulnerabilidades de seguridad de la información (véase el numeral 8,8 y 8,19).

El software informático puede basarse en software y paquetes suministrados externamente (por ejemplo, programas de software que utilizan módulos alojados en sitios externos), que debería monitorearse y controlarse para evitar cambios no autorizados ya que pueden introducir vulnerabilidades de seguridad de la información.

El software suministrado por el proveedor y utilizado en los sistemas operativos debería mantenerse a un nivel respaldado por el proveedor. Con el tiempo, los proveedores de software dejarán de admitir versiones anteriores de software. La organización debería considerar los riesgos de confiar en software no compatible. El software de código abierto utilizado en los sistemas operativos debería mantenerse en la última versión apropiada del software. Con el tiempo, el código de código abierto puede dejar de mantenerse, pero sigue estando disponible en un repositorio de software de código abierto. La organización también debería considerar los riesgos de depender de software de código abierto no mantenido cuando se utiliza en sistemas operativos.

Cuando los proveedores participan en la instalación o actualización de software, el acceso físico o lógico solo debería darse cuando sea necesario y con la autorización adecuada. Es preciso monitorear las actividades del proveedor (véase el numeral 5,22).

La organización debería definir y aplicar reglas estrictas sobre los tipos de software que los usuarios pueden instalar.

El principio de privilegio mínimo debería aplicarse a la instalación de software en sistemas operativos. La organización debería identificar qué tipos de instalaciones de software están permitidas (por ejemplo, actualizaciones y parches de seguridad para el software existente) y qué tipos de instalaciones están prohibidas (por ejemplo, software que solo es para uso personal y software cuyo origen con respecto a ser potencialmente malintencionado es desconocido o sospechoso). Estos privilegios deberían concederse en función de las funciones de los usuarios afectados.

Otra información

No hay más información.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

8.20 Seguridad de las redes

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención #Detección	#Confidencialidad #Integridad #Disponibilidad	#Protección #Detección	#Seguridad del sistema y de las redes	#Protección

Control

Las redes y los dispositivos de red deberían estar protegidos, gestionados y controlados para proteger la información de los sistemas y las aplicaciones.

Objetivo

Proteger la información de las redes y sus instalaciones de procesamiento de información de apoyo frente a riesgos a través de la red.

Guía

Deberían implementarse controles para Asegurar la seguridad de la información en las redes y para proteger los servicios conectados del acceso no autorizado. Especialmente, se deberían tomar en consideración los siguientes factores:

a) el tipo y el nivel de clasificación de la información que admite la red;

b) establecer responsabilidades y procedimientos para la gestión de equipos y dispositivos de red;

c) mantener documentación actualizada, incluidos diagramas de red y archivos de configuración de dispositivos (por ejemplo, routers, switches);

d) Separar la responsabilidad operativa de las redes de las operaciones de los sistemas de TIC cuando proceda (Véase el numeral 5.3);

e) establecer controles para salvaguardar la confidencialidad e integridad de los datos que pasan a través de redes públicas, redes de terceros o redes inalámbricas y proteger los sistemas y aplicaciones conectados (véanse 5,22, 8,24, 5,14 y 6,6). También pueden ser necesarios controles adicionales para mantener la disponibilidad de los servicios de red y de los computadores conectados a la red;

f) registro y supervisión adecuados para permitir el registro y la detección de acciones que puedan afectar o sean relevantes para la seguridad de la información (véase el numeral 8,16 y 8,15);

g) coordinar estrechamente las actividades de gestión de la red tanto para optimizar el servicio a la organización como para Asegurar que los controles se aplican de forma coherente en toda la infraestructura de procesamiento de la información;

h) autenticación de sistemas en la red;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

i) restringir y filtrar la conexión de los sistemas a la red (por ejemplo, mediante firewalls);

j) detectar, restringir y autenticar la conexión de equipos y dispositivos a la red;

k) refuerzo de los dispositivos de red;

l) separar los canales de administración de red de otro tráfico de red;

m) aislar temporalmente subredes críticas (por ejemplo, con puentes levadizos) si la red está siendo atacada;

n) desactivación de protocolos de red vulnerables.

La organización debería asegurarse de que se aplican controles de seguridad adecuados al uso de redes virtualizadas. Las redes virtualizadas también abarcan redes definidas por software (SDN, SD-WAN). Las redes virtualizadas pueden ser deseables desde el punto de vista de la seguridad ya que pueden permitir la separación lógica de la comunicación en redes físicas, especialmente para sistemas y aplicaciones que se implementan mediante informática distribuida.

Otra información

Puede encontrar información adicional sobre la seguridad de la red en la serie ISO/IEC 27033. En la ISO/IEC 23167 se puede encontrar información sobre redes virtualizadas.

8.21 Seguridad de los servicios de red

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad del sistema y de las redes	#Protección

Control

Deberían identificarse, implementarse y supervisarse los mecanismos de seguridad, los niveles de servicio y los requisitos de servicio de los servicios de red.

Objetivo

Asegurar la seguridad en el uso de los servicios de red.

Guía

Las medidas de seguridad necesarias para determinados servicios, como las características de seguridad, los niveles de servicio y los requisitos de servicio, deberían ser identificadas e implementadas (por proveedores de servicios de red internos o externos). La organización debería asegurarse de que los proveedores de servicios de red implementan estas medidas.

La capacidad del proveedor de servicios de red para gestionar los servicios acordados de forma segura debería determinarse y supervisarse regularmente. El derecho a la auditoría debería acordarse entre

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

la organización y el proveedor. La organización también debería tener en cuenta los certificados de terceros proporcionados por los proveedores de servicios para demostrar que mantienen las medidas de seguridad adecuadas.

Deberían formularse y aplicarse normas sobre la utilización de las redes y los servicios de red para abarcar:

a) las redes y los servicios de red a los que se puede acceder;

b) requisitos de autenticación para acceder a diversos servicios de red;

c) procedimientos de autorización para determinar quién puede acceder a qué redes y servicios en red;

d) gestión de redes y controles y procedimientos tecnológicos para proteger el acceso a las conexiones de red y a los servicios de red;

e) Los medios utilizados para acceder a las redes y los servicios de red [por ejemplo, el uso de la red privada virtual (VPN) o la red inalámbrica];

f) hora, ubicación y otros atributos del usuario en el momento del acceso;

g) monitoreo del uso de los servicios de red.

Se debería tener en cuenta las siguientes características de seguridad de los servicios de red:

a) tecnología aplicada para la seguridad de los servicios de red, como la autenticación, el cifrado y los controles de conexión de red;

b) parámetros técnicos necesarios para una conexión segura con los servicios de red de acuerdo con las normas de seguridad y conexión de red;

c) almacenamiento en caché (por ejemplo, en una red de distribución de contenido) y sus parámetros que permiten a los usuarios elegir el uso del almacenamiento en caché de acuerdo con los requisitos de rendimiento, disponibilidad y confidencialidad;

d) procedimientos para el uso del servicio de red para restringir el acceso a servicios o aplicaciones de red, cuando sea necesario.

Otra información

Los servicios de red incluyen el suministro de conexiones, servicios de red privada y soluciones de seguridad de red administradas, como firewalls y sistemas de detección de intrusiones. Estos servicios pueden variar desde un ancho de banda simple no administrado hasta ofertas complejas de valor añadido.

En la norma ISO/IEC 29146 se ofrecen más directrices sobre un marco para la gestión del acceso.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

8.22 Segregación de redes

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad del sistema y de las redes	#Protección

Control

Los grupos de servicios de información, usuarios y sistemas de información deberían separarse en las redes de la organización.

Objetivo

Dividir la red en límites de seguridad y controlar el tráfico entre ellos en función de las necesidades de la empresa.

Guía

La organización debería considerar la gestión de la seguridad de las grandes redes dividiéndolas en dominios de red separados y separándolas de la red pública (es decir, Internet). Los dominios se pueden elegir en función de los niveles de confianza, criticidad y sensibilidad (por ejemplo, dominio de acceso público, dominio de escritorio, dominio de servidor, sistemas de bajo y alto riesgo), a lo largo de las unidades organizativas (por ejemplo, recursos humanos, finanzas, marketing) o alguna combinación (por ejemplo, dominio de servidor que se conecta a varias unidades organizativas). La segregación se puede realizar al utilizar redes físicamente diferentes o al utilizar redes lógicas diferentes.

El perímetro de cada dominio debería estar bien definido. Si se permite el acceso entre dominios de red, se debería controlar en el perímetro mediante una puerta de enlace (por ejemplo, un firewall o un router de filtrado). Los criterios para la segregación de las redes en dominios y el acceso permitido a través de las puertas de enlace deberían basarse en una evaluación de los requisitos de seguridad de cada dominio. La evaluación debería realizarse de acuerdo con la política temática específica sobre control de acceso (véase el numeral 5,15), requisitos de acceso, valor y clasificación de la información procesada y tener en cuenta el costo relativo y el impacto en el desempeño de incorporar una tecnología de pasarela adecuada.

Las redes inalámbricas requieren un tratamiento especial debido al perímetro de red mal definido. El ajuste de la cobertura de radio debería considerarse para la segregación de las redes inalámbricas. Para entornos sensibles, se debería considerar tratar todo el acceso inalámbrico como conexiones externas y separar este acceso de las redes internas hasta que el acceso haya pasado a través de una puerta de enlace de acuerdo con los controles de red (véase el numeral 8,20) antes de conceder acceso a los sistemas internos. La red de acceso inalámbrico para invitados debería separarse de la del personal si el personal solo utiliza dispositivos de punto final de usuario controlados que cumplan las directivas específicas de la organización. El WiFi para invitados debería tener al menos las mismas restricciones que el WiFi para el personal, con el fin de desalentar el uso del WiFi para invitados por parte del personal.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Otra información

Las redes a menudo se extienden más allá de los límites de la organización ya que se forman asociaciones del negocioes que requieren la interconexión o el intercambio de servicios de procesamiento de la información y redes. Estas extensiones pueden aumentar el riesgo de acceso no autorizado a los sistemas de información de la organización que utilizan la red, algunos de los cuales requieren protección de otros usuarios de la red debido a su sensibilidad o criticidad.

8.23 Filtrado web

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad del sistema y de las redes	#Protección

Control

El acceso a sitios web externos debería gestionarse para reducir la exposición a contenido malintencionado.

Objetivo

Para proteger los sistemas contra el peligro de malware y para evitar el acceso a recursos no autorizador de la web.

Guía

La organización debería reducir los riesgos de que su personal acceda a sitios web que contienen información ilegal o que se sabe que contienen virus o material de phishing. Una técnica para lograr esto funciona al bloquear la dirección IP o el dominio de los sitios web en cuestión. Algunos navegadores y tecnologías antimalware lo hacen automáticamente o pueden configurarse para hacerlo.

La organización debería identificar los tipos de sitios web a los que el personal debería o no tener acceso. La organización debería considerar bloquear el acceso a los siguientes tipos de sitios web:

a) sitios web que tengan una función de carga de información a menos que se permita por razones comerciales válidas;

b) sitios web maliciosos conocidos o sospechosos (por ejemplo, aquellos que distribuyen contenido de malware o phishing);

c) servidores de comando y control;

d) sitio web malicioso adquirido de inteligencia contra amenazas (véase el numeral 5,7);

e) sitios web que comparten contenido ilegal.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Antes de implementar este control, la organización debería establecer reglas para un uso seguro y apropiado de recursos en línea, incluida cualquier restricción a sitios web indeseables o inadecuados y aplicaciones basadas en web. Las normas debería mantenerse actualizadas.

Se debería impartir capacitación al personal sobre el uso seguro y adecuado de los recursos en línea, incluido el acceso a la Web. La formación debería incluir las reglas de la organización, el punto de contacto para plantear problemas de seguridad y el proceso de excepción cuando se necesite acceder a recursos web restringidos por razones del negocioes legítimas. También se debería impartir formación al personal para asegurarse de que no anulan ningún aviso del navegador que informe de que un sitio web no es seguro, pero que permite al usuario continuar.

Otra información

El filtrado web puede incluir una serie de técnicas, entre las que se incluyen firmas, heurística, lista de sitios web o dominios aceptables, lista de sitios web o dominios prohibidos y configuración personalizada para ayudar a evitar que software malintencionado y otras actividades maliciosas ataquen la red y los sistemas de la organización.

8.24 Uso de cifrado

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Configuración_segura	#Protección

Control

Se deberían definir e implementar reglas para el uso efectivo de la criptografía, incluida la administración de claves cifradas.

Objetivo

Asegurar el uso adecuado y efectivo del cifrado para proteger la confidencialidad, autenticidad o integridad de la información de acuerdo con los requisitos de seguridad de la empresa y la información y tomando en consideración los requisitos legales, estatutarios, reglamentarios y contractuales relacionados con el cifrado.

Guía

General

Al utilizar el cifrado, se debería tener en cuenta lo siguiente:

a) la directiva específica del tema sobre cifrado definida por la organización, incluidos los principios generales para la protección de la información. Es necesaria una política específica sobre el uso del cifrado para maximizar los beneficios y minimizar los riesgos de utilizar técnicas de cifrado y evitar un uso inapropiado o incorrecto;

b) identificar el nivel de protección requerido y la clasificación de la información y, en consecuencia, establecer el tipo, la fuerza y la calidad de los algoritmos cifrados necesarios;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

c) el uso del cifrado para la protección de la información contenida en dispositivos finales de usuario móvil o medios de almacenamiento y transmitida a través de redes a dichos dispositivos o medios de almacenamiento;

d) el enfoque de la gestión de claves, incluidos los métodos para tratar la generación y protección de claves cifradas y la recuperación de información cifrada en caso de pérdida, compromiso o daño de claves;

e) funciones y responsabilidades para:

1) la implementación de las reglas para el uso efectivo del cifrado;

2) la gestión de claves, incluida la generación de claves (véase el numeral 8,24);

f) los estándares que se van a adoptar, así como los algoritmos cifrados, la fuerza del cifrado, las soluciones cifradas y las prácticas de uso aprobadas o requeridas para su uso en la organización;

g) el impacto del uso de información cifrada en controles que dependen de la inspección de contenido (por ejemplo, detección de malware o filtrado de contenido).

Al implementar las reglas de la organización para el uso efectivo del cifrado, se deberían tener en cuenta las regulaciones y restricciones nacionales que pueden aplicarse al uso de técnicas de cifrado en diferentes partes del mundo, así como los temas del flujo transfronterizo de información cifrada (ver 5,31).

El contenido de los acuerdos de nivel de servicio o contratos con proveedores externos de servicios cifrados (por ejemplo, con una autoridad de certificación) debería abarcar cuestiones de responsabilidad, fiabilidad de los servicios y tiempos de respuesta para la prestación de servicios (véase el numeral 5,22).

Gestión de claves

La gestión de claves adecuada requiere procesos seguros para generar, almacenar, archivar, recuperar, distribuir, retirar y destruir claves cifradas.

Un sistema de gestión de claves debería basarse en un conjunto acordado de normas, procedimientos y métodos seguros para:

a) generar claves para diferentes sistemas de cifrado y diferentes aplicaciones;

b) emitir y obtener certificados de clave pública;

c) distribuir claves a las entidades previstas, incluido cómo activar las claves cuando se reciben;

d) almacenamiento de claves, incluida la forma en que los usuarios autorizados obtienen acceso a las claves;

e) cambiar o actualizar claves, incluidas las reglas sobre cuándo cambiar claves y cómo se hará esto; f) tratar con claves comprometidas;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

g) revocación de claves, incluido cómo retirar o desactivar claves [por ejemplo, cuando las claves se han puesto en peligro o cuando un usuario abandona una organización (en cuyo caso las claves también deberían archivarse)];

h) recuperar claves que se pierden o están dañadas;

i) copia de seguridad o archivado de claves;

j) destruir claves;

k) registro y auditoría de actividades relacionadas con la gestión clave;

l) establecer las fechas de activación y desactivación de las claves para que solo se puedan utilizar durante el período de tiempo de acuerdo con las reglas de la organización sobre la gestión de claves;

m) gestionar solicitudes legales de acceso a claves cifradas (por ejemplo, se puede requerir que la información cifrada esté disponible en forma no cifrada como prueba en un caso judicial).

Todas las claves cifradas deberían estar protegidas contra modificaciones y pérdidas. Además, las claves secretas y privadas necesitan protección contra el uso no autorizado, así como la divulgación. El equipo utilizado para generar, almacenar y archivar claves debería estar físicamente protegido.

Además de la integridad, en muchos casos de uso, también debería considerarse la autenticidad de las claves públicas.

Otra información

La autenticidad de las claves públicas se suele abordar mediante procesos de administración de claves públicas mediante autoridades de certificación y certificados de claves públicas, pero también es posible abordarla mediante tecnologías como la aplicación de procesos manuales para claves de número pequeño.

El cifrado se puede utilizar para lograr diferentes objetivos de seguridad de la información, por ejemplo:

a) confidencialidad: utilizar el cifrado de la información para proteger la información confidencial o crítica, almacenada o transmitida;

b) integridad o autenticidad: utilizar firmas digitales o códigos de autenticación de mensajes para verificar la autenticidad o integridad de la información confidencial o crítica almacenada o transmitida. El uso de algoritmos para la comprobación de la integridad de los archivos;

c) no rechazo: utilizar técnicas de cifrado para proporcionar pruebas de la ocurrencia o no ocurrencia de un evento o acción;

d) autenticación: uso de técnicas de cifrado para autenticar usuarios y otras entidades del sistema que soliciten acceso o realicen transacciones con usuarios, entidades y recursos del sistema.

La serie ISO/IEC 11770 proporciona más información sobre la gestión de claves.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

8.25 Ciclo de vida de desarrollo seguro

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_las_aplicaciones #Seguridad_del_sistema_y_de_la_red	#Protección

Control

Debería establecerse y aplicarse normas para el desarrollo seguro de software y sistemas.

Objetivo

Asegurar que la seguridad de la información se diseña e implementa dentro del ciclo de vida de desarrollo seguro del software y los sistemas.

Guía

El desarrollo seguro es un requisito para crear un servicio, una arquitectura, un software y un sistema seguros. Para lograr esto, se deberían tomar en consideración los siguientes factores:

a) Separación de entornos de desarrollo, pruebas y entornos de producción (véase el numeral 8.31);

b) guía sobre la seguridad en el ciclo de vida de desarrollo de software:

   1) seguridad en la metodología de desarrollo de software (ver 8,28 y 8,27);

   2) directrices de codificación seguras para cada lenguaje de programación utilizado (véase el numeral 8,28);

c) requisitos de seguridad en la fase de especificación y diseño (véase el numeral 5,8);

d) puntos de control de seguridad en los proyectos (véase el numeral 5,8);

e) pruebas de sistema y seguridad, como pruebas de regresión, análisis de código y pruebas de penetración (véase el numeral 8,29); f) repositorios seguros para el código fuente y la configuración (véase el numeral 8,4 y 8,9);

g) seguridad en el control de versiones (véase el numeral 8,32);

h) conocimientos y formación necesarios sobre seguridad de las aplicaciones (véase el numeral 8,28);

i) capacidad de los desarrolladores para prevenir, encontrar y corregir vulnerabilidades (véase el numeral 8,28);

j) requisitos de licencia y alternativas para Asegurar soluciones rentables y evitar futuros problemas de licencia (véase el numeral 5,32).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Si se subcontrata el desarrollo, la organización debería obtener la garantía de que el proveedor cumple con las reglas de desarrollo seguro de la organización (véase el numeral 8,30).
Otra información

El desarrollo también puede tener lugar dentro de aplicaciones, como aplicaciones de oficina, secuencias de comandos, exploradores y bases de datos.

8.26 Requisitos de seguridad de la información

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_las_aplicaciones #Seguridad_del_sistema_y_de_la_red	#Protección #Defensa

Control

Los requisitos de seguridad de la información deberían ser identificados, especificados y aprobados al desarrollar o adquirir aplicaciones.

Objetivo

Asegurar que todos los requisitos de seguridad de la información se identifican y se abordan al desarrollar o adquirir aplicaciones.

Guía

General

Se debería identificar y especificar los requisitos de seguridad de las aplicaciones. Estos requisitos se determinan generalmente a través de una evaluación de riesgos. Los requisitos deberían elaborarse con el apoyo de especialistas en seguridad de la información.

Los requisitos de seguridad de las aplicaciones pueden abarcar una amplia gama de temas, en función del propósito de la aplicación.

Los requisitos de seguridad de las aplicaciones deberían incluir, según corresponda:

a) nivel de confianza en la identidad de las entidades [por ejemplo, mediante autenticación (véanse 5,17, 8,2 y 8,5)];

b) identificar el tipo de información y el nivel de clasificación que debería procesar la solicitud;

c) necesidad de segregación de acceso y nivel de acceso a los datos y funciones de la aplicación;

d) resiliencia frente a ataques malintencionados o interrupciones no intencionadas [por ejemplo, protección contra desbordamiento de búfer o inyecciones de lenguaje de consulta estructurado (SQL)];

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

e) requisitos legales, estatutarios y reglamentarios en la jurisdicción donde se genera, procesa, completa o almacena la transacción;

f) necesidad de privacidad asociada a todas las partes implicadas;

g) los requisitos de protección de cualquier información confidencial;

h) protección de datos mientras se procesan, en tránsito y en reposo;

i) necesidad de cifrar de forma segura las comunicaciones entre todas las partes implicadas;

j) controles de entrada, incluidas las comprobaciones de integridad y la validación de entrada;

k) controles automatizados (por ejemplo, límites de aprobación o aprobaciones dobles);

l) controles de salida, considerando también quién puede acceder a los resultados y su autorización;

m) restricciones en torno al contenido de campos de texto libre ya que pueden conducir a un almacenamiento incontrolado de datos confidenciales (por ejemplo, datos personales);

n) los requisitos derivados del proceso de negocio, como el registro y la supervisión de las transacciones, los requisitos de no rechazo;

o) requisitos exigidos por otros controles de seguridad (por ejemplo, interfaces para el registro y el monitoreo o sistemas de detección de fugas de datos);

p) manejo de mensajes de error.

Servicios transaccionales

Adicionalmente, para las aplicaciones que ofrecen servicios transaccionales entre la organización y un socio, se debería considerar lo siguiente al identificar los requisitos de seguridad de la información:

a) el nivel de confianza que cada parte requiere en la identidad declarada de la otra;

b) el nivel de confianza requerido en la integridad de la información intercambiada o procesada y los mecanismos para identificar la falta de integridad (por ejemplo, comprobación de redundancia cíclica, hashing, firmas digitales)

c) los procesos de autorización asociados a quién puede aprobar el contenido de los documentos transaccionales clave, emitirlos o firmarlos;

d) la confidencialidad, la integridad, la prueba de envío y de recepción de los documentos clave y el no repudio (por ejemplo, los contratos asociados a los procesos de licitación y de contratación);

e) la confidencialidad e integridad de cualquier transacción (por ejemplo, pedidos, detalles de la dirección de entrega y confirmación de recibos);

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

f) requisitos sobre la duración de la confidencialidad de una transacción;

g) seguros y otros requisitos contractuales.

Aplicaciones de pedidos y pagos electrónicos

Asimismo, en el caso de las aplicaciones que implican pedidos y pagos electrónicos, se debería tener en cuenta lo siguiente:

a) los requisitos para mantener la confidencialidad e integridad de la información de los pedidos;

b) el grado de verificación apropiado para comprobar la información de pago suministrada por un cliente;

c) evitar la pérdida o duplicación de la información de las transacciones;

d) el almacenamiento de los datos de las transacciones fuera de cualquier entorno de acceso público (por ejemplo, en una plataforma de almacenamiento existente en la intranet de la organización y no conservada y expuesta en medios de almacenamiento electrónico directamente accesibles desde Internet);

e) cuando se utilice una autoridad de confianza (por ejemplo, para la emisión y el mantenimiento de firmas digitales o certificados digitales), la seguridad esté integrada e incorporada en todo el proceso de gestión de certificados o firmas de extremo a extremo.

Varias de las consideraciones anteriores pueden abordarse mediante la aplicación de la criptografía (véase el numeral 8.24), tomando en consideración los requisitos legales (véanse los numerales 5.31 a 5.36, especialmente el numeral 5.31 para la legislación sobre cifrado).

Otra información

Las aplicaciones accesibles a través de las redes están sujetas a una serie de amenazas relacionadas con la red, como las actividades fraudulentas, los conflictos contractuales o la divulgación de información al público; la transmisión incompleta, el enrutamiento erróneo, la alteración no autorizada de mensajes, la duplicación o la repetición. Por lo tanto, es indispensable realizar evaluaciones de riesgo detalladas y determinar cuidadosamente los controles. Los controles necesarios suelen incluir métodos de cifrado para la autenticación y la seguridad de la transferencia de datos.

Se puede encontrar más información sobre la seguridad de las aplicaciones en la serie ISO/IEC 27034.

8.27 Arquitectura de sistemas seguros y principios de ingeniería

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_las_aplicaciones #Seguridad_del_sistema_y_de_la_red	#Protección

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Control

Los principios para la ingeniería de sistemas seguros deberían establecerse, documentarse, mantenerse y aplicarse a cualquier actividad de desarrollo de sistemas de información.

Objetivo

Asegurar que los sistemas de información se diseñan, implementan y operan de forma segura dentro del ciclo de vida del desarrollo.

Guía

Los principios de ingeniería de seguridad deberían establecerse, documentarse y aplicarse a las actividades de ingeniería de los sistemas de información. La seguridad debería diseñarse en todas las capas de la arquitectura (negocio, datos, aplicaciones y tecnología). La nueva tecnología debería ser analizada para detectar los riesgos de seguridad y el diseño debería ser revisado contra los patrones de ataque conocidos.

Los principios de ingeniería de seguridad proporcionan guía sobre las técnicas de autenticación de usuarios, el control de sesiones seguras y la validación y saneamiento de datos.

Los principios de ingeniería de sistemas seguros deberían incluir el análisis de:

a) la variedad de controles de seguridad necesarios para proteger la información y los sistemas contra las amenazas identificadas;

b) las capacidades de los controles de seguridad para prevenir, detectar o responder a eventos de seguridad;

c) los controles de seguridad específicos que requieren determinados procesos del negocioes (por ejemplo, el cifrado de información sensible, la comprobación de la integridad y la firma digital de la información);

d) dónde y cómo deberían aplicarse los controles de seguridad (por ejemplo, mediante la integración con una arquitectura de seguridad y la infraestructura técnica);

e) cómo funcionan los controles de seguridad individuales (manuales y automáticos) para producir un conjunto integrado de controles.

Los principios de ingeniería de seguridad deberían tener en cuenta:

a) la necesidad de integrarse con una arquitectura de seguridad;

b) infraestructura técnica de seguridad [por ejemplo, infraestructura de clave pública (PKI), gestión de la identidad y el acceso (IAM), prevención de la fuga de datos y gestión dinámica del acceso];

c) capacidad de la organización para desarrollar y apoyar la tecnología elegida;

d) el costo, el tiempo y la complejidad de cumplir con los requisitos de seguridad;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

e) las buenas prácticas actuales.

La ingeniería de sistemas seguros debería incluir:

a) el uso de principios de arquitectura de seguridad, como "seguridad por diseño", "defensa en profundidad", "seguridad por defecto", "denegación por defecto", "falla segura", "desconfianza en la entrada de aplicaciones externas", "seguridad en el despliegue", "asumir el incumplimiento", "mínimo privilegio", "usabilidad y manejabilidad" y "mínima funcionalidad";

b) una revisión del diseño centrada en la seguridad para ayudar a identificar las vulnerabilidades de la seguridad de la información, Asegurar que se especifican los controles de seguridad y cumplir con los requisitos de seguridad;

c) la documentación y el reconocimiento formal de los controles de seguridad que no cumplen plenamente los requisitos (por ejemplo, debido a requisitos de seguridad imperativos);

d) fortalecimiento de los sistemas.

La organización debería considerar los principios de "confianza cero", tales como

a) asumir que los sistemas de información de la organización ya han sido vulnerados y, por tanto, no depender únicamente de la seguridad del perímetro de la red;

b) emplear un enfoque de "nunca confiar y siempre verificar" para el acceso a los sistemas de información;

c) Asegurar que las solicitudes a los sistemas de información estén cifradas de principio a fin;

d) verificar cada solicitud a un sistema de información como si se originara en una red abierta y externa, incluso si estas solicitudes se originan dentro de la organización (es decir, no confiar automáticamente en nada dentro o fuera de sus perímetros);

e) utilizar técnicas de control de acceso dinámico y de "mínimo privilegio" (véanse los numerales 5.15, 5.18 y 8.2). Esto incluye la autenticación y autorización de las solicitudes de información o a los sistemas en función de la información contextual, como la información de autenticación (véase el numeral 5.17), las identidades de los usuarios (véase el numeral 5.16), los datos sobre el dispositivo del usuario y la clasificación de los datos (véase el numeral 5.12);

f) autenticar siempre a los solicitantes y validar siempre las solicitudes de autorización a los sistemas de información sobre la base de información que incluya la información de autenticación (véase el numeral 5.17) y las identidades de los usuarios (véase el numeral 5.16), los datos sobre el dispositivo final del usuario y la clasificación de los datos (véase el numeral 5.12), por ejemplo, aplicando una autenticación fuerte (por ejemplo, multifactorial, véase el numeral 8.5).

Se debería aplicar los principios de ingeniería de seguridad establecidos, cuando sea aplicable, al desarrollo externo de sistemas de información a través de los contratos y otros acuerdos vinculantes entre la organización y el proveedor al que la organización subcontrata. La organización debería

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

asegurarse de que las prácticas de ingeniería de seguridad de los proveedores se ajusten a las necesidades de la organización.

Los principios de ingeniería de seguridad y los procedimientos de ingeniería establecidos debería revisarse periódicamente para Asegurar que contribuyen efectivamente a mejorar los estándares de seguridad dentro del proceso de ingeniería. También debería revisarse periódicamente para Asegurar que se mantienen actualizados en lo que respecta a la lucha contra cualquier nueva amenaza potencial y para que sigan siendo aplicables a los avances en las tecnologías y soluciones que se aplican.

Otra información

Los principios de la ingeniería de seguridad pueden aplicarse al diseño o la configuración de una serie de técnicas, como:

- tolerancia a fallas y otras técnicas de resiliencia;
- segregación (por ejemplo, mediante la virtualización o la contenerización)
- resistencia a la manipulación.

Las técnicas de virtualización segura pueden utilizarse para evitar la interferencia entre las aplicaciones que se ejecutan en el mismo dispositivo físico. Si una instancia virtual de una aplicación se ve comprometida por un atacante, solo esa instancia se ve afectada. El ataque no tiene efecto sobre ninguna otra aplicación o datos.

Las técnicas de resistencia a la manipulación pueden utilizarse para detectar la manipulación de contenedores de información ya sean físicos (por ejemplo, una alarma antirrobo) o lógicos (por ejemplo, un archivo de datos). Una característica de estas técnicas es que queda constancia del intento de manipulación del contenedor. Además, el control puede impedir que se extraigan con éxito los datos mediante su destrucción (por ejemplo, se puede borrar la memoria del dispositivo).

8.28 Codificación segura

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_las_aplicaciones #Seguridad del sistema y de la red	#Protección

Control

Los principios de codificación segura se deberían aplicar al desarrollo del software.

Objetivo

Asegurar que el software se escribe de forma segura, lo que reduce el número de posibles vulnerabilidades de seguridad de la información en el software.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Guía

General

La organización debería establecer procesos en toda la organización para proporcionar un buen gobierno para la codificación segura. Debería establecerse y aplicarse una base mínima de seguridad. Además, estos procesos y el gobierno debería ampliarse para cubrir los componentes de software de terceros y el software de código abierto.

La organización debería supervisar las amenazas del mundo real y los consejos e información actualizados sobre las vulnerabilidades del software para guiar los principios de codificación segura de la organización a través de la mejora y el aprendizaje continuos. Esto puede ayudar a Asegurar la aplicación de prácticas eficaces de codificación segura para combatir el cambiante panorama de las amenazas.

Planificación y antes de la codificación

Los principios de codificación segura deberían utilizarse tanto en los nuevos desarrollos como en los escenarios de reutilización. Estos principios deberían aplicarse a las actividades de desarrollo tanto dentro de la organización como para los productos y servicios suministrados por la organización a otros. La planificación y los requisitos previos a la codificación deberían incluir:

a) las expectativas específicas de la organización y los principios aprobados para la codificación segura que se utilizarán tanto para los desarrollos de código internos como para los subcontratados;

b) prácticas de codificación comunes e históricas y defectos que conducen a vulnerabilidades de seguridad de la información;

c) configurar las herramientas de desarrollo, como los entornos de desarrollo integrados (IDE), para ayudar a imponer la creación de código seguro;

d) seguir las directrices emitidas por los proveedores de herramientas de desarrollo y entornos de ejecución, según proceda;

e) mantenimiento y uso de herramientas de desarrollo actualizadas (por ejemplo, compiladores); f) calificación de los desarrolladores en la escritura de código seguro;

g) diseño y arquitectura seguros, incluida la modelización de amenazas;

h) normas de codificación segura y, en su caso obligatoriedad de su uso;

i) uso de entornos controlados para el desarrollo.

Durante la codificación

Las consideraciones durante la codificación deberían incluir:

a) prácticas de codificación segura específicas de los lenguajes y técnicas de programación que se utilicen;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

b) el uso de técnicas de programación seguras, como la programación por parejas, la refactorización, la revisión por pares, las iteraciones de seguridad y el desarrollo basado en pruebas;

c) utilizar técnicas de programación estructurada;

d) documentar el código y eliminar los defectos de programación, que pueden permitir la explotación de las vulnerabilidades de la seguridad de la información;

e) prohibir el uso de técnicas de diseño inseguras (por ejemplo, el uso de contraseñas codificadas, muestras de código no aprobadas y servicios web no autenticados).

Las pruebas deberían realizarse durante y después del desarrollo (véase el numeral 8.29). Los procesos de pruebas estáticas de seguridad de las aplicaciones (SAST) pueden identificar vulnerabilidades de seguridad en el software.

Antes de que el software se ponga en funcionamiento, debería evaluarse lo siguiente:

a) la superficie de ataque y el principio de mínimo privilegio;

b) la realización de un análisis de los errores de programación más comunes y la documentación de que se han mitigado.

Revisión y mantenimiento

Una vez que el código se ha hecho operativo:

a) las actualizaciones deberían ser empaquetadas y desplegadas de forma segura;

b) se deberían tratar las vulnerabilidades de seguridad de la información notificadas (véase el numeral 8.8);

c) los errores y las sospechas de ataques deberían anotarse y los registros deberían revisarse periódicamente para realizar los ajustes necesarios en el código;

d) el código fuente debería estar protegido contra el acceso no autorizado y la manipulación (por ejemplo, mediante el uso de herramientas de gestión de la configuración, que suelen ofrecer funciones como el control de acceso y el control de versiones).

Si se utilizan herramientas y bibliotecas externas, la organización debería considerar:

a) asegurarse de que las bibliotecas externas se gestionan (por ejemplo, mediante el mantenimiento de un inventario de las bibliotecas utilizadas y sus versiones) y que se actualizan regularmente con los ciclos de lanzamiento;

b) la selección, la autorización y la reutilización de componentes bien examinados, en particular los componentes de autenticación y cifrado;

c) la licencia, la seguridad y el historial de los componentes externos;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

d) la garantía de que el software es mantenible, tiene un seguimiento y procede de fuentes acreditadas y de confianza;

e) la disponibilidad a largo plazo de los recursos y artefactos de desarrollo.

Cuando sea necesario modificar un paquete de software, debería tenerse en cuenta los siguientes puntos:

a) el riesgo de que los controles incorporados y los procesos de integridad se vean comprometidos;

b) la posibilidad de obtener el consentimiento del proveedor;

c) la posibilidad de obtener los cambios necesarios del proveedor como actualizaciones estándar del programa;

d) el impacto si la organización se hace responsable del futuro mantenimiento del software como resultado de los cambios;

e) la compatibilidad con otros programas informáticos en uso.

Otra información

Un principio rector es Asegurar que el código pertinente para la seguridad se invoque cuando sea necesario y sea resistente a las manipulaciones. Los programas instalados a partir de código binario compilado también tienen estas propiedades, pero solo para los datos contenidos en la aplicación. En el caso de los lenguajes interpretados, el concepto solamente funciona cuando el código se ejecuta en un servidor inaccesible para los usuarios y procesos que lo utilizan y que sus datos se guardan en una base de datos igualmente protegida. Por ejemplo, el código interpretado puede ejecutarse en un servicio en la nube donde el acceso al propio código requiere privilegios de administrador. Este acceso de administrador debería estar protegido por mecanismos de seguridad como los principios de administración "justo a tiempo" y la autenticación fuerte. Si el propietario de la aplicación puede acceder a los scripts mediante un acceso remoto directo al servidor, en principio también puede hacerlo un atacante. Los servidores web deberían estar configurados para impedir la navegación por los directorios en estos casos.

La mejor manera de diseñar el código de las aplicaciones es partiendo de la base de que siempre es susceptible de ser atacado, por error o por acción maliciosa. Además, las aplicaciones críticas pueden diseñarse para ser tolerantes a las fallas internos. Por ejemplo, la salida de un algoritmo complejo puede comprobarse para asegurar que se encuentra dentro de los límites de seguridad antes de que los datos se utilicen en una aplicación como una aplicación crítica de seguridad o financiera. El código que realiza las comprobaciones de los límites es sencillo y, por tanto, mucho más fácil de demostrar su corrección.

Algunas aplicaciones web son susceptibles de sufrir una serie de vulnerabilidades introducidas por un diseño y una codificación deficientes, como la inyección en la base de datos y los ataques de scripting entre sitios. En estos ataques, las peticiones pueden ser manipuladas para abusar de la funcionalidad del servidor web.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Puede encontrar más información sobre la evaluación de la seguridad de las TIC en la serie ISO/IEC 15408.

8.29 Pruebas de seguridad en el desarrollo y la aceptación

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_de_las_aplicaciones #Seguridad_de_la_información #Seguridad del sistema y de las redes	#Protección

Control

Los procesos de pruebas de seguridad deberían definirse e implementarse en el ciclo de vida del desarrollo.

Objetivo

Validar si se cumplen los requisitos de seguridad de la información cuando las aplicaciones o el código se despliegan en el entorno de producción.

Guía

Los nuevos sistemas de información, las actualizaciones y las nuevas versiones deberían probarse y verificarse a fondo durante los procesos de desarrollo. Las pruebas de seguridad deberían ser una parte integral de las pruebas de los sistemas o componentes.

Las pruebas de seguridad deberían realizarse en función de un conjunto de requisitos, que pueden expresarse como funcionales o no funcionales. Las pruebas de seguridad deberían incluir pruebas de:

a) funciones de seguridad [por ejemplo, autenticación de usuarios (véase el numeral 8.5), restricción de acceso (véase el numeral 8.3) y uso de cifrado (véase el numeral 8.24);

b) codificación segura (véase el numeral 8.28);

c) configuraciones seguras (véanse los numerales 8.9, 8.20 y 8.22), incluidas las de los sistemas operativos, los cortafuegos y otros componentes de seguridad.

Los planes de pruebas deberían determinarse mediante un conjunto de criterios. El alcance de las pruebas debería ser proporcional a la importancia, la naturaleza del sistema y el impacto potencial del cambio introducido. El plan de pruebas debería incluir:

a) un calendario detallado de actividades y pruebas;

b) las entradas y salidas previstas en una serie de condiciones;

c) criterios para evaluar los resultados;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

d) decisión sobre las acciones posteriores que sean necesarias.

La organización puede aprovechar las herramientas automatizadas, por ejemplo, las herramientas de análisis de código o los escáneres de vulnerabilidad y debería verificar la corrección de los defectos relacionados con la seguridad.

En el caso de los desarrollos internos, estas pruebas deberían ser realizadas inicialmente por el equipo de desarrollo. A continuación, deberían realizarse pruebas de aceptación independientes para Asegurar que el sistema funciona como se espera y solo como se espera (véase el numeral 5.8). Debería tenerse en cuenta lo siguiente:

a) la realización de actividades de revisión del código como elemento relevante para la comprobación de las fallas de seguridad, incluidas las entradas y condiciones no previstas;

b) la realización de escaneos de vulnerabilidad para identificar configuraciones inseguras y vulnerabilidades del sistema;

c) la realización de pruebas de penetración para identificar el código y el diseño inseguros.

En el caso de los componentes de desarrollo y compra subcontratados, debería seguirse un proceso de adquisición. Los contratos con el proveedor debería abordar los requisitos de seguridad identificados (véase el numeral 5.20). Los productos y servicios debería ser evaluados según estos criterios antes de su adquisición.

Las pruebas deberían realizarse en un entorno de pruebas que se ajuste lo más posible al entorno de producción objetivo para Asegurar que el sistema no introduce vulnerabilidades en el entorno de la organización y que las pruebas son fiables (véase el numeral 8.31).

Otra información

Se pueden establecer múltiples entornos de prueba, que se pueden utilizar para diferentes tipos de pruebas (por ejemplo, pruebas funcionales y de rendimiento). Estos diferentes entornos pueden ser virtuales, con configuraciones individuales para simular una variedad de entornos operativos.

También hay que tener en cuenta las pruebas y monitoreo de los entornos de prueba, las herramientas y las tecnologías para Asegurar la eficacia de las pruebas. Las mismas consideraciones se aplican a la supervisión de los sistemas de control desplegados en los entornos de desarrollo, prueba y producción. Es necesario tener criterio, guiado por la sensibilidad de los sistemas y los datos, para determinar cuántas capas de metapruebas son útiles.

8.30 Desarrollo tercerizado

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención #Detección	#Confidencialidad #Integridad #Disponibilidad	#Identificar#Protección #Detección	#Seguridad del sistema y de la red #Seguridad de las aplicaciones #Seguridad de las relaciones con los proveedores	#Gobierno_y_ Ecosistema #Protección

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Control

La organización debería dirigir, monitorear y revisar las actividades relacionadas con el desarrollo de sistemas tercerizados.

Objetivo

Asegurar la aplicación de las medidas de seguridad de la información requeridas por la organización en el desarrollo de sistemas tercerizados.

Guía

En los casos en que el desarrollo del sistema se subcontrata, la organización debería comunicar y acordar los requisitos y expectativas y monitorear y revisar continuamente si la entrega del trabajo subcontratado cumple con estas expectativas. Los siguientes puntos deberían considerarse en toda la cadena de suministro externa de la organización:

a) acuerdos de licencia, propiedad del código y derechos de propiedad intelectual relacionados con el contenido subcontratado (Véase el numeral 5.32);

b) requisitos contractuales para las prácticas de diseño, codificación y pruebas seguras (véanse los numerales 8.25 al 8.29);

c) suministro del modelo de amenaza a considerar por desarrolladores externos;

d) pruebas de aceptación de la calidad y exactitud de los resultados (Véase el numeral 8.29);

e) suministro de pruebas de que se han establecido niveles mínimos aceptables de capacidades de seguridad y privacidad (por ejemplo, informes de garantía)

f) pruebas de que se han realizado pruebas suficientes para evitar la presencia de contenidos maliciosos (tanto intencionados como no intencionados) en el momento de la entrega;

g) pruebas de que se han realizado pruebas suficientes para evitar la presencia de vulnerabilidades conocidas;

h) acuerdos de custodia del código fuente del software (por ejemplo, si el proveedor quiebra);

i) derecho contractual a auditar los procesos y controles de desarrollo;

j) requisitos de seguridad para el entorno de desarrollo(véase el numeral 8.31);

k) tomando en consideración la legislación aplicable (por ejemplo, sobre protección de datos personales).

Otra información

Se puede encontrar más información sobre las relaciones con los proveedores en la serie ISO/IEC 27036.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

8.31 Separación de los entornos de desarrollo, prueba y producción

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_las_aplicaciones #Seguridad_del_sistema_y_de_la_red	#Protección

Control

Los entornos de desarrollo, prueba y producción deberían estar separados y protegidos.

Objetivo

Proteger el entorno de producción y los datos del peligro que suponen las actividades de desarrollo y prueba.

Guía

Debería identificarse y aplicarse el nivel de separación entre los entornos de producción, prueba y desarrollo que es necesario para evitar problemas de producción.

Se deberían tomar en consideración los siguientes factores:

a) separar adecuadamente los sistemas de desarrollo y producción y hacerlos funcionar en dominios diferentes (por ejemplo, en entornos virtuales o físicos separados);

b) definir, documentar y aplicar normas y autorizaciones para el despliegue de software desde el estado de desarrollo al de producción;

c) probar los cambios en los sistemas y aplicaciones de producción en un entorno de prueba o de ensayo antes de aplicarlos a los sistemas de producción (véase el numeral 8.29);

d) que no se realicen pruebas en entornos de producción, salvo en circunstancias definidas y aprobadas;

e) que los compiladores, editores y otras herramientas de desarrollo o programas de utilidad no sean accesibles desde los sistemas de producción cuando no sean necesarios;

f) mostrar etiquetas de identificación del entorno adecuadas en los menús para reducir el riesgo de error;

g) no copiar información sensible en los entornos de los sistemas de desarrollo y de prueba, a menos que se proporcionen controles equivalentes para los sistemas de desarrollo y de prueba.

En todos los casos, los entornos de desarrollo y prueba deberían estar protegidos tomando en consideración:

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

a) la aplicación de parches y la actualización de todas las herramientas de desarrollo, integración y prueba (incluidos constructores, integradores, compiladores, sistemas de configuración y bibliotecas);

b) configuración segura de los sistemas y programas informáticos;

c) control de acceso a los entornos;

d) monitoreo de los cambios en el ambiente y en el código almacenado en el mismo;

e) supervisión segura de los entornos; f) realización de copias de seguridad de los entornos.

Una sola persona no debería tener la capacidad de realizar cambios tanto en el desarrollo como en la producción sin revisión y aprobación previas. Esto puede lograrse, por ejemplo, mediante la separación de los derechos de acceso o mediante reglas supervisadas. En situaciones excepcionales, deberían aplicarse medidas adicionales, como el registro detallado y la supervisión en tiempo real, para detectar los cambios no autorizados y actuar en consecuencia.

Otra información

Sin las medidas y procedimientos adecuados, los desarrolladores y probadores que tienen acceso a los sistemas de producción pueden introducir riesgos significativos (por ejemplo, modificación no deseada de los archivos o del entorno del sistema, fallas del sistema, ejecución de código no autorizado y no probado en los sistemas de producción, divulgación de datos confidenciales, problemas de integridad y disponibilidad de los datos). Es necesario mantener un entorno conocido y estable en el que se puedan realizar pruebas significativas y evitar el acceso inadecuado de los desarrolladores al entorno de producción.

Las medidas y los procedimientos incluyen el diseño cuidadoso de las funciones junto con la aplicación de los requisitos de separación de funciones y el establecimiento de procesos de supervisión adecuados.

El personal de desarrollo y pruebas también supone una amenaza para la confidencialidad de la información de producción. Las actividades de desarrollo y prueba pueden provocar cambios no deseados en el software o la información si comparten el mismo entorno informático. Por lo tanto, es conveniente separar los entornos de desarrollo, pruebas y producción para reducir el riesgo de cambios accidentales o de acceso no autorizado al software de producción y a los datos de la empresa (véase el numeral 8.33 para la protección de la información de pruebas).

En algunos casos, la distinción entre los entornos de desarrollo, prueba y producción puede ser deliberadamente borrosa y las pruebas se pueden llevar a cabo en un entorno de desarrollo o a través de despliegues controlados a usuarios o servidores en vivo (por ejemplo, una pequeña población de usuarios piloto). En algunos casos, las pruebas del producto se pueden realizar mediante el uso en vivo del producto dentro de la organización. Además, para reducir el tiempo de inactividad de los despliegues en vivo, se puede dar soporte a dos entornos de producción idénticos en los que solo uno esté en vivo en un momento dado.

Se requieren procesos de apoyo para el uso de datos de producción en entornos de desarrollo y pruebas (véase el numeral 8.33).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Las organizaciones también pueden tomar en consideración las orientaciones proporcionadas en esta sección para los entornos de formación cuando realicen la formación de los usuarios finales.

8.32 Gestión del cambio

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_las_aplicaciones #Seguridad_del_sistema_y_de_la_red	#Protección

Control

Los cambios en las instalaciones de procesamiento de la información y en los sistemas de información deberían estar sujetos a procedimientos de gestión del cambio.

Objetivo

Para preservar la seguridad de la información al ejecutar los cambios.

Guía

La introducción de nuevos sistemas y de cambios importantes en los sistemas existentes debería seguir unas normas acordadas y un proceso formal de documentación, especificación, pruebas, control de calidad y aplicación gestionada. Debería establecerse responsabilidades y procedimientos de gestión para Asegurar un control satisfactorio de todos los cambios.

Los procedimientos de control de cambios deberían documentarse y aplicarse para Asegurar la confidencialidad, la integridad y la disponibilidad de la información en las instalaciones de procesamiento de la información y en los sistemas de información, para todo el ciclo de vida de desarrollo del sistema, desde las primeras etapas de diseño hasta todos los esfuerzos de mantenimiento posteriores.

Siempre que sea posible, los procedimientos de control de cambios para la infraestructura y el software de las TIC debería estar integrados.

Los procedimientos de control de cambios deberían incluir:

a) planificar y evaluar el impacto potencial de los cambios tomando en consideración todas las dependencias;

b) autorización de cambios;

c) comunicar los cambios a las partes interesadas pertinentes;

d) pruebas y aceptación de pruebas para los cambios (véase el numeral 8.29);

e) aplicación de los cambios, incluidos los planes de despliegue;

f) consideraciones de emergencia y contingencia, incluidos los procedimientos de repliegue;

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

g) mantenimiento de registros de los cambios que incluyan todo lo anterior;

h) Asegurar que la documentación de funcionamiento (véase el numeral 5.37) y los procedimientos de los usuarios se modifiquen según sea necesario para que sigan siendo adecuados;

i) Asegurar que los planes de continuidad de las TIC y los procedimientos de respuesta y recuperación (véase el numeral 5.30) se modifiquen según sea necesario para seguir siendo adecuados.

Otra información

El control inadecuado de los cambios en las instalaciones de procesamiento de la información y en los sistemas de información es una causa común de fallas en el sistema o en la seguridad. Los cambios en el entorno de producción, especialmente cuando se transfiere el software del entorno de desarrollo al operativo, pueden repercutir en la integridad y disponibilidad de las aplicaciones.

Los cambios en el software pueden afectar al entorno de producción y viceversa.

Las buenas prácticas incluyen la comprobación de los componentes de las TIC en un entorno separado de los entornos de producción y desarrollo. (véase el numeral 8.31). Esto proporciona un medio para tener control sobre el nuevo software y permite una protección adicional de la información operativa que se utiliza para fines de prueba. Esto debería incluir parches, paquetes de servicio y otras actualizaciones.

El entorno de producción incluye los sistemas operativos, las bases de datos y las plataformas de middleware. El control debería aplicarse a los cambios de aplicaciones e infraestructuras.

8.33 Información de la prueba

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad	#Proteger	#Protección_de_información	#Protección

Control

La información de las pruebas debería seleccionarse, protegerse y gestionarse adecuadamente.

Objetivo

Asegurar la pertinencia de las pruebas y la protección de la información operativa utilizada para las mismas.

Guía

La información de las pruebas debería seleccionarse para Asegurar la fiabilidad de los resultados de las pruebas y la confidencialidad de la información operativa pertinente. La información sensible

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

(incluida la información de identificación personal) no debería copiarse en los entornos de desarrollo y pruebas (véase el numeral 8.31).

Las siguientes directrices deberían aplicarse para proteger las copias de la información operativa, cuando se utilicen con fines de prueba, tanto si el entorno de prueba se construye internamente como en un servicio en la nube:

a) aplicar a los entornos de prueba los mismos procedimientos de control de acceso que se aplican a los entornos operativos;

b) tener una autorización independiente cada vez que se copie información operativa en un entorno de pruebas;

c) registrar la copia y el uso de la información operativa para proporcionar un registro de auditoría;

d) proteger la información sensible mediante su eliminación o enmascaramiento (véase el numeral 8.11) si se utiliza para las pruebas;

e) eliminar adecuadamente (véase el numeral 8.10) la información operativa de un entorno de prueba inmediatamente después de que se haya completado la prueba para evitar el uso no autorizado de la información de prueba.

La información de las pruebas debería almacenarse de forma segura (para evitar su manipulación, que puede dar lugar a resultados no válidos) y utilizarse únicamente con fines de prueba.

Otra información

Las pruebas de sistemas y de aceptación pueden requerir volúmenes considerables de información de prueba que se acerquen lo más posible a la información operativa.

8.34 Protección de los sistemas de información durante las pruebas de auditoría

Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad del sistema y de la red #Protección de la información	#Gobierno_y_ ecosistema #Protección

Control

Las pruebas de auditoría y otras actividades de garantía que impliquen la evaluación de los sistemas operativos debería planificarse y acordarse entre el encargado de las pruebas y la dirección correspondiente.

Objetivo

Minimizar el impacto de las auditorías y otras actividades de garantía en los sistemas operativos y los procesos del negocioes.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Guía

Deberían observarse las siguientes directrices:

a) acordar las solicitudes de auditoría para el acceso a los sistemas y datos con la dirección correspondiente;

b) acordar y controlar el alcance de las pruebas técnicas de auditoría;

c) limitar las pruebas de auditoría al acceso de solo lectura a los programas y datos. Si no se dispone de acceso de solo lectura para obtener la información necesaria, ejecutar la prueba por un administrador experimentado que tenga los derechos de acceso necesarios en nombre del auditor;

d) si se concede el acceso, establecer y verificar los requisitos de seguridad (por ejemplo, antivirus y parches) de los dispositivos utilizados para acceder a los sistemas (por ejemplo computadores portátiles o tabletas) antes de permitir el acceso;

e) solo permitir el acceso a copias aisladas de los archivos del sistema que no sean de solo lectura y borrarlas una vez finalizada la auditoría o darles la protección adecuada si existe la obligación de conservar dichos archivos en virtud de los requisitos de la documentación de auditoría;

f) identificar y acordar las solicitudes de procesamiento especial o adicional, como la ejecución de herramientas de auditoría;

g) la ejecución de pruebas de auditoría que puedan afectar a la disponibilidad del sistema fuera del horario laboral;

h) supervisar y registrar todos los accesos con fines de auditoría y prueba.

Otra información

Las pruebas de auditoría y otras actividades de aseguramiento también pueden tener lugar en los sistemas de desarrollo y de prueba, donde dichas pruebas pueden afectar, por ejemplo, a la integridad del código o llevar a la divulgación de cualquier información sensible que se encuentre en dichos entornos.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

ANEXO A
(Informativo)

UTILIZACIÓN DE ATRIBUTOS

A.1 GENERAL

Este anexo proporciona una tabla en la que se demuestra el uso de los atributos como forma de crear diferentes vistas de los controles. Los cinco ejemplos de atributos son (véase el numeral 4.2):

a) Tipos de control (#Prevención, #Detección, #Corrección)

b) Propiedades de seguridad de la información (#Confidencialidad, #Integridad, #Disponibilidad)

c) Conceptos de ciberseguridad (#Identificar, #Proteger, #Detectar, #Responder, #Recuperar)

d) Capacidades operativas (#Gobierno, #Gestión_de_activos, #Protección_de_la_información, #Seguridad_de_los_recursos_humanos, #Seguridad_física, #Seguridad_de_los_sistemas_y_las_redes, #Seguridad_de_las_aplicaciones, #Configuración_segura, #Gestión de identidades y accesos, Gestión de amenazas y vulnerabilidades, #Continuidad, #Seguridad de las relaciones con los proveedores, #Legal y cumplimiento, #Gestión de eventos de seguridad de la información, #Aseguramiento de la seguridad de la información)

e) Dominios de seguridad (#Gobierno_y_Ecosistema, #Protección, #Defensa, #Resiliencia) Tabla A.1 contiene una matriz de todos los controles de este documento con los valores de sus atributos.

El filtrado u ordenación de la matriz se puede realizar mediante una herramienta como una simple hoja de cálculo o una base de datos, que puede incluir más información como texto de control, directrices, directrices específicas de la organización o atributos (véase el numeral la tabla A.2).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 Matriz de controles y valores de atributos

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5,1	Políticas de seguridad de la información	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gobierno	#Gobierno_y_Ecosistema #Resiliencia
5.2	Funciones y responsabilidades en materia de seguridad de la información	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gobierno	#Gobierno y ecosistema #Protección #Resiliencia
5.3	Separación de obligaciones	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gobierno #Gestión_de_la_identidad_y_del_acceso	#Gobierno y ecosistema
5.4	Responsabilidades de gestión	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gobierno	#Gobierno y ecosistema
5.5	Contacto con las autoridades	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger #responder #recuperar	#Gobierno	#Defensa #Resiliencia
5.6	Contacto con grupos de interés especiales	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder #Recuperar	#Gobierno	#Defensa
5.7	Inteligencia sobre amenazas	#Prevención #Detección #Corrección	#Confidencialidad #Integridad #Disponibilidad	#Identificación #Detección #Respuesta	#Gestión_de_amenazas_y_de_vulnerabilidades	#Defensa #Resiliencia
5.8	Seguridad de la información en la gestión de proyectos	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger	#Gobierno	#Gobierno_y_Ecosistema #Protección

Continúa…

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.9	Inventario de información y otros activos asociados	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Gestión de activos	#Gobierno_y_Ecosistema #Protección
5.10	Uso aceptable de la información y otros activos asociados	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_activos #Protección_de_la_información	#Gobierno_y_Ecosistema #Protección
5.11	Devolución de activos	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de activos	#Protección
5.12	Clasificación de la información	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Información_protección_	#Protección #Defensa
5.13	Etiquetado de la información	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Información_protección_	#Defensa #Protección
5.14	Transferencia de información;	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_activos #Protección_de_la_información	#Protección
5.15	Control de acceso	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_la_identidad_y_del_acceso	#Protección
5.16	Gestión de la identidad	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_la_identidad_y_del_acceso	#Protección
5.17	Información de autentificación	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_la_identidad_y_del_acceso	#Protección

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.18	Derechos de acceso	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_la_identidad_y_del_acceso	#Protección
5.19	Seguridad de la información en las relaciones con los proveedores	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_de_las_relaciones_con_los_proveedores	#Gobierno_y_Ecosistema #Protección
5.20	Abordar la seguridad de la información en los acuerdos con los proveedores	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_de_las_relaciones_con_los_proveedores	#Gobierno_y_Ecosistema #Protección
5.21	Gestión de la seguridad de la información en la cadena de suministro de las TIC	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_de_las_relaciones_con_los_proveedores	#Gobierno_y_Ecosistema #Protección
5.22	Monitoreo, revisión y gestión de cambios de los servicios de los proveedores	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_de_las_relaciones_con_los_proveedores	#Gobierno_y_Ecosistema #Protección #Defensa #Seguridad_de_la_información
5.23	Seguridad de la información para el uso de servicios en la nube	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_las_relaciones_con_los_proveedores	#Gobierno_y_Ecosistema #Protección

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.24	Planificación y preparación de la gestión de incidentes de seguridad de la información	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Responder #Recuperar	#Gobierno #Gestión de eventos de seguridad de la información	#Defensa
5.25	Evaluación y decisión sobre eventos de seguridad de la información	#Detección	#Confidencialidad #Integridad #Disponibilidad	#Detección #Respuesta	#Gestión de eventos de seguridad de la información	#Defensa
5.26	Respuesta a los incidentes de seguridad de la información	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Responder #Recuperar	#Gestión de eventos de seguridad de la información	#Defensa
5.27	Aprendizaje de los incidentes de seguridad de la información	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger	#Gestión de eventos de seguridad de la información	#Defensa
5.28	Recopilación de pruebas	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Detección #Respuesta	#Gestión de eventos de seguridad de la información	#Defensa
5.29	Seguridad de la información durante la interrupción	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Protección #Respuesta	#Continuidad	#Protección #Resiliencia
5.30	Preparación de las TIC para la continuidad de la actividad	#Correctivo	#Disponibilidad.	#Responder	#Continuidad	#Resiliencia

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.31	Requisitos legales, estatutarios, reglamentarios y contractuales	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Legal_y_cumplimiento	#Gobierno_y_Ecosistema #Protección
5.32	Derechos de propiedad intelectual	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Legal_y_cumplimiento	#Gobierno y ecosistema
5.33	Protección de documentos	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger	#Legal_y_cumplimiento#Gestión_de_activos #Protección_de_la_información	#Defensa
5.34	Privacidad y protección de la IIP	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger	#Protección_de_la_información #Legal_y_cumplimiento	#Protección
5.35	Revisión independiente de la seguridad de la información	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger	#Seguridad_de_la_información	#Gobierno y ecosistema
5.36	Cumplimiento de las políticas, reglas y normas de seguridad de la información	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger	#Legal_y_cumplimiento #Seguridad_de_la_información	#Gobierno_y_ecosistema

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.37	Procedimientos operativos documentados	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Recuperar	#Gestión_de_activos #Seguridad_física #Seguridad_del_sistema_y_de_la_red #Seguridad_de_las_aplicaciones #Configuración_segura #Gestión_de_la_identidad_y_del_acceso #Gestión_de_las_amenazas_y_de_la_vulnerabilidad #Continuidad #Gestión_de_eventos_de_seguridad_de_la_información	#Gobierno_y_Ecosistema #Protección #Defensa
6.1	Selección	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobierno y ecosistema
6.2	Condiciones del empleo	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobierno y ecosistema
6.3	Sensibilización, educación y formación en materia de seguridad de la información	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_de_los_recursos_humanos	#Gobierno y ecosistema
6.4	Proceso disciplinario proceso (process)	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Protección #Respuesta	#Seguridad_de_los_recursos_humanos	#Gobierno y ecosistema
6.5	Responsabilidades tras el cese o el cambio de empleo	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad de los recursos humanos #Gestión de activos	#Gobierno y ecosistema

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
6.6	Acuerdos de confidencialidad o no divulgación	#Prevención	#Confidencialidad	#Proteger	#Seguridad de los recursos humanos #Protección de la información #Relaciones con los proveedores	#Gobierno y ecosistema
6.7	Trabajo remoto	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de activos #Protección de la información #Seguridad física #Seguridad del sistema y de la red	#Protección
6.8	Informes de eventos de seguridad de la información	#Detección	#Confidencialidad #Integridad #Disponibilidad	#Detección	#Gestión de eventos de seguridad de la información	#Defensa
7.1	Perímetros de seguridad física	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad física	#Protección
7.2	Entrada física	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad física #Gestión de la identidad y del acceso	#Protección
7.3	Seguridad de oficinas, salas e instalaciones	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección
7.4	Monitoreo de la seguridad física	#Prevención #Detección	#Confidencialidad #Integridad #Disponibilidad	#Protección #Detección	#Seguridad física	#Protección #Defensa
7.5	Protección contra Amenazas físicas y ambientales	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad física	#Protección
7.6	Trabajo en zonas seguras	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad física	#Protección
7.7	Escritorio limpio y pantalla limpia	#Prevención	#Confidencialidad	#Proteger	#Seguridad física	#Protección

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
7.8	Ubicación y protección de los equipos	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección
7.9	Seguridad de los activos fuera de las instalaciones	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección
7.10	Medios de almacenamiento	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección
7.11	Servicios públicos de respaldo	#Prevención #Detección	#Integridad #Disponibilidad	#Protección #Detección	#Seguridad física	#Protección
7.12	Seguridad del cableado	#Prevención	#Confidencialidad #Disponibilidad	#Proteger	#Seguridad física	#Protección
7.13	Mantenimiento del equipo	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección #Resiliencia
7.14	Eliminación segura o reutilización del equipo	#Prevención	#Confidencialidad	#Proteger	#Seguridad_física #Gestión_de_activos	#Protección
8.1	Dispositivos finales del usuario	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_activos #Protección_de_la_información	#Protección
8.2	Derechos de acceso privilegiados	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_la_identidad_y_del_acceso	#Protección
8.3	Restricción del acceso a la información	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_la_identidad_y_del_acceso	#Protección

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.4	Acceso al código fuente	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión de identidades y accesos #Seguridad_de_las_aplicaciones #Configuración_segura	#Protección
8.5	Autenticación segura	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Gestión_de_la_identidad_y_del_acceso	#Protección
8.6	Gestión de la capacidad	#Prevención #Detección	#Integridad #Disponibilidad	#Identificar #protección #Detección	#Continuidad	#Gobierno_y_Ecosistema #Protección
8.7	Protección contra malware	#Prevención #Detección #Corrección	#Confidencialidad #Integridad #Disponibilidad	#Protección #Detección	#Seguridad_del_sistema_y_de_la_red #Protección_de_la_información	#Protección #Defensa
8.8	Gestión de las vulnerabilidades técnicas	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger	#Gestión_de_amenazas_y_de_vulnerabilidades	#Gobierno_y_Ecosistema #Protección #Defensa
8.9	Gestión de la configuración	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Configuración_segura	#Protección
8.10	Eliminación de información	#Prevención	#Confidencialidad	#Proteger	#Protección_de_la_información #Legal_y_cumplimiento	#Protección
8.11	Enmascaramiento de datos	#Prevención	#Confidencialidad	#Proteger	#Información_protección_	#Protección
8.12	Prevención de la fuga de datos	#Prevención #Detección	#Confidencialidad	#Protección #Detección	#Información_protección_	#Protección #Defensa
8.13	Copia de seguridad de la información	#Correctivo	#Integridad #Disponibilidad	#Recuperar	#Continuidad	#Protección
8.14	Redundancia de las instalaciones de tratamiento de la información	#Prevención	#Disponibilidad.	#Proteger	#Continuidad #Gestión de activos	#Protección #Resiliencia

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.15	Registros	#Detección	#Confidencialidad #Integridad #Disponibilidad	#Detección	#Gestión de eventos de seguridad de la información	#Protección #Defensa
8.16	Actividades de monitoreo	#Detección #Corrección	#Confidencialidad #Integridad #Disponibilidad	#Detección #Respuesta	#Gestión de eventos de seguridad de la información	#Defensa
8.17	Sincronización del reloj	#Detección	#Integridad	#Protección #Detección	#Gestión de eventos de seguridad de la información	#Protección #Defensa
8.18	Uso de programas de utilidad privilegiados	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_del_sistema_y_de_la_red #Seguridad_de_las_aplicaciones #Configuración_segura #Seguridad de las aplicaciones	#Protección
8.19	Instalación de software en sistemas operativos	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Configuración segura #Seguridad de las aplicaciones	#Protección
8.20	Seguridad de las redes	#Prevención #Detección	#Confidencialidad #Integridad #Disponibilidad	#Protección #Detección	#Seguridad del sistema y de las redes	#Protección
8.21	Seguridad de los servicios de redes	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad del sistema y de las redes	#Protección
8.22	Separación de las redes	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad del sistema y de las redes	#Protección
8.23	Filtrado web	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad del sistema y de las redes	#Protección
8.24	Uso de cifrado	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Configuración_segura	#Protección
8.25	Ciclo de vida de desarrollo seguro	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad de las aplicaciones #Seguridad del sistema y de las redes	#Protección

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.26	Requisitos de seguridad de las aplicaciones	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad de las aplicaciones #Seguridad del sistema y de las redes	#Protección #Defensa
8.27	Arquitectura de sistemas seguros y principios de ingeniería	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad de las aplicaciones #Seguridad del sistema y de las redes	#Protección
8.28	Codificación segura	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad de las aplicaciones #Seguridad del sistema y de las redes	#Protección
8.29	Pruebas de seguridad en el desarrollo y la aceptación	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Identificar	#Seguridad_de_las_aplicaciones #Aseguramiento_de_la_información #Seguridad_del_sistema_y_de_la_red	#Protección
8.30	Desarrollo tercerizado	#Prevención #Detección	#Confidencialidad #Integridad #Disponibilidad	#Identificar #protección #Detección	#Seguridad_del_sistema_y_de_la_red #Seguridad_de_las_aplicaciones #Seguridad_de_las_relaciones_con_los_proveedores	#Gobierno_y_Ecosistema #Protección
8.31	Separación de los entornos de desarrollo, prueba y producción	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad de las aplicaciones #Seguridad del sistema y de las redes	#Protección
8.32	Gestión del cambio	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad de las aplicaciones #Seguridad del sistema y de las redes	#Protección
8.33	Información de la prueba	#Prevención	#Confidencialidad #Integridad	#Proteger	#Información_protección_	#Protección

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.1 (Final)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
8.34	Protección de los sistemas de información durante las pruebas de auditoría	#Prevención	#Confidencialidad #Integridad #Disponibilidad	#Proteger	#Seguridad_del_sistema_y_de_la_red #Protección_de_la_información	#Gobierno_y_Ecosistema #Protección

La Tabla A.2 muestra un ejemplo de cómo crear una vista al filtrar por un valor de atributo particular, en este caso #Correctivo.

Tabla A.2 Vista de los controles de #Correctivo

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.5	Contacto con las autoridades	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger #responder #recuperar	#Gobierno	#Defensa #Resiliencia
5.6	Contacto con grupos de interés especiales	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Responder #Recuperar	#Gobierno	#Defensa
5.7	Inteligencia sobre amenazas	#Prevención #Detección #Corrección	#Confidencialidad #Integridad #Disponibilidad	#Identificación #Detección #Respuesta	#Gestión_de_amenazas_y_de_vulnerabilidades	#Defensa #Resiliencia

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.2 (Continuación)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.24	Planificación y preparación de la gestión de incidentes de seguridad de la información	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Responder #Recuperar	#Gobierno #Gestión de eventos de seguridad de la información	#Defensa
5.26	Respuesta a los incidentes de seguridad de la información	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Responder #Recuperar	#Gestión de eventos de seguridad de la información	#Defensa
5.28	Recopilación de pruebas	#Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Detección #Respuesta	#Gestión de eventos de seguridad de la información	#Defensa
5.29	Seguridad de la información durante la interrupción	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Protección #Respuesta	#Continuidad	#Protección #Resiliencia
5.30	Preparación de las TIC para la continuidad de la actividad	#Correctivo	#Disponibilidad.	#Responder	#Continuidad	#Resiliencia
5.35	Revisión independiente de la seguridad de la información	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Identificar #proteger	#Seguridad_de_la_información	#Gobierno y ecosistema

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla A.2 (Final)

ISO/ Nivel de prueba IEC 27002 control(control) identificador	Nombre del control	Tipo de control	Propiedades de seguridad de la información	Conceptos de ciberseguridad	Capacidades operativas	Dominios de seguridad
5.37	Procedimientos operativos documentados	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Proteger #Recuperar	#Gestión_de_activos #Seguridad_física #Seguridad_del_sistema_y_de_la_red #Seguridad_de_las_aplicaciones #Configuración_segura #Gestión_de_la_identidad_y_del_acceso #Gestión_de_las_amenazas_y_de_la_vulnerabilidad #Continuidad #Gestión_de_eventos_de_seguridad_de_la_información	#Gobierno_y_Ecosistema #Protección #Defensa
6.4	Proceso disciplinario	#Preventivo #Correctivo	#Confidencialidad #Integridad #Disponibilidad	#Protección #Respuesta	#Seguridad_de_los_recursos_humanos	#Gobierno y ecosistema
8.7	Protección contra malware	#Prevención #Detección #Corrección	#Confidencialidad #Integridad #Disponibilidad	#Protección #Detección	#Seguridad_del_sistema_y_de_la_red #Protección_de_la_información	#Protección #Defensa
8.13	Copia de seguridad de la información	#Correctivo	#Integridad #Disponibilidad	#Recuperar	#Continuidad	#Protección
8.16	Actividades de monitoreo	#Detección #Corrección	#Confidencialidad #Integridad #Disponibilidad	#Detección #Respuesta	#Gestión de eventos de seguridad de la información	#Defensa

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

A.2 PERSPECTIVAS DE LA ORGANIZACIÓN

Dado que los atributos se utilizan para crear diferentes perspectivas de los controles, las organizaciones pueden descartar los ejemplos de atributos propuestos en este documento y crear sus propios atributos con diferentes valores para abordar necesidades específicas en la organización. Además, los valores asignados a cada atributo pueden diferir entre organizaciones ya que éstas pueden tener diferentes perspectivas sobre el uso o la aplicabilidad del control o de los valores asociados al atributo (si los valores son específicos del contexto de la organización). El primer paso es entender por qué es conveniente un atributo específico de la organización. Por ejemplo, si una organización ha construido sus planes de tratamiento de riesgos [véase el numeral la norma ISO/IEC 27001:2013, 6.1.3 e)] basándose en eventos, puede desear asociar un atributo de escenario de riesgo a cada control de este documento.

El beneficio de dicho atributo es agilizar el proceso de cumplimiento del requisito de la norma ISO/IEC 27001 relacionado con el tratamiento de riesgos, que consiste en comparar los controles determinados a través del proceso de tratamiento de riesgos (denominados controles “necesarios”), con los de la norma ISO/IEC 27001:2013, Anexo A (que se emiten a partir de este documento) para Asegurar que no se ha pasado por alto ningún control necesario.

Una vez conocidos el objetivo y los beneficios, el siguiente paso es determinar los valores de los atributos. Por ejemplo, la organización podría identificar 9 eventos:

1) pérdida o robo del dispositivo móvil;

2) pérdida o robo de las instalaciones de la organización;

3) fuerza mayor, vandalismo y terrorismo;

4) fallas de software, hardware, energía, internet y comunicaciones;

5) fraude;

6) piratería informática (hacking);

7) divulgación;

8) incumplimiento de la ley;

9) ingeniería social.

Por lo tanto, el segundo paso puede realizarse a través de la asignación de identificadores a cada evento (por ejemplo, E1, E2, ..., E9).

La tercera etapa consiste en copiar los identificadores y los nombres de los controles de este documento en una hoja de cálculo o una base de datos y asociar los valores de los atributos a cada control, recordando que cada control puede tener más de un valor de atributo.

El último paso es ordenar la hoja de cálculo o consultar la base de datos para extraer la información necesaria. Otros ejemplos de atributos organizativos (y posibles valores) comprenden:

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

a) madurez (valores de la serie ISO/IEC 33000 u otros modelos de madurez);

b) estado de implementación (por hacer, en proceso, parcialmente implementado, totalmente implementado)

c) prioridad (1, 2, 3, etc.)

d) áreas organizativas implicadas (seguridad, TIC, recursos humanos, alta dirección, etc.);

e) eventos;

f) activos involucrados;

e) construir y ejecutar, para diferenciar los controles utilizados en las diferentes etapas del ciclo de vida del servicio;

g) otros marcos con los que la organización trabaja o de los que puede hacer la transición.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

ANEXO B
(Informativo)

CORRESPONDENCIA DE LA ISO/IEC 27002:2022 (ESTE DOCUMENTO) CON LA ISO/IEC 27002:2013

El propósito de este anexo es proporcionar compatibilidad con la norma ISO/IEC 27002:2013 para las organizaciones que actualmente están al utilizar esa norma y ahora desean hacer la transición a esta edición.

La Tabla B.1 proporciona la correspondencia de los controles especificados en las Cláusulas 5 a la 8 con las de la ISO/IEC 27002:2013.

Tabla B.1 Correspondencia entre los controles de este documento y los controles de la norma ISO/IEC 27002:2013

ISO/ IEC 27002:2022 identificador del control	ISO/IEC 27002:2013. Identificador del control	Nombre del control
5.1	05.1.1, 05.1.2	Políticas de seguridad de la información
5.2	06.1.1	Funciones y responsabilidades en materia de seguridad de la información
5.3	06.1.2	Segregación de funciones
5.4	07.2.1	Responsabilidades de gestión
5.5	06.1.3	Contacto con las autoridades
5.6	06.1.4	Contacto con grupos de interés especiales
5.7	Nuevo	Inteligencia sobre amenazas
5.8	06.1.5, 14.1.1	Seguridad de la información en la gestión de proyectos
5.9	08.1.1, 08.1.2	Inventario de información y otros activos asociados
5.10	08.1.3, 08.2.3	Uso aceptable de la información y otros activos asociados
5.11	08.1.4	Devolución de activos
5.12	08.2.1	Clasificación de la información
5.13	08.2.2	Etiquetado de la información
5.14	13.2.1, 13.2.2, 13.2.3	Transferencia de información;
5.15	09.1.1, 09.1.2	Control de acceso
5.16	09.2.1	Gestión de identidad
5.17	09.2.4, 09.3.1, 09.4.3	Información de autentificación
5.18	09.2.2, 09.2.5, 09.2.6	Derechos de acceso
5.19	15.1.1	Seguridad de la información en las relaciones con los proveedores
5.20	15.1.2	Abordar la seguridad de la información en los acuerdos con los proveedores
5.21	15.1.3	Gestión de la seguridad de la información en la cadena de suministro de las TIC

Continúa...

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla B.1 (Continuación)

ISO/ IEC 27002:2022 identificador del control	ISO/IEC 27002:2013. Identificador del control	Nombre del control
5.22	15.2.1, 15.2.2	Seguimiento, revisión y gestión de cambios de los servicios de los proveedores
5.23	Nuevo	Seguridad de la información para el uso de servicios en la nube
5.24	16.1.1	Planificación y preparación de la gestión de incidentes de seguridad de la información
5.25	16.1.4	Evaluación y decisión sobre eventos de seguridad de la información
5.26	16.1.5	Respuesta a los incidentes de seguridad de la información
5.27	16.1.6	Aprendizaje de los incidentes de seguridad de la información
5.28	16.1.7	Recopilación de pruebas
5.29	17.1.1, 17.1.2, 17.1.3	Seguridad de la información durante la interrupción
5.30	Nuevo	Preparación de las TIC para la continuidad de la actividad
5.31	18.1.1, 18.1.5	Requisitos legales, reglamentarios y contractuales
5.32	18.1.2	Derechos de propiedad intelectual
5.33	18.1.3	Protección de los registros
5.34	18.1.4	Privacidad y protección de la IIP
5.35	18.2.1	Revisión independiente de la seguridad de la información
5.36	18.2.2, 18.2.3	Cumplimiento de las políticas, reglas y normas de seguridad de la información
5.37	12.1.1	Procedimientos operativos documentados
6.1	07.1.1	Selección
6.2	07.1.2	Condiciones del empleo
6.3	07.2.2	Sensibilización, educación y formación en materia de seguridad de la información
6.4	07.2.3	Proceso disciplinario
6.5	07.3.1	Responsabilidades tras el cese o el cambio de empleo
6.6	13.2.4	Acuerdos de confidencialidad o no divulgación
6.7	06.2.2	Trabajo remoto
6.8	16.1.2, 16.1.3	Informes de eventos de seguridad de la información
7.1	11.1.1	Perímetros de seguridad física
7.2	11.1.2, 11.1.6	Entrada física
7.3	11.1.3	Protección de oficinas, salas e instalaciones
7.4	Nuevo	Monitoreo de la seguridad física
7.5	11.1.4	Protección contra las amenazas físicas y medioambientales
7.6	11.1.5	Trabajo en zonas seguras
7.7	11.2.9	Escritorio limpio y pantalla limpia
7.8	11.2.1	Ubicación y protección de los equipos
7.9	11.2.6	Seguridad de los activos fuera de las instalaciones
7.10	08.3.1, 08.3.2, 08.3.3, 11.2.5	Medios de almacenamiento

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla B.1 (Continuación)

ISO/ IEC 27002:2022 identificador del control	ISO/IEC 27002:2013. Identificador del control	Nombre del control
7.11	11.2.2	Servicios públicos de respaldo
7.12	11.2.3	Seguridad del cableado
7.13	11.2.4	Mantenimiento del equipo
7.14	11.2.7	Eliminación segura o reutilización del equipo
8.1	06.2.1, 11.2.8	Dispositivos finales del usuario
8.2	09.2.3	Derechos de acceso privilegiados
8.3	09.4.1	Restricción del acceso a la información
8.4	09.4.5	Acceso al código fuente
8.5	09.4.2	Autenticación de seguridad
8.6	12.1.3	Gestión de capacidad
8.7	12.2.1	Protección contra malware
8.8	12.6.1, 18.2.3	Gestión de las vulnerabilidades técnicas
8.9	Nuevo	Gestión de la configuración
8.10	Nuevo	Eliminación de información
8.11	Nuevo	Enmascaramiento de datos
8.12	Nuevo	Prevención de la fuga de datos
8.13	12.3.1	Copia de seguridad de la información
8.14	17.2.1	Redundancia de las instalaciones de tratamiento de la información
8.15	12.4.1, 12.4.2, 12.4.3	Registros
8.16	Nuevo	Actividades de monitoreo
8.17	12.4.4	Sincronización del reloj
8.18	09.4.4	Uso de programas de utilidad privilegiados
8.19	12.5.1, 12.6.2	Instalación de software en sistemas operativos
8.20	13.1.1	Seguridad de las redes
8.21	13.1.2	Seguridad de los servicios de red
8.22	13.1.3	Segregación de redes
8.23	Nuevo	Filtrado web
8.24	10.1.1, 10.1.2	Uso de cifrado
8.25	14.2.1	Ciclo de vida de desarrollo seguro
8.26	14.1.2, 14.1.3	Requisitos de seguridad de la información
8.27	14.2.5	Arquitectura de sistemas seguros y principios de ingeniería
8.28	Nuevo	Codificación segura
8.29	14.2.8, 14.2.9	Pruebas de seguridad en el desarrollo y la aceptación
8.30	14.2.7	Desarrollo tercerizado
8.31	12.1.4, 14.2.6	Separación de los entornos de desarrollo, prueba y producción
8.32	12.1.2, 14.2.2, 14.2.3, 14.2.4	Gestión del cambio

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla B.1 (Final)

ISO/ IEC 27002:2022 identificador del control	ISO/IEC 27002:2013. Identificador del control	Nombre del control
8.33	14.3.1	Información de la prueba
8.34	12.7.1	Protección de los sistemas de información durante las pruebas de auditoría

La Tabla B.2 proporciona la correspondencia de los controles especificados en la ISO/IEC 27002:2013 con los de este documento.

Tabla B.2 Correspondencia entre los controles de la norma ISO/IEC 27002:2013 y los controles de este documento

ISO/IEC 27002:2013. identificador del control	ISO/ IEC 27002:2022 Identificador del control	Nombre de control de acuerdo con la norma ISO/IEC 27002:2013
5		Políticas de seguridad de la información
5.1		Dirección de la gestión de la seguridad de la información
5.1.1	5.1	Políticas de seguridad de la información
5.1.2	5.1	Revisión de las políticas de seguridad de la información
6		Organización de la seguridad de la información
6.1		Organización interna
6.1.1	5.2	Funciones y responsabilidades en materia de seguridad de la información
6.1.2	5.3	Segregación de funciones
6.1.3	5.5	Contacto con las autoridades
6.1.4	5.6	Contacto con grupos de interés especiales
6.1.5	5.8	Seguridad de la información en la gestión de proyectos
6.2		Dispositivos móviles y teletrabajo
6.2.1	8.1	Política de dispositivos móviles
6.2.2	6.7	Teletrabajo
7		Seguridad de los recursos humanos
7.1		Precontratación
7.1.1	6.1	Selección
7.1.2	6.2	Condiciones del empleo
7.2		Durante el empleo
7.2.1	5.4	Responsabilidades de gestión
7.2.2	6.3	Sensibilización, educación y formación en materia de seguridad de la información
7.2.3	6.4	Proceso disciplinario
7.3		Terminación y cambio de empleo
7.3.1	6.5	Cese o cambio de responsabilidades laborales
8		Gestión de activos

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla B.2 (Continuación)

ISO/IEC 27002:2013. identificador del control	ISO/ IEC 27002:2022 Identificador del control	Nombre de control de acuerdo con la norma ISO/IEC 27002:2013
8.1		Responsabilidad de los activos
8.1.1	5.9	Inventario de activos
8.1.2	5.9	Propiedad de los activos
8.1.3	5.10	Uso aceptable de los activos
8.1.4	5.11	Devolución de activos
8.2		Clasificación de la información
8.2.1	5.12	Clasificación de la información
8.2.2	5.13	Etiquetado de la información
8.2.3	5.10	Manejo de activos
8.3		Manejo de los medios de almacenamiento
8.3.1	7.10	Gestión de medios extraíbles
8.3.2	7.10	Eliminación de medios de almacenamiento
8.3.3	7.10	Transferencia de medios físicos
9		Control de acceso
9.1		Requisitos comerciales del control de acceso
9.1.1	5.15	Política de control de acceso
9.1.2	5.15	Acceso a redes y servicios de red
9.2		Gestión del acceso de los usuarios
9.2.1	5.16	Registro y baja de usuarios
9.2.2	5.18	Aprovisionamiento del acceso de los usuarios
9.2.3	8.2	Gestión de los derechos de acceso privilegiados
9.2.4	5.17	Gestión de la información secreta de autentificación de los usuarios
9.2.5	5.18	Revisión de los derechos de acceso del usuario
9.2.6	5.18	Eliminación o ajuste de los derechos de acceso
9.3		Responsabilidades del usuario
9.3.1	5.17	Uso de información secreta de autenticación
9.4		Control de acceso al sistema y a las aplicaciones
9.4.1	8.3	Restricción del acceso a la información
9.4.2	8.5	Procedimientos seguros de inicio de sesión
9.4.3	5.17	Sistema de gestión de contraseñas
9.4.4	8.18	Uso de programas de utilidad privilegiados
9.4.5	8.4	Control de acceso al código fuente del programa
10		Cifrado
10.1		Controles de cifrados
10.1.1	8.24	Política de uso de controles cifrados
10.1.2	8.24	Gestión de claves
11		Seguridad física y medioambiental
11.1		Zonas seguras

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla B.2 (Continuación)

ISO/IEC 27002:2013. identificador del control	ISO/ IEC 27002:2022 Identificador del control	Nombre de control de acuerdo con la norma ISO/IEC 27002:2013
11.1.1	7.1	Perímetros de seguridad física
11.1.2	7.2	Controles físicos de entrada
11.1.3	7.3	Protección de oficinas, salas e instalaciones
11.1.4	7.5	Protección contra las amenazas externas y medioambientales
11.1.5	7.6	Trabajo en zonas seguras
11.1.6	7.2	Zonas de entrega y carga
11.2		Equipo
11.2.1	7.8	Ubicación y protección de los equipos
11.2.2	7.11	Servicios públicos de respaldo
11.2.3	7.12	Seguridad del cableado
11.2.4	7.13	Mantenimiento del equipo
11.2.5	7.10	Retirada de activos
11.2.6	7.9	Seguridad de equipos y activos fuera de las instalaciones
11.2.7	7.14	Eliminación segura o reutilización de los equipos
11.2.8	8.1	Equipo de usuario desatendido
11.2.9	7.7	Política de escritorio limpio y pantalla limpia
12		Seguridad de las operaciones
12.1		Procedimientos operacionales y responsabilidades
12.1.1	5.37	Procedimientos operativos documentados
12.1.2	8.32	Gestión del cambio
12.1.3	8.6	Gestión de capacidad
12.1.4	8.31	Separación de los entornos de desarrollo, prueba y operación
12.2		Protección contra el malware
12.2.1	8.7	Controles contra malware
12.3		Copia de seguridad
12.3.1	8.13	Copia de seguridad de la información
12.4		Registro y monitoreo
12.4.1	8.15	Registro de evento
12.4.2	8.15	Protección de la información de registro
12.4.3	8.15	Registros del administrador y del operador
12.4.4	8.17	Sincronización del reloj
12.5		Control del software operativo
12.5.1	8.19	Instalación de software en sistemas operativos
12.6		Gestión de la vulnerabilidad técnica
12.6.1	8.8	Gestión de las vulnerabilidades técnicas
12.6.2	8.19	Restricciones a la instalación de software
12.7		Consideraciones sobre la auditoría de los sistemas de información

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla B.2 (Continuación)

ISO/IEC 27002:2013. identificador del control	ISO/ IEC 27002:2022 Identificador del control	Nombre de control de acuerdo con la norma ISO/IEC 27002:2013
12.7.1	8.34	Controles de auditoría de los sistemas de información
13		Seguridad de las comunicaciones
13.1		Instalaciones de gestión de la seguridad de la red.
13.1.1	8.20	Controles de red
13.1.2	8.21	Seguridad de los servicios de red
13.1.3	8.22	Separación en las redes
13.2		Transferencia de información;
13.2.1	5.14	Políticas y procedimientos de transferencia de información
13.2.2	5.14	Acuerdos sobre la transferencia de información
13.2.3	5.14	Mensajería electrónica
13.2.4	6.6	Acuerdos de confidencialidad o no divulgación
14		Adquisición, desarrollo y mantenimiento del sistema
14.1		Requisitos de seguridad de los sistemas de información
14.1.1	5.8	Análisis y especificación de los requisitos de seguridad de la información
14.1.2	8.26	Seguridad de los servicios de aplicaciones en las redes públicas
14.1.3	8.26	Protección de las transacciones de los servicios de aplicación
14.2		Seguridad en los procesos de desarrollo y apoyo
14.2.1	8.25	Política de desarrollo segura
14.2.2	8.32	Procedimientos de control de cambios del sistema
14.2.3	8.32	Revisión técnica de las aplicaciones tras los cambios de plataforma operativa
14.2.4	8.32	Restricciones a los cambios en los paquetes de software
14.2.5	8.27	Principios de ingeniería de sistemas seguros
14.2.6	8.31	Entorno de desarrollo seguro
14.2.7	8.30	Desarrollo tercerizado
14.2.8	8.29	Pruebas de seguridad del sistema
14.2.9	8.29	Pruebas de aceptación del sistema
14.3		Datos de prueba
14.3.1	8.33	Protección de los datos de prueba
15		Relaciones con los proveedores
15.1		Seguridad de la información en las relaciones con los proveedores
15.1.1	5.19	Política de seguridad de la información para las relaciones con los proveedores
15.1.2	5.20	Abordar la seguridad en los acuerdos con los proveedores
15.1.3	5.21	Cadena de suministro de tecnologías de la información y la comunicación
15.2		Gestión de la prestación de servicios de los proveedores

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Tabla B.2 (Final)

ISO/IEC 27002:2013. identificador del control	ISO/ IEC 27002:2022 Identificador del control	Nombre de control de acuerdo con la norma ISO/IEC 27002:2013
15.2.1	5.22	Seguimiento y revisión de los servicios de los proveedores
15.2.2	5.22	Gestión de los cambios en los servicios de los proveedores
16		Gestión e incidentes de seguridad de la información
16.1		Gestión de incidentes y mejoras en la seguridad de la información
16.1.1	5.24	Responsabilidades y procedimientos
16.1.2	6.8	Notificación de sucesos relacionados con la seguridad de la información
16.1.3	6.8	Notificación de deficiencias en la seguridad de la información
16.1.4	5.25	Evaluación y decisión sobre eventos de seguridad de la información
16.1.5	5.26	Respuesta a los incidentes de seguridad de la información
16.1.6	5.27	Aprendizaje de los incidentes de seguridad de la información
16.1.7	5.28	Recopilación de pruebas
17		Aspectos de la seguridad de la información en la gestión de la continuidad de la actividad
17.1		Continuidad de la seguridad de la información
17.1.1	5.29	Planificación de la continuidad de la seguridad de la información
17.1.2	5.29	Implementación de la continuidad de la seguridad de la información
17.1.3	5.29	Verificación, revisión y evaluación de la continuidad de la seguridad de la información
17.2		Redundancias
17.2.1	8.14	Disponibilidad de instalaciones para el tratamiento de la información
18		Cumplimiento
18.1		Cumplimiento de los requisitos legales y contractuales
18.1.1	5.31	Identificación de la legislación aplicable y de los requisitos contractuales
18.1.2	5.32	Derechos de propiedad intelectual
18.1.3	5.33	Protección de los registros
18.1.4	5.34	Privacidad y protección de la información personal identificable
18.1.5	5.31	Regulación de los controles cifrados
18.2		Revisiones de la seguridad de la información
18.2.1	5.35	Revisión independiente de la seguridad de la información
18.2.2	5.36	Cumplimiento de las políticas y normas de seguridad
18.2.3	5.36, 8.8	Revisión del cumplimiento técnico

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

BIBLIOGRAFÍA

[1] NTC- ISO 9000, *Sistema de Gestión de Calidad. Fundamentos y vocabulario*.

[2] NTC-ISO 55001, *Gestión de Activos. Sistema de Gestión. Requisitos.*

[3] ISO/IEC 11770 (*all parts*), *Information security. Key management*.

[4] ISO/IEC 15408 (*all parts*), *Information technology. Security techniques - Evaluation criteria for IT security*.

[5] ISO 15489 (*all parts*), *Information and documentation. Records management*.

[6] ISO/IEC 17788, *Information technology. Cloud computing. Overview and vocabulary*.

[7] ISO/IEC 17789, *Information technology. Cloud computing. Reference architecture*.

[8] ISO/IEC 19086 (*all parts*), *Cloud computing. Service level agreement* (SLA) *framework*.

[9] ISO/IEC 19770 (*all parts*), *Information technology - IT asset management*.

[10] ISO/IEC 19941, *Information technology. Cloud computing. Interoperability and portability*.

[11] ISO/IEC 20889, *Privacy enhancing data de-identification terminology and classification of techniques.*

[12] ISO 21500, *Project, programme and portfolio management. Context and concepts*.

[13] ISO 21502, *Project, programme and portfolio management. Guidance on project management.*

[14] ISO 22301, *Security and resilience. Business continuity management systems. Requirements*.

[15] ISO 22313, *Security and resilience. Business continuity management systems. Guidance on the use of* ISO 22301.

[16] ISO/TS 22317, *Societal security. Business continuity management systems - Guidelines for business impact analysis* (BIA).

[17] ISO 22396, *Security and resilience. Community resilience. Guidelines for information exchange between organizations*.

[18] ISO/IEC TS 23167, *Information technology. Cloud computing. Common technologies and techniques*.

[19] ISO/IEC 23751[2)], *Information technology. Cloud computing and distributed platforms. Data sharing agreement* (DSA) *framework*.

[20] ISO/IEC 24760 (*all parts*), *IT Security and Privacy - A framework for identity management.*

[2)] En preparación. Etapa en el momento de la publicación: ISO/IEC PRF 23751:2022.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

[21] ISO/IEC 27001:2013, *Information technology. Security techniques. Information security management systems. Requirements*.

[22] ISO/IEC 27005, *Information technology. Security techniques. Information security risk management*.

[23] ISO/IEC 27007, *Information security, cybersecurity and privacy protection. Guidelines for information security management systems auditing*.

[24] ISO/IEC TS 27008, *Information technology. Security techniques. Guidelines for the assessment of information security controls*.

[25] ISO/IEC 27011, *Information technology. Security techniques. Code of practice for Information security controls based on* ISO/IEC 27002 *for telecommunications organizations*.

[26] ISO/IEC TR 27016, *Information technology. Security techniques. Information security management - Organizational economics*.

[27] ISO/IEC 27017, *Information technology. Security techniques. Code of practice for information security controls based on* ISO/IEC 27002 *for cloud services*.

[28] ISO/IEC 27018, *Information technology. Security techniques. Code of practice for protection of personally identifiable information* (PII) *in public clouds acting as PII processors*.

[29] ISO/IEC 27019, *Information technology. Security techniques. Information security controls for the energy utility industry*.

[30] ISO/IEC 27031, *Information technology. Security techniques. Guidelines for information and communication technology readiness for business continuity*.

[31] ISO/IEC 27033 (*all parts*), *Information technology. Security techniques. Network security*.

[32] ISO/IEC 27034 (*all parts*), *Information technology. Application security*.

[33] ISO/IEC 27035 (*all parts*), *Information technology. Security techniques. Information security incident management*.

[34] ISO/IEC 27036 (*all parts*), *Information technology. Security techniques. Information security for supplier relationships*.

[35] ISO/IEC 27037, *Information technology. Security techniques. Guidelines for identification, collection, acquisition and preservation of digital evidence*.

[36] ISO/IEC 27040, *Information technology. Security techniques. Storage security*.

[37] ISO/IEC 27050 (*all parts*), *Information technology. Electronic discovery*.

[38] ISO/IEC TS 27110, *Information technology, cybersecurity and privacy protection. Cybersecurity framework development guidelines*.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

[39] ISO/IEC 27701, *Security techniques. Extension to* ISO/IEC 27001 *and* ISO/IEC 27002 *for privacy information management. Requirements and guidelines.*

[40] ISO 27799, *Health informatics. Information security management in health using* ISO/IEC 27002.

[41] ISO/IEC 29100, *Information technology. Security techniques. Privacy framework*.

[42] ISO/IEC 29115, *Information technology. Security techniques. Entity authentication assurance framework*.

[43] ISO/IEC 29134, *Information technology. Security techniques. Guidelines for privacy impact assessment*.

[44] ISO/IEC 29146, *Information technology. Security techniques. A framework for access management.*

[45] ISO/IEC 29147, *Information technology. Security techniques. Vulnerability disclosure*.

[46] ISO 30000, *Ships and marine technology. Ship recycling management systems. Specifications for management systems for safe and environmentally sound ship recycling facilities*.

[47] ISO/IEC 30111, *Information technology. Security techniques. Vulnerability handling processes*.

[48] ISO 31000:2018, *Risk management. Guidelines*.

[49] IEC 31010, *Risk management. Risk assessment techniques*.

[50] ISO/IEC 22123 (*all parts*), *Information technology. Cloud computing*.

[51] ISO/IEC 27555, *Information security, cybersecurity and privacy protection. Guidelines on personally identifiable information deletion*.

[52] *Information Security Forum* (ISF). *The ISF Standard of Good Practice for Information Security* 2020, *August* 2018. *Available* at https://www.securityforum.org/tool/standard-of-good-practice-for-information-security-2020/.

[53] ITIL® Foundation, ITIL 4 edition, AXELOS, February 2019, ISBN: 9780113316076.

[54] *National Institute of Standards and Technology* (NIST), SP 800-37, *Risk Management Framework for Information Systems and Organizations: A System Life Cycle Approach for Security and Privacy, Revision* 2. *December* 2018 [*viewed* 2020-07-31]. *Available at* https://doi.org/10.6028/NIST.SP.800-37r2.

[55] *Open Web Application Security Project* (OWASP). OWASP Top Ten - 2017, *The Ten Most Critical Web Application Security Risks*, 2017 [*viewed* 2020-07-31]. *Available at* https://owasp.org/www-project-top-ten/OWASP_Top_Ten_2017/.

[56] *Open Web Application Security Project* (OWASP). OWASP *Developer Guide*, [*online*] [*viewed* 2020-10-22]. *Available at* https://github.com/OWASP/DevGuide.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

[57] *National Institute of Standards and Technology* (NIST), SP 800-63B, *Digital Identity Guidelines; Authentication and Lifecycle Management. February* 2020 [*viewed* 2020-07-31]. *Available at* https://doi.org/10.6028/NIST.SP.800-63b.

[58] OASIS, *Structured Threat Information Expression. Available at* https://www.oasis-open.org/standards#stix2.0.

[59] OASIS, *Trusted Automated Exchange of Indicator Information. Available at* https://www.oasis-open.org/standards#taxii2.0.

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

DOCUMENTO DE REFERENCIA

INTERNATIONAL ORGANIZATION FOR STANDARDIZATION. *Information security, Cybersecurity and Privacy Protection. Information Security Controls,* Geneve, 2022, 152p (ISO/IEC 27002:2022).

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta

Colombia

Apartadó
apartado@icontec.org

Armenia
armenia@icontec.org

Barranquilla
barranquilla@icontec.org

Barrancabermeja
barrancabermeja@icontec.org

Bogotá
bogota@icontec.org

Bucaramanga
bucaramanga@icontec.org

Cali
cali@icontec.org

Cartagena
cartagena@icontec.org

Cúcuta
cucuta@icontec.org

Manizales
manizales@icontec.org

Medellín
medellin@icontec.org

Montería
monteria@icontec.org

Ibagué
ibague@icontec.org

Neiva
neiva@icontec.org

Pereira
pereira@icontec.org

Pasto
pasto@icontec.org

Villavicencio
villavicencio@icontec.org

Resto del mundo

Bolivia
bolivia@icontec.org

Ecuador
ecuador@icontec.org

Honduras
honduras@icontec.org

Panamá
panama@icontec.org

Costa Rica
costarica@icontec.org

El Salvador
elsalvador@icontec.org

México
mexico@icontec.org

República Dominicana
republicadominicana@icontec.org

Chile
chile@icontec.org

Guatemala
guatemala@icontec.org

Nicaragua
nicaragua@icontec.org

Perú
peru@icontec.org

Canales de atención al cliente:
Bogotá: **607 8888**
Resto del país: **01 8000 94 9000**
cliente@icontec.org
www.icontec.org

icontec.org

Ejemplar para uso exclusivo - ICONTEC - DEMO MARZO -

Impreso por: Consulta